Curso Online

COBIT

FUNDAMENTOS EM GOVERNANÇA DE TI



Todos os direitos de cópia reservados. Não é permitida a distribuição física ou eletrônica deste material sem a permissão expressa do autor.

Bem vindo ao Curso de COBIT

Este curso foi desenvolvido a partir do COBIT 4.0, fornecido pelo ISACA®. O propósito deste curso é ajudar você a entender os conceitos de Governança de TI e o uso do Framework COBIT (Control Objectives for Information and related Technology - Objetivos de Controle para Informações e Tecnologia correspondente), seu propósito e como aplicá-lo na prática. Além disto, no final deste curso você estará apto para realizar a Certificação COBIT FOUNDATION.

Este curso tem a duração de **6 horas**, sendo dividido em 5 módulos:

- **Introdução a Governança de TI**
- **Introdução ao COBIT**
- **Objetivos de Controle**
- **Diretrizes de Gerenciamento e Auditoria**
- **Produtos e Suporte do ITGI**

Sobre o Curso

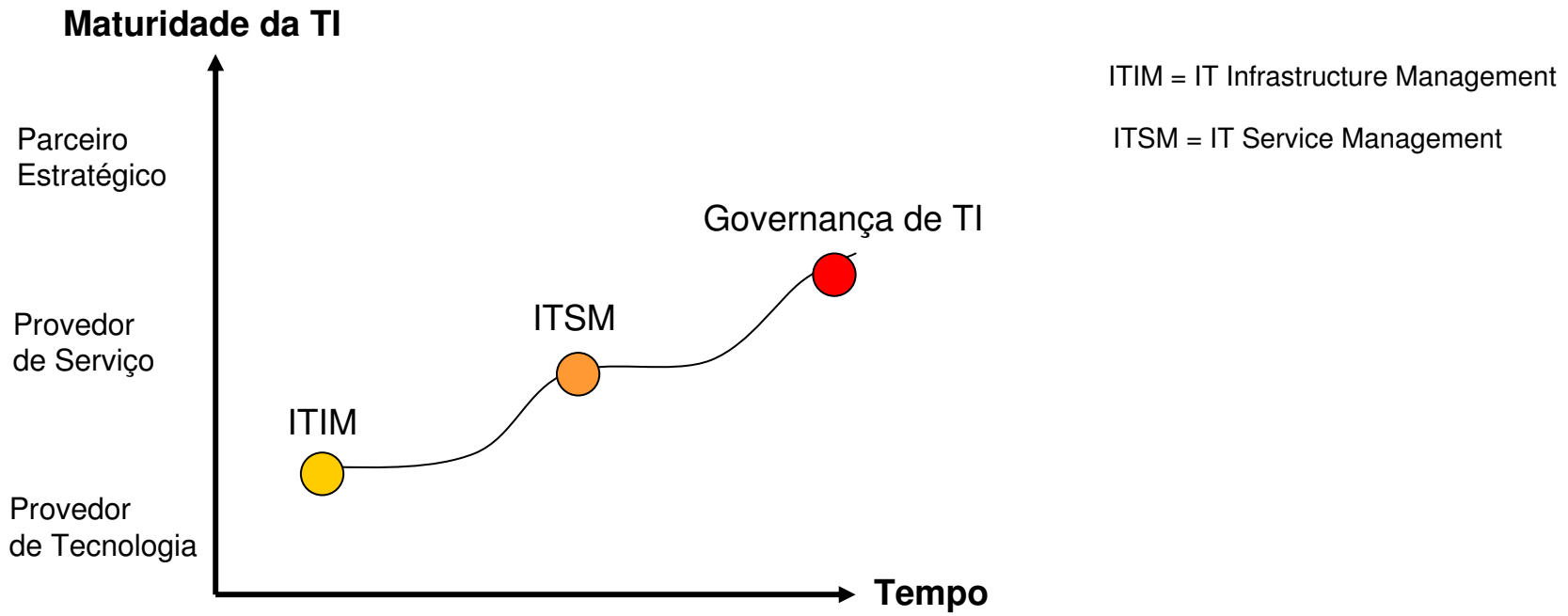
Ao final deste curso você irá aprender:

- Sobre Evolução da Função da TI ao longo dos anos
- A importância da TI e como as questões de TI afetam as organizações;
- Conceitos de Governança Corporativa e Governança de TI;
- A necessidade de um framework de controle para a Governança de TI;
- Como o COBIT atende os requisitos de um framework de Governança de TI;
- O relacionamento do COBIT com outros padrões e melhores práticas de mercado;
- Estrutura do COBIT em detalhes(Objetivos de Controle, Práticas de Controle, Diretrizes de Gerenciamento, Diretrizes de Auditoria) ;
- Os benefícios e desvantagens do uso do COBIT
- Os produtos e suporte fornecido pelo ITGI (IT Governance Institute)

Evolução da TI

Evolução da TI

A TI tem atuado como um provedor de tecnologia ajudando o negócio a realizar suas atividades de forma mais eficiente desde o seu surgimento. Durante anos a TI tem se tornado uma retaguarda para o negócio, chegando no ponto de realizar algumas funções que até então seriam impossíveis sem a sua ajuda. A TI é hoje um elemento essencial para a organização.



Evolução da Função de TI dentro das organizações

Evolução da TI

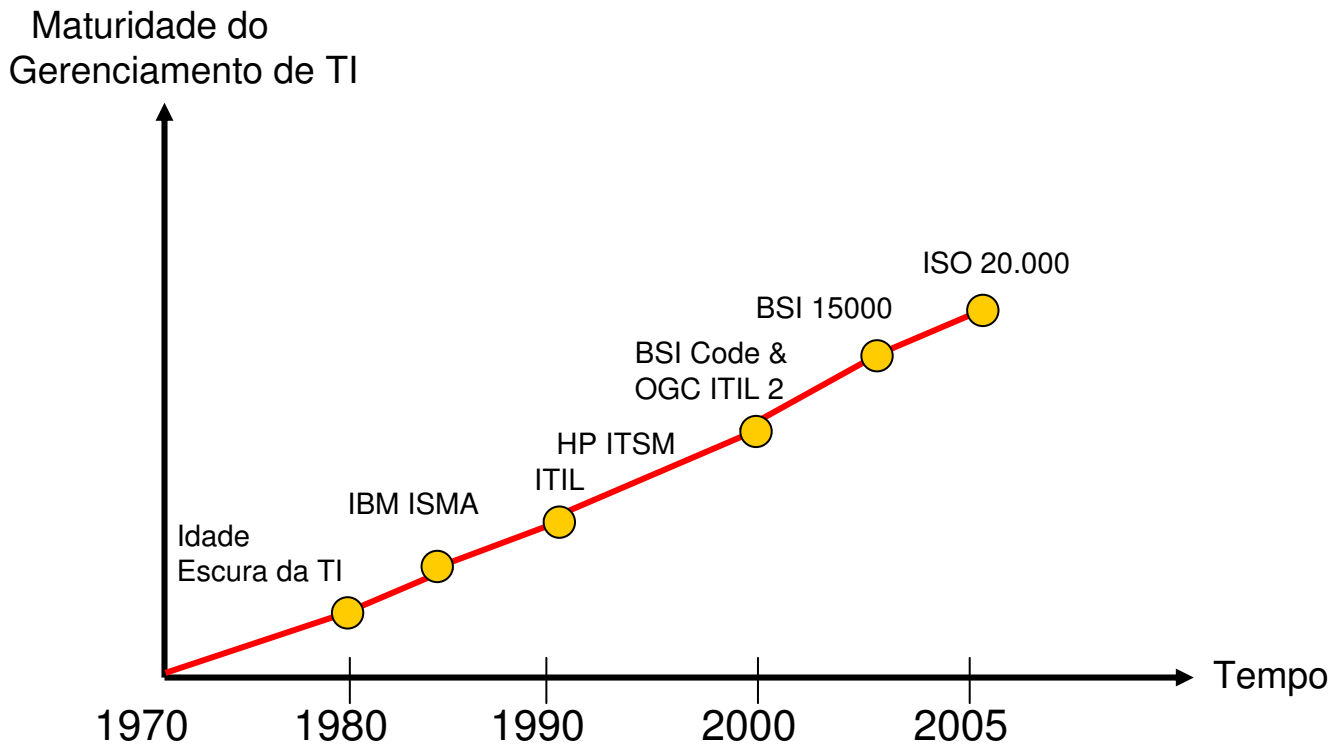
A evolução da TI parte da atuação como Provedor de Tecnologia para um Parceiro Estratégico. A partir do momento em que a atuação da TI começa a se envolver com o gerenciamento de valor para o negócio, implementando Governança de TI, ela começa a se transformar em um parceiro de negócio, possibilitando novas oportunidades de negócios. Neste estágio, os processos de TI são integrados com o processos do ciclo de vida do negócio, melhora a qualidade do serviço e agilidade no negócio.

A tabela abaixo ilustra a contribuição da TI para o negócio

Provedor de Serviços	Parceiro Estratégico
▪A TI busca eficiência	▪A TI busca o crescimento do negócio
▪Os orçamentos são baseados em benchmarks externos	▪Os orçamentos são baseados na estratégia do negócio
▪A TI atua independente do negócio	▪A TI é inseparável do negócio
▪A TI é vista como uma despesa a ser controlada	▪A TI é vista como um investimento a ser gerenciado
▪Os gerentes de TI são técnicos	▪Os gerentes de TI são solucionadores de problemas de negócio

Evolução do Gerenciamento de TI

Para ajudar as organizações a se moverem ao longo do caminho de transição, várias metodologias tem sido definidas durante anos. A figura abaixo mostra a evolução destas metodologias e seus níveis de maturidade em termos de Gerenciamento de Serviços.



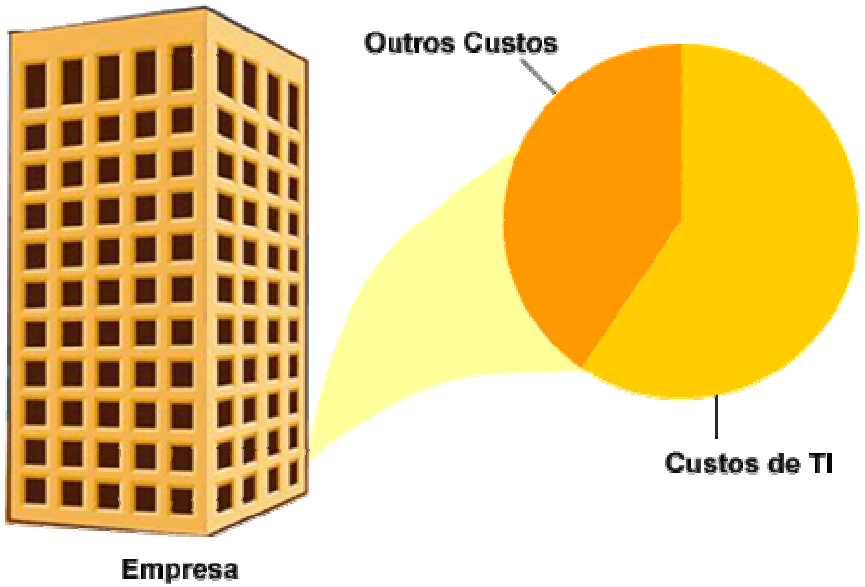
Evolução das metodologias de gerenciamento de TI

Desafios da TI

Desafios da TI

Por muitos anos, algumas organizações puderam continuar seus negócios, ainda que tivessem pouco apoio da TI. Hoje a realidade é diferente, a Tecnologia da Informação é um fator crítico de sucesso para a organização. Com o aumento do peso de importância dentro da organização, a TI passou a ter os seguintes desafios:

- Manter os serviços de TI disponíveis
- Gerar valor nos projetos de TI
- Redução de Custos e Riscos
- Crescimento da complexidade dos ambientes de TI
- Aumento da pressão para alavancar tecnologia nas estratégias de negócio
- Conformidade com normas regulatórias
- Manter segurança sobre as informações



Manter os Serviços de TI disponíveis

Para a maioria das empresas que dependem de TI para realizar suas operações, a disponibilidade do serviço se tornou extramente crítica a ponto que se TI parar o negócio também pára. A disponibilidade dos sistemas de informações contribuem para a produtividade dos usuários, e o gerenciamento de TI deve assegurar a alta disponibilidade dos sistemas.



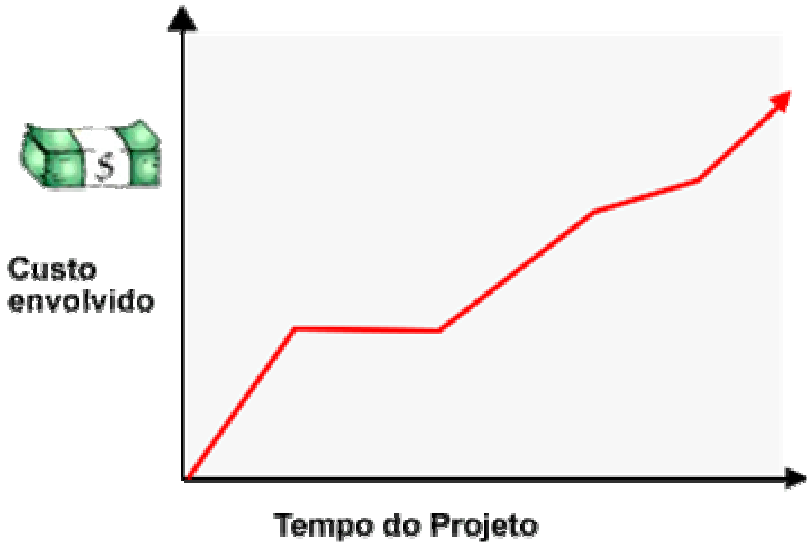
Se a TI parar pode acarretar nos seguintes problemas:

- Processos críticos do negócio como processamento de pedidos são interrompidos
- O pessoal da área administrativa fica impossibilitado de executar suas atividades diárias como envio de e-mails ou acesso a documentos.
- Os clientes ficam sem acesso aos call centers.
- Isto pode resultar ainda em perda de negócios, redução de lucros e até mesmo interferir na reputação da empresa.

Gerar valor nos projetos de TI

Devido aos altos investimentos realizados em TI e a importância estratégica dos Projetos de TI, as empresas precisam obter retorno sobre o valor investido. A maioria dos projetos mal gerenciados ultrapassam o orçamento inicial ou o prazo de entrega, onde os seus principais problemas são:

- Requisitos mal definidos
- Os sistemas são muito complexos para serem desenvolvidos
- Falta de pessoas capacitadas
- Avaliação subestimada do esforço necessário
- Falta de Gerenciamento do Projeto



Redução de Custos e Riscos

Os orçamentos estão cada vez mais apertados para a TI e isto cria uma pressão para o departamentos de TI escolherem o *portfolio* de serviços de TI necessários dentro do orçamento. Como a TI não é vista como uma competência principal dentro empresa, e sim vista como uma *commodity* ou uma necessidade do negócio, os riscos que ela cria tornam-se mais importantes do que as vantagens que ela cria. As principais razões para este aumento de custos e riscos são:

- A maioria das empresas não sabem como associar os custos aos seus ativos de TI.
- Os orçamentos operacionais aumentam a cada ano devido aos licenciamentos, manutenções e contratos de outsourcing.
- Projetos mal sucedidos levam a perdas financeiras.
- Os gastos relacionados a TI que são realizados às unidades de negócio não estão sendo monitorados.

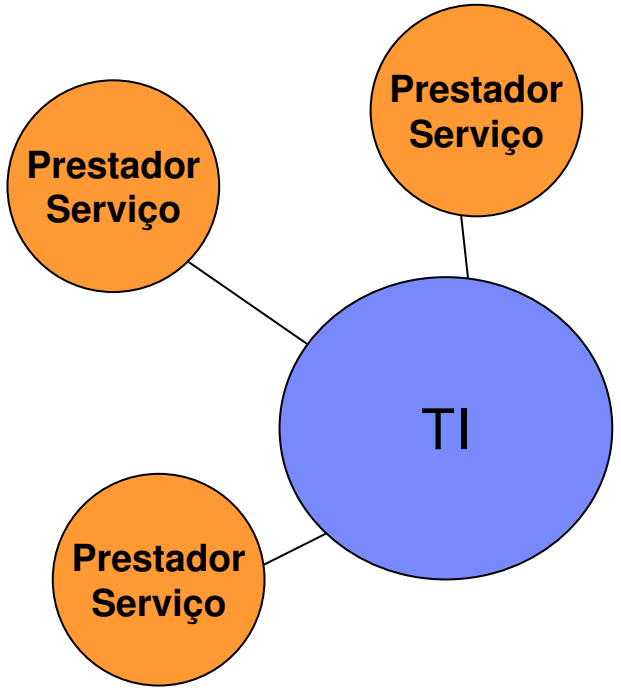


Crescimento da complexidade dos ambientes de TI

Hoje o desenvolvimento tecnológico é rápido, existem inúmeros fornecedores e soluções disponíveis no mercado. O controle de TI tem expandido para poder gerenciar os inúmeros prestadores de serviço.

Os problemas típicos devido a este ambiente são:

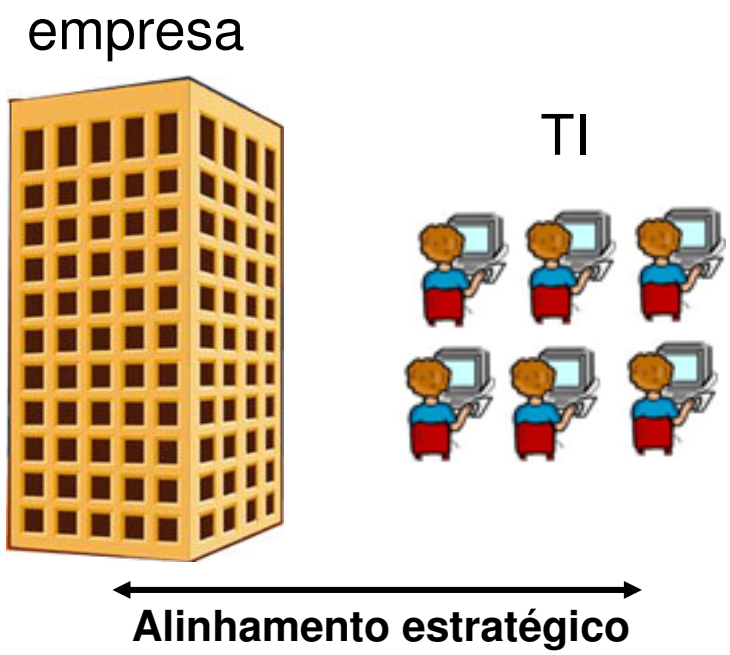
- Manter a competência técnica da equipe de TI
- Gerenciar diversas infra-estruturas de TI em várias filiais
- Adaptar-se a rápidas mudanças e novos desenvolvimentos
- Gerenciar relações com provedores de serviços externo



Alinhar a TI com o negócio

O interesse do uso de TI nas empresas e a inovação contínua propiciada pela TI criam uma vantagem tecnológica para a empresa. A utilização de tecnologias mais recentes está em alta entre as empresas qualificadas tecnologicamente. A meta estratégica para estas empresas será de obter uma vantagem tecnológica sobre os seus concorrentes. O desenvolvimento de TI deve estar alinhado com o negócio da empresa para poder criar estas vantagens de negócio. Entretanto na maioria das organizações as lacunas entre o que os usuários esperam e o que a TI pode fornecer continua a existir devido as seguintes razões:

- Falta de definição dos requisitos de negócio
- Falta de capacidade de esclarecer as prioridades
- Complexidade dos projetos
- Falta de comprometimento da alta direção
- Problemas de comunicação entre o negócio e a TI

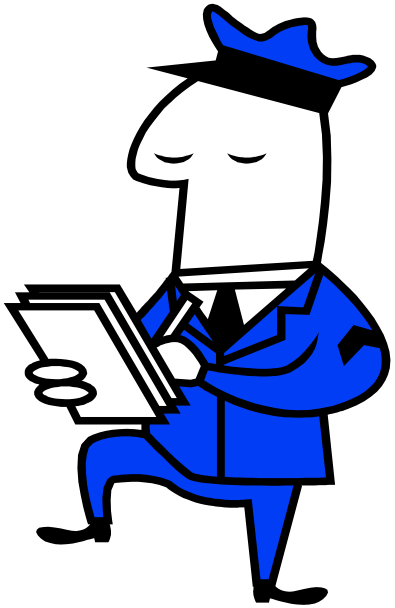


Conformidade com normas regulatórias

Existe muita pressão sobre as empresas para mostrar que elas são eficientes (conformidade com os padrões e regulamentos) e eficazes (lucrativas). Os Regulamentos que governam as operações do negócio impactam o ambiente TI da empresa.

A TI deve dar atenção aos requisitos regulatórios tanto nacionais como internacionais, os quais se referem a:

- Governança Corporativa e relatórios financeiros
- Privacidade e segurança

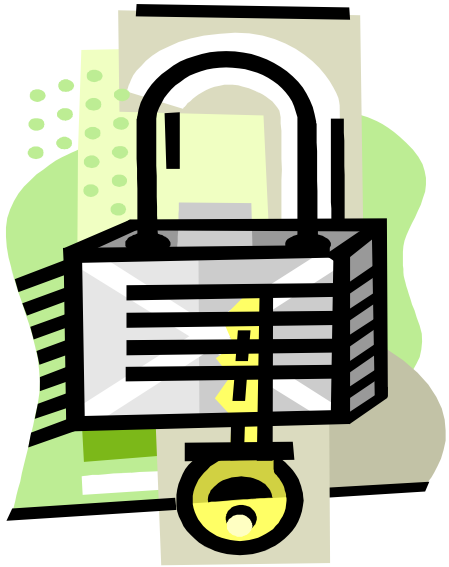


Manter segurança sobre as informações

Assegurar a segurança dos dados e infra-estrutura é uma das metas básicas do gerenciamento de TI. Com o aumento da complexidade dos sistemas hoje, vulnerabilidades e ameaças aumentam, desta forma nunca se pode ter 100% de segurança para a infra-estrutura de TI. Da mesma forma que há pressão para redução de custos, há pressão para aumentar a segurança sobre os dados.

Estes riscos têm aumentado devido ao seguintes fatores:

- Uso da Internet expondo os sistemas internos da empresa para o mundo.
- Vírus e ataque de hackers.
- Aumento da necessidade por informações
- Complexidades técnicas dos ambientes de TI e problemas de segurança associados.
- Falta de responsabilidade dos usuários em relação ao uso dos serviços de TI.



Introdução a Governança de TI

O que vamos ver agora?

- Quais sãos os princípios da Governança de TI?
- Como a Governança de TI pode ajudar a gerenciar as questões de gerenciamento de TI?
- Quem é responsável pela Governança de TI?
- Quais são os benefícios da Governança de TI?

O que é Governança de TI?

É um conjunto de estruturas e processos que visa garantir que a TI suporte e maximize adequadamente os objetivos e estratégias de negócio da organização, adicionando valores aos serviços entregues, balanceando os riscos e obtendo o retorno sobre os investimentos em TI.

A Governança de TI engloba:

- Princípios de Governança de TI
- Stakeholders de Governança de TI
- Escopo de Governança de TI

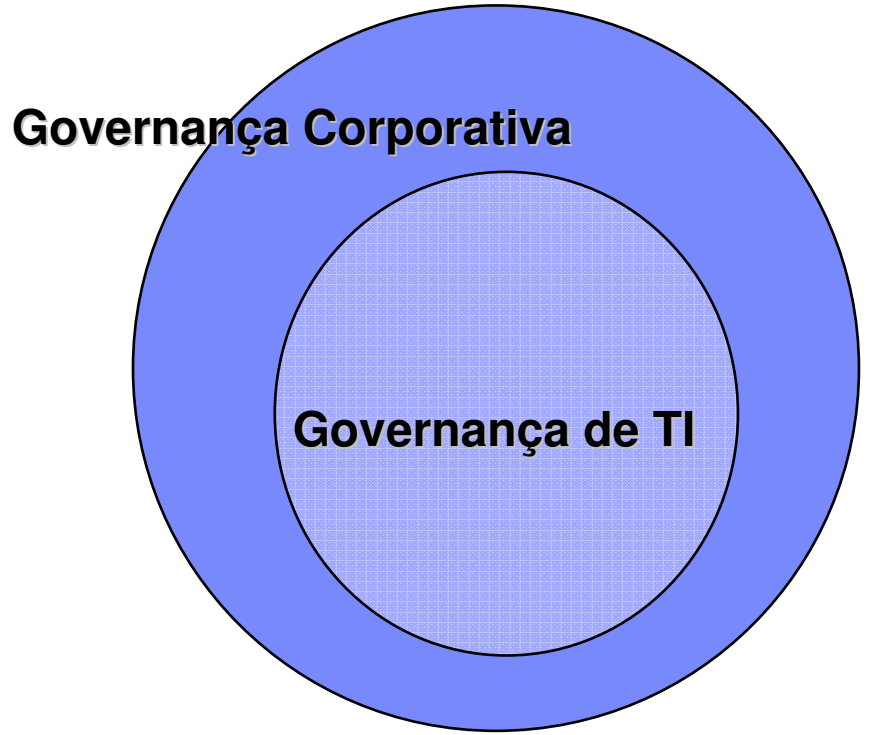


Conceito baseado no ITGI

Governança de TI faz parte da Governança Corporativa

O aumento da demanda por a transparência e conformidade faz com que Conselho Administrativo e Executivos estendam a governança para a TI e forneçam liderança, estruturas organizacionais e processos que assegurem que as estratégicas de TI sustem e cubram as estratégias e objetivos da empresa. A Governança de TI não é um disciplina isolada, ela é parte integral da governança corporativa.

As responsabilidades na Governança de TI fazem parte do framework de governança corporativo e devem fazer parte da agenda de planejamento estratégico dos diretores da empresa. De forma mais simples, para a dependência crítica sobre os sistemas de TI, a governança de ser efetiva, transparente e responsável. Desta forma é possível assegurar que as expectativas sobre TI sejam alcançadas e os riscos sobre TI sejam gerenciados.



Por que a Governança de TI é importante?

Atualmente, é impossível imaginar uma empresa sem uma forte área de sistemas de informações (TI), para manipular os dados operacionais e prover informações gerenciais aos executivos para tomadas de decisões. A criação e manutenção de uma infra-estrutura de TI, incluindo profissionais especializados requerem altos investimentos.

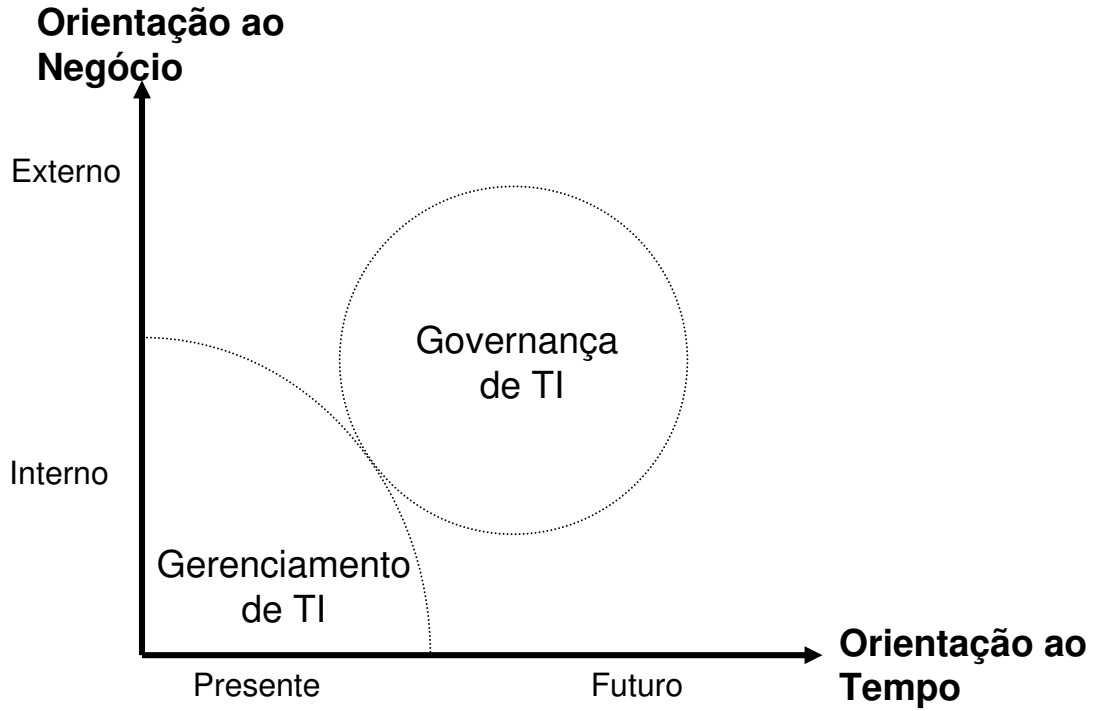
Algumas vezes a alta direção da empresa coloca restrições aos investimentos de TI por duvidarem dos reais benefícios da tecnologia. Entretanto, a ausência de investimentos em TI pode ser o fator chave para o fracasso de um empreendimento em mercados cada vez mais competitivos. Por outro lado, alguns gestores de TI não possuem habilidade para demonstrar os riscos associados ao negócio sem os corretos investimentos em TI.

Para melhorar o processo de análise de riscos e tomada de decisão é necessário um processo estruturado para gerenciar e controlar as iniciativas de TI nas empresas, para garantir o retorno de investimentos e adição de melhorias nos processos empresariais. É neste cenário então que Governança de TI aparece como importância vital para o negócio.

Diferença entre Gerenciamento de TI e Governança de TI

A diferença entre o Gerenciamento de Serviços em TI e a Governança de TI tem sido assunto de confusão e mitos. O Gerenciamento de TI foca em fornecer serviços de TI e produtos de forma eficiente e eficaz, e o gerenciamento das operações de TI, já a Governança de TI se preocupa com as operações e performance dos negócios, transformando e posicionando a TI para alcançar os requisitos de negócio.

A figura ao lado mostra o posicionamento do Gerenciamento de TI e a Governança de TI em duas dimensões: Orientação ao Negócio e Orientação ao Tempo.

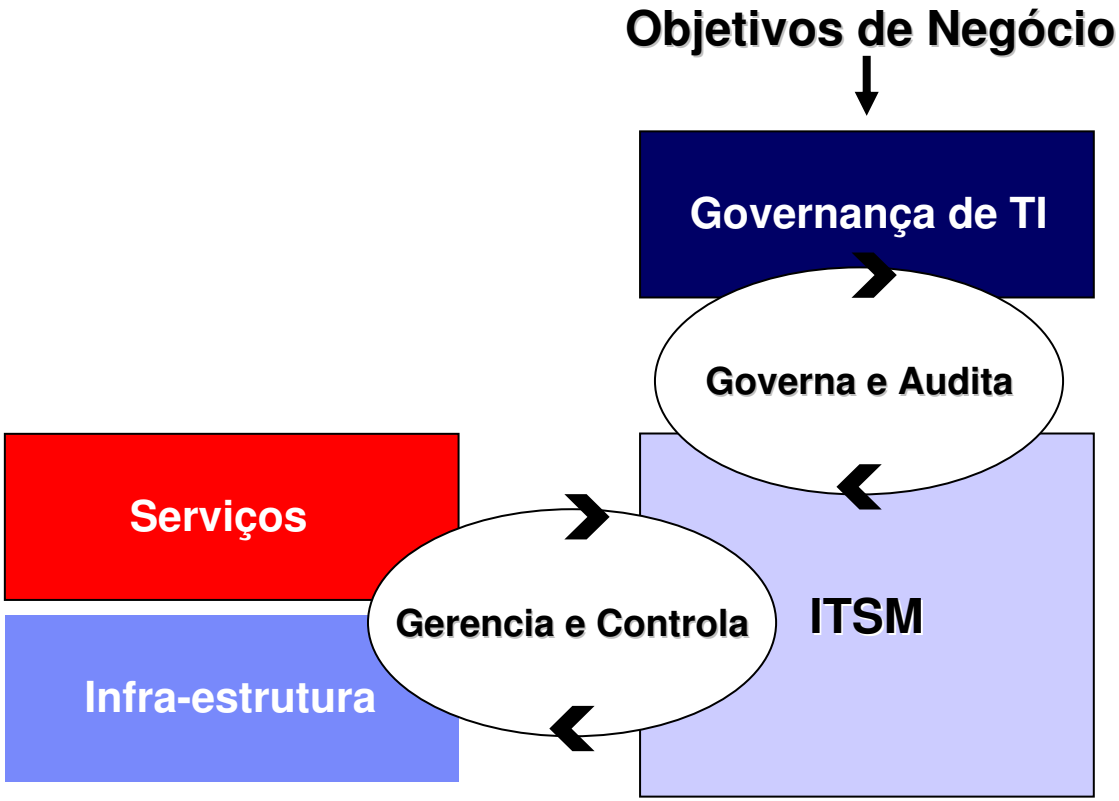


Governança de TI e Gerenciamento de TI

Fonte: Peterson(2003) Information Strategies Tactis for Information Technology Governance

Diferença entre Gerenciamento de TI e Governança de TI

Como introduzido anteriormente, uma das metas da Governança de TI é se alinhar com os objetivos de negócio definidos pela Governança Corporativa. Estas metas organizacionais de alto nível e objetivos são usados como entrada para gerar as metas, métricas de objetivos e performance necessárias para gerenciar a TI eficientemente. Ao mesmo tempo, os processos de auditoria são implementados para medir e analisar a performance da organização.



Questões a serem tomadas

Uma Governança de TI efetiva visa responder adequadamente as questões a seguir.

Princípios básicos para a TI	Declarações de alto nível sobre como a TI deve ser usada na organização
Arquitetura de TI	Escolhas técnicas, políticas, regras, planos de migração (inclui dados, tecnologias e aplicações)
Estratégias para a Infra-estrutura de TI	Estratégias para os recursos e competências de TI compartilhadas na organização (pessoal, rede, dados, help desk, etc.)
Necessidades das aplicações aos negócios	Especificar necessidades de negócio para comprar ou desenvolver aplicações de TI
Investimentos em TI e suas prioridades	Decisões sobre quanto e onde investir em TI. Aprovação e justificação de projetos

Estruturas de Governança de TI

A Governança de TI pode ter 4 tipos de estrutura de decisões dentro de uma organização, vejamos abaixo quais são:

Modelos de Governança	**Monarquia de Negócios**	Os diretores seniores tomam as decisões de TI afetando toda a organização
	Monarquia de TI	Os profissionais de TI podem tomar as decisões
	Feudalismo	As unidades de negócios podem tomar decisões para as áreas de responsabilidade
	Federalismo	Decisão coordenada envolvendo a organização e os departamentos
	Duopólio	Acordo bilateral entre executivos de TI e um outro grupo

Cada um dos modelos tem seu próprio benefício. A escolha mais popular é o federalismo, na qual combina decisões centralizadas e descentralizadas. A decisão por qual estrutura utilizar vai depender muito do contexto da organização.

Princípios de Governança de TI

O Conselho de Administração e os Executivos são responsáveis pela Governança de TI. Ela envolve estrutura e processos que dirigem a organização para alcançar seus objetivos.

Vamos agora discutir sobre os princípios da Governança de TI.



Direção e Controle



Responsabilidade



Prestação de Contas



Atividades

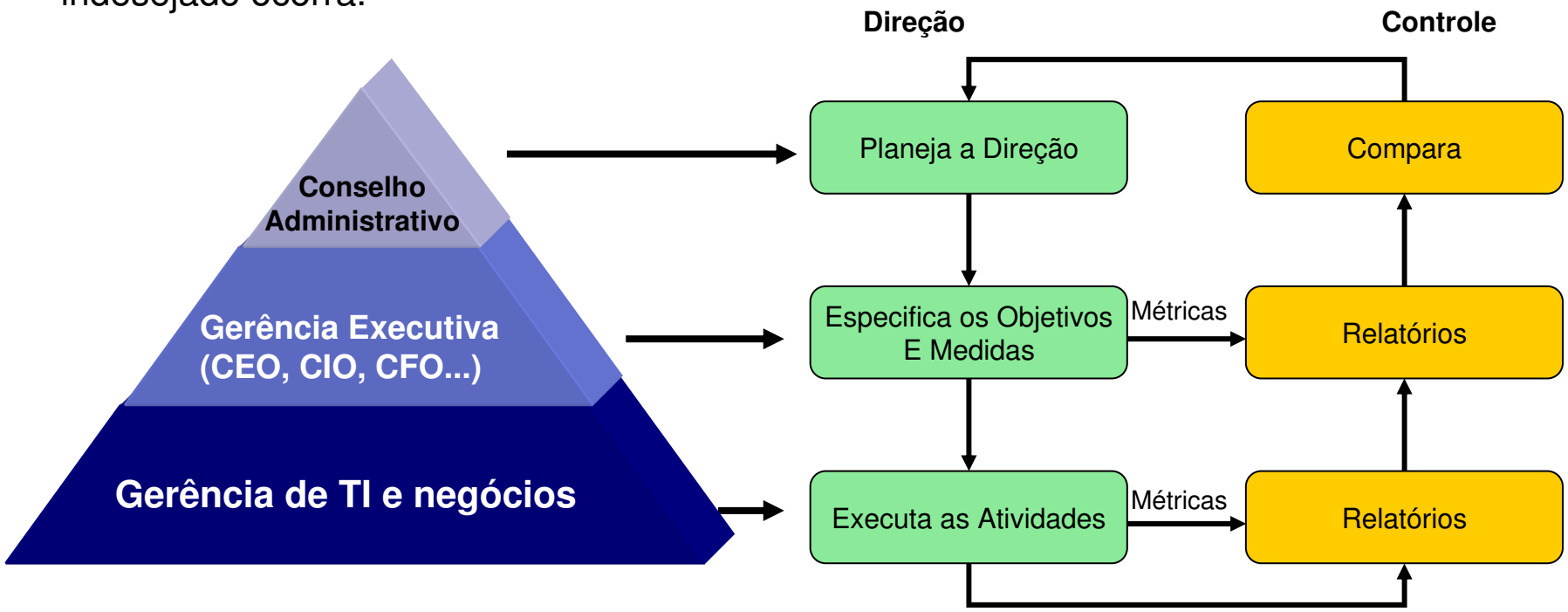
Princípios de Governança de TI

Direção e Controle

"Direção e Controle" são dois conceitos chaves da Governança de TI.

Direção: O Diretor fornece direção para implementar uma mudança. Para fornecer uma direção efetiva, o Diretor precisa entender a mudança pretendida. O Diretor dirige outra pessoa executar a mudança.

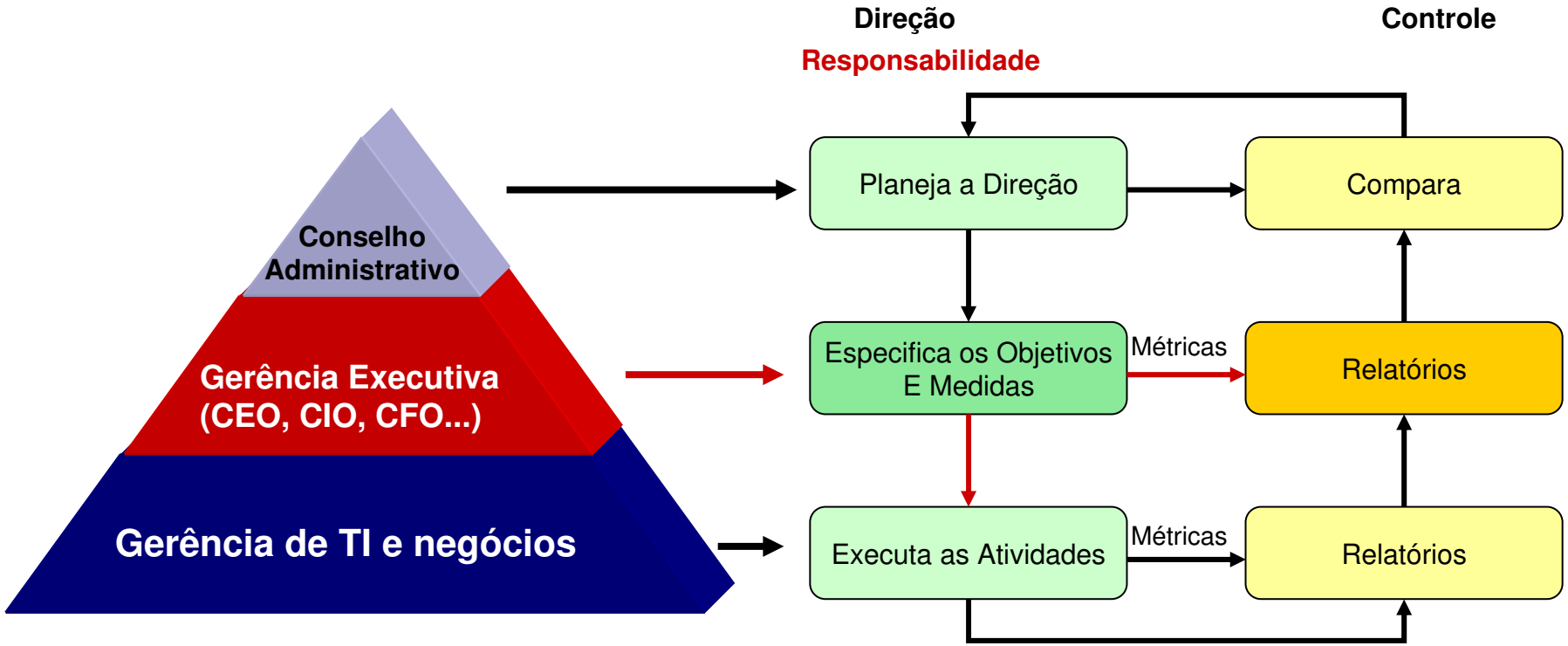
Controle: O Controle assegura que o objetivo é alcançado e que nenhum incidente indesejado ocorra.



Princípios de Governança de TI

Responsabilidade

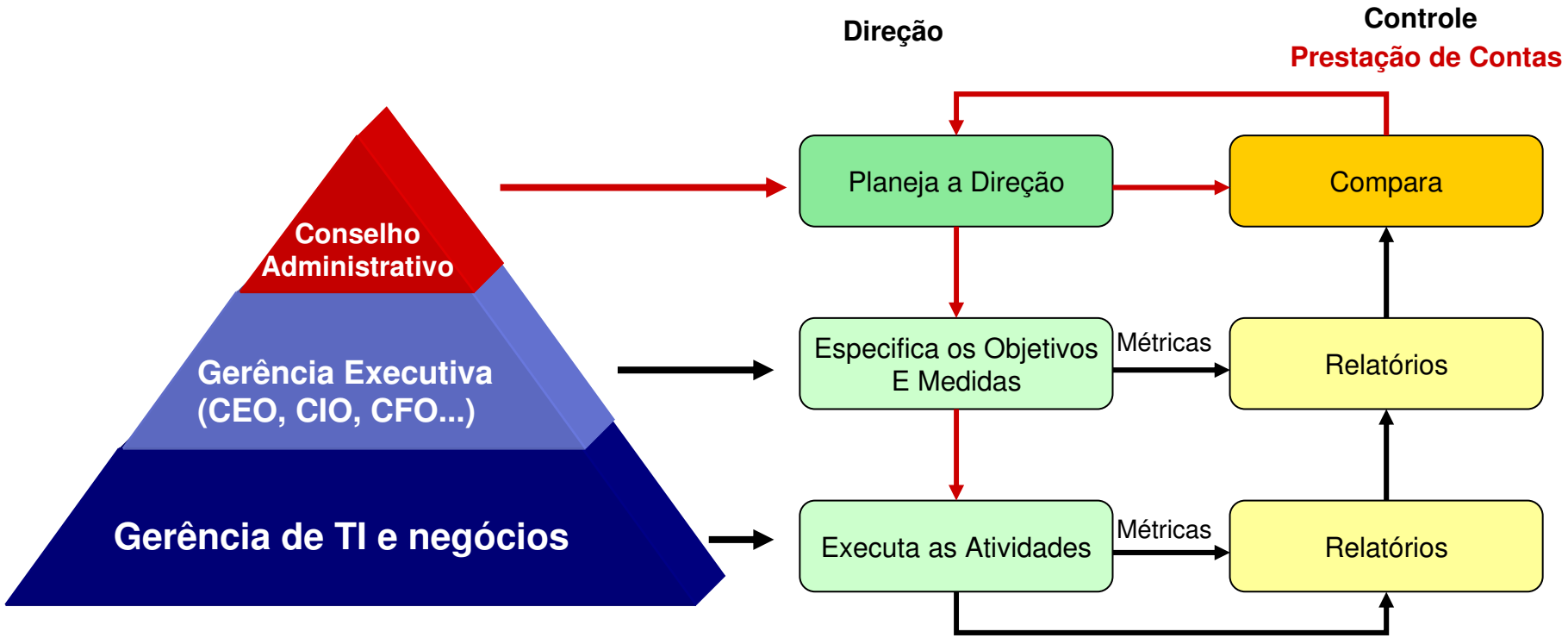
O CEO normalmente é o responsável pelo controle interno. Os diretores seniores determinam a responsabilidade para o estabelecimento de um controle interno específico ao pessoal responsável pelas unidades funcionais (departamentos). O Controle interno é de responsabilidade de todos em uma organização e pode ser uma função explícita ou implícita.



Princípios de Governança de TI

Prestação de Contas

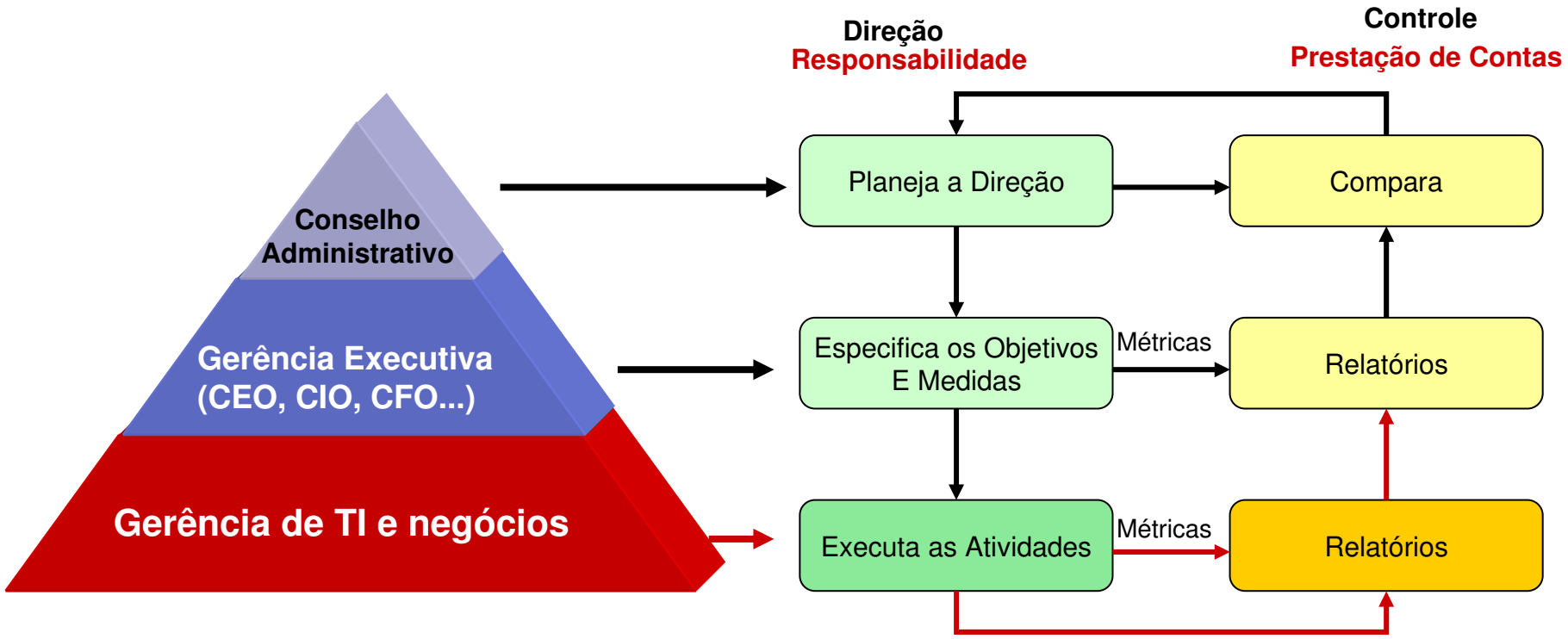
Os colaboradores tem a obrigação de prestar contas, fornecer relatórios ou explicar suas ações sobre o uso de recursos que lhe são transmitidos. Os executivos prestam contas ao Conselho Administrativo os quais fornecem governança, direção e monitoração. Para cada um é essencial conhecer como suas ações contribuem para alcançar os objetivos da organização.



Princípios de Governança de TI

Atividades

As atividades de TI são eficientes quando existe uma boa Governança de TI. Normalmente os Departamentos de TI nas empresas funcionam como se fossem o motor de um automóvel, onde trabalham conforme ações realizadas pelo motorista, que neste caso se equivale ao Conselho Administrativo.



Stakeholders de Governança de TI

Um elemento que pode ter responsabilidade relacionada a TI ou usufrui de algum serviço gerado pela função de TI na empresa é considerado um stakeholder na Governança de TI da empresa.



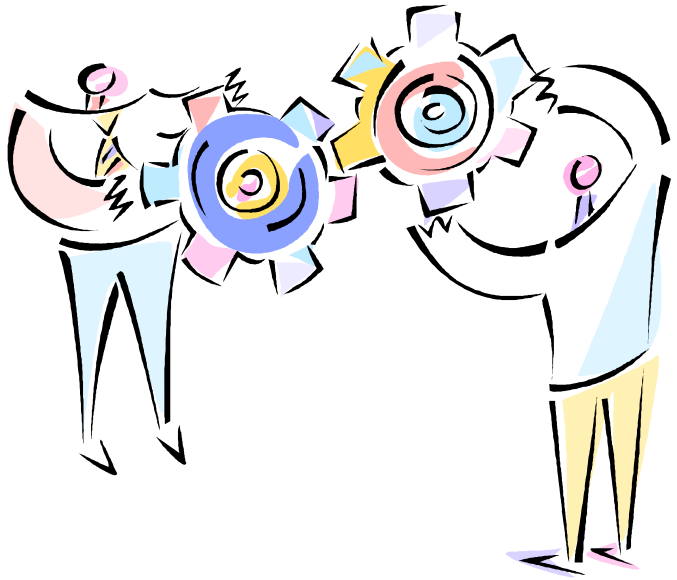
Escopo da Governança de TI

Nós já discutimos sobre os princípios e stakeholders de Governança de TI. Vamos agora discutir sobre o escopo de Governança de TI. O Escopo de Governança de TI pode ser classificado em cinco áreas, conforme apresentado abaixo:



Alinhamento Estratégico

O alinhamento estratégico se refere a alinhar a TI com as estratégias do negócio. A questão chave é verificar se os investimentos da empresa em TI estão em harmonia com objetivos estratégicos da empresa e ainda está desenvolvendo capacidades necessárias para entregar valor ao negócio.



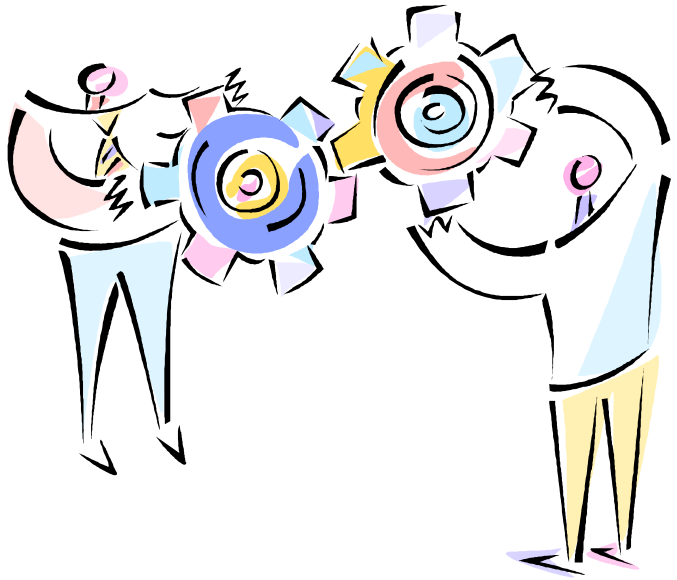
Alinhando TI com o Negócio

Objetivos Estratégicos

- Especificar os objetivos
- Desenvolver estratégias para alcançar os objetivos especificados
- Desenhar planos de ações para implementar as estratégias

Alinhamento Estratégico

A TI ainda é considerada um mal necessário, mas considerada estrategicamente ela pode fornecer a empresa vários benefícios:



Alinhando TI com o Negócio

Benefícios do Alinhamento Estratégico

- Valor agregado aos produtos e serviços da empresa
- Ajuda no posicionamento competitivo da empresa
- Uso otimizado dos recursos
- Custos eficiência administrativa aperfeiçoada

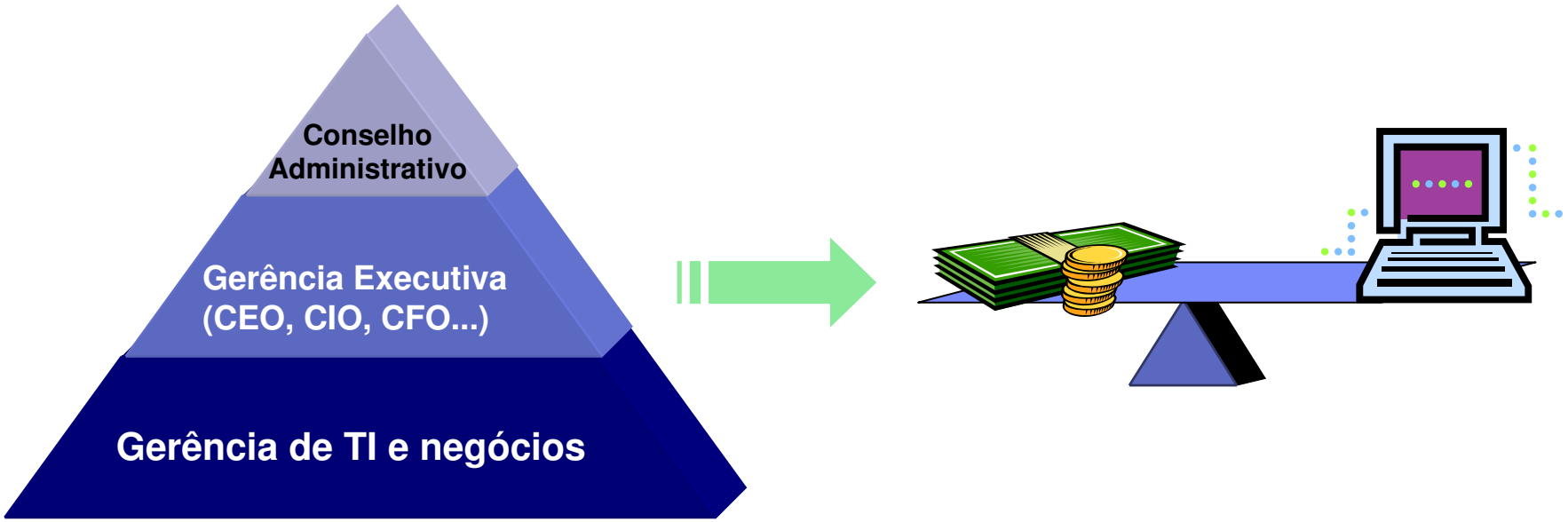
Entrega de Valor

Um outro domínio chave da Governança de TI é a Entrega de Valor.



Entrega de Valor

Os princípios básicos do valor de TI está na entrega de qualidade apropriada dentro do prazo e custo, a qual deve atingir os benefícios que foram prometidos. Em termos de negócio isto pode ser traduzido como: vantagem competitiva, tempo necessário para o preenchimento de um pedido/serviço, satisfação do cliente, tempo de espera do cliente, produtividade dos funcionários e lucro. Para uma entrega de valor TI efetivada ser alcançada, tanto os custos como o retorno sobre os investimentos devem ser gerenciados.



Governança de TI

A Governança de TI procura estabelecer um modelo de medida de valor entregue pela TI ao negócio antes de embarcar em grandes projetos.

Gerenciamento de Riscos

O Gerenciamento de Riscos de refere ao tratamento das incertezas.



Gerenciamento de Riscos

O gerenciamento de riscos está diretamente ligado à boa governança e envolve, entre outras coisas, a identificação de riscos sistêmicos, tecnológicos e da informação, a fim de dar maior proteção aos ativos de TI. Enquanto o objetivo da entrega de serviços é criar valor, orientado pelo alinhamento, o gerenciamento de riscos busca preservar valor.

O Gerenciamento de Riscos envolve as seguintes atividades:

- Entendimento sobre os riscos ou atitudes da organização que levam aos riscos.
- Definição do impacto e a probabilidade de um risco.
- Aprovação do plano de ação do Gerenciamento de Riscos.



Importância do Gerenciamento de Riscos

Devido ao alto investimento em TI que as empresas estão realizando para poder atender as exigência legais e regulamentações, implementar novos sistemas de gestão, garantir a segurança das suas informações, deverá ter um controle interno para garantir a gestão de riscos em seus processos, buscando mais segurança nos projetos e operações de TI.

Os riscos são gerenciados de quatro formas:

Mitigação de Riscos: Implementação de controles que protejam contra riscos, por exemplo, implementação de um firewall de segurança.

Transferência de Riscos: compartilhar riscos com parceiros ou contratar seguro apropriado.

Aceitação de Riscos: confirmação e monitoração de riscos, e ter um plano de resposta ao risco pronto.

Evitando os Riscos: adotar uma opção diferente que evite completamente o risco.

Gerenciamento de Recursos

Gerenciar e otimizar recursos de TI é uma outra área de foco da Governança de TI.



Gerenciamento de Recursos

Um item chave para a performance de TI ter sucesso é o investimento otimizado, uso e alocação de recursos de TI (pessoas, aplicações, tecnologia e informação) para atender as necessidades da organização. Muitas empresas falham ao maximizar a eficiência dos seus ativos de TI e a otimização dos custos relacionados a estes. Ainda relacionado com o Gerenciamento de Recursos está os serviços terceirizados, onde se deve considerar onde e como terceirizar estes serviços de forma que eles gerem o valor prometido a um preço aceitável.

Pontos de Otimização de Recursos

- Assegurar que existe capacidade suficiente para dar suporte às atividades críticas do negócio
- Otimização de custos
- Outsourcing



A Governança de TI ajuda a otimizar Custos e Recursos

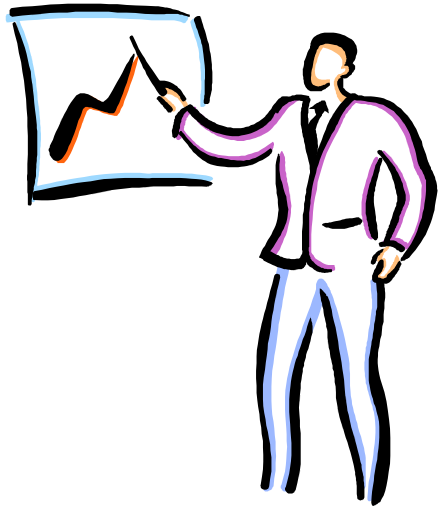
Monitoração de Performance

Esta área envolve a medição e monitoração das atividades da TI.



Monitoração de Performance

Se você não poder medir o processo, você não poderá gerenciá-lo. Se não existir nenhuma forma de medir e monitorar as atividades de TI, não é possível governar a TI e assegurar o seu alinhamento, valor entregue, gerenciamento de riscos, e o uso adequado dos recursos.



Se você não poder medir o processo, você não poderá gerenciá-lo.

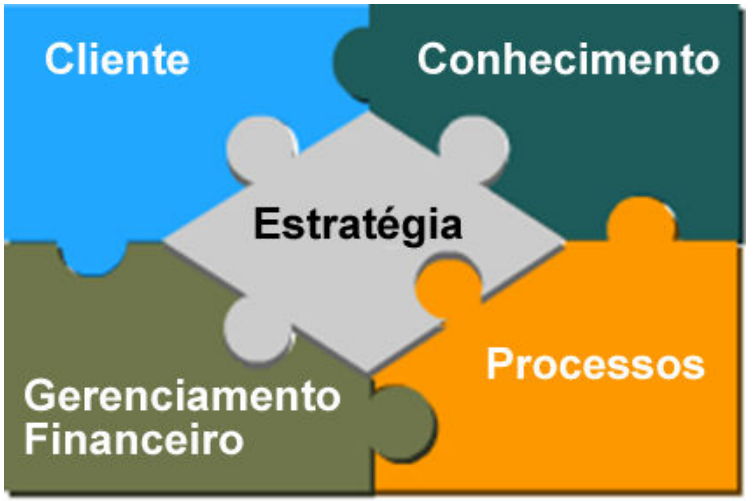
Para a monitoração de performance ter sucesso, métricas eficientes devem ser definidas e aprovadas pelos stakeholders. Estas métricas podem ser acompanhadas usando scorecards de performance (pontos de performance).

Monitoração de Performance

Para ajudar na monitoração de performance poderá ser utilizado a técnica do Balanced Scorecard.

BSC(Balanced Scorecard) é uma sigla que, traduzida, significa Indicadores Balanceados de Desempenho. Este é o nome de uma metodologia voltada à gestão estratégica de empresas que foi criado pelos professores Robert Kaplan e David Norton em1992.

Balanced Scorecard é uma abordagem que permite a operacionalização da estratégia, facilitando a comunicação e a compreensão dos objetivos estratégicos aos vários níveis organizacionais. Através do Balanced Scorecard a direção das empresas dispõe de uma visão integrada do negócio e de um processo contínuo de monitoramento do desempenho. Integra-se com facilidade a outras metodologias como CobiT e ITIL.



Balanced Scorecard

Governança e o Framework de Controle

Framework de Controle

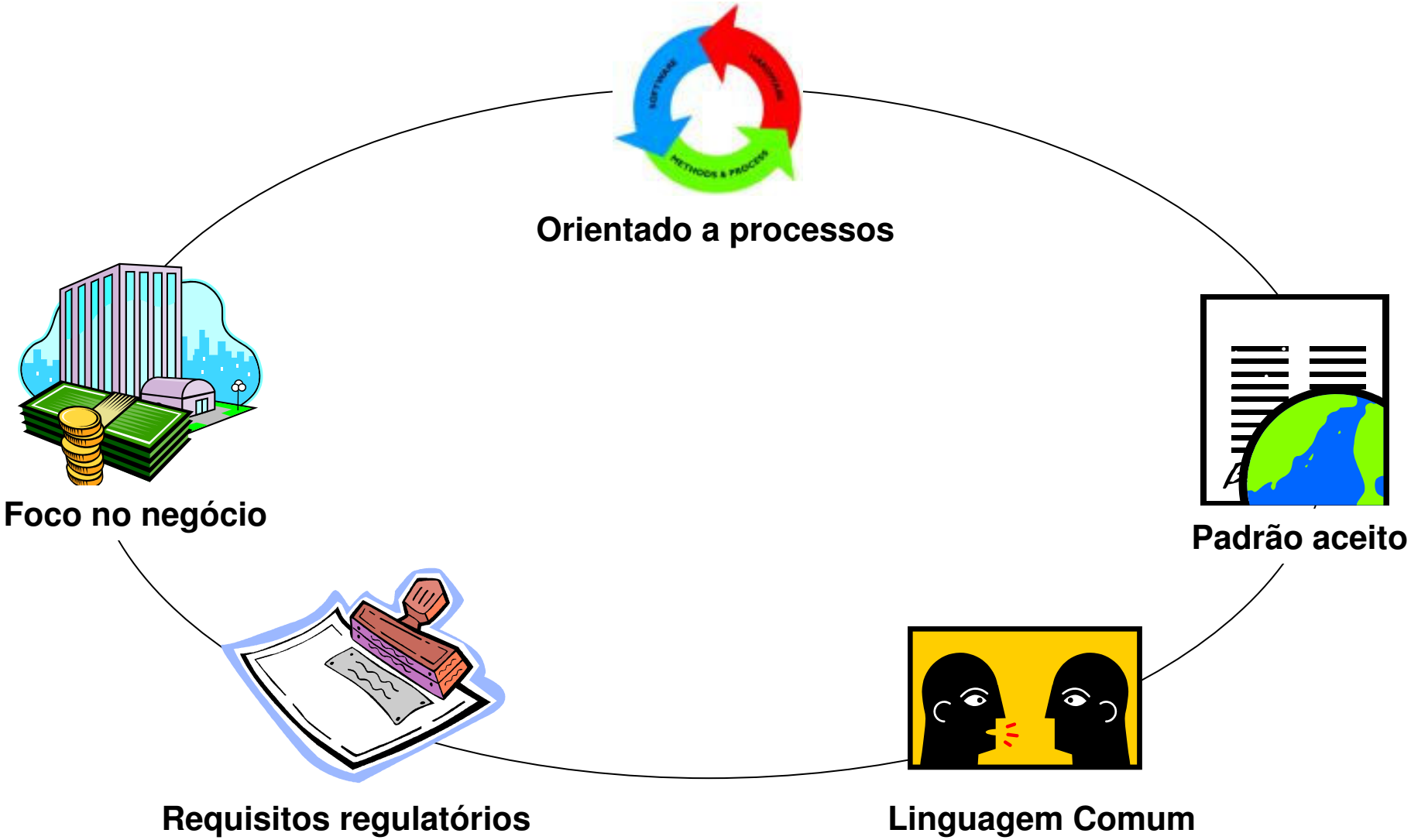
Vamos entender as características de um framework de controle e discutir cada uma delas em detalhes.

Características:

- Foco no negócio
- Orientada a processo
- Padrão aceito
- Linguagem comum
- Requisitos regulatórios

Características de um framework de controle

A característica chave de um framework de controle é o Foco no negócio.



Benefícios da Governança de TI

Benefícios da Governança de TI

Até agora você aprendeu sobre os vários domínios da Governança de TI. Vamos agora discutir sobre os seus benefícios.

Principais Benefícios que iremos ver:

- Confiança da Alta administração
- TI mais comprometida com o Negócio
- Retorno sobre o Investimento (ROI) maior
- Serviços mais confiáveis
- Mais transparência

Benefícios da Governança de TI

Confiança da Alta administração

A TI como sendo um assunto técnico ela é difícil de ser entendia pelos diretores de negócio. Uma Governança de TI eficiente pode ajudar a estabelecer uma comunicação clara para todos.

A linguagem comum tornará os mecanismos de tomada de decisão mais claros, e facilitará a transparência e precisão das informações gerenciais.

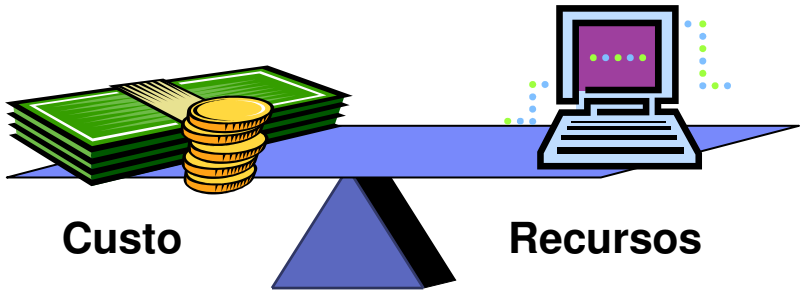


Benefícios da Governança de TI

TI mais comprometida com o negócio

A TI será mais focada nas necessidades do negócio. Agilidade, flexibilidade e comprometimento são atributos vitais para a função de TI no suporte ao desenvolvimento das necessidades do negócio.

Uma Governança de TI eficiente assegurará que as decisões sejam tomadas com mais fundamento e clareza, reduzindo os riscos nos investimentos.



Benefícios da Governança de TI

Maior Retorno sobre o Investimento (ROI)

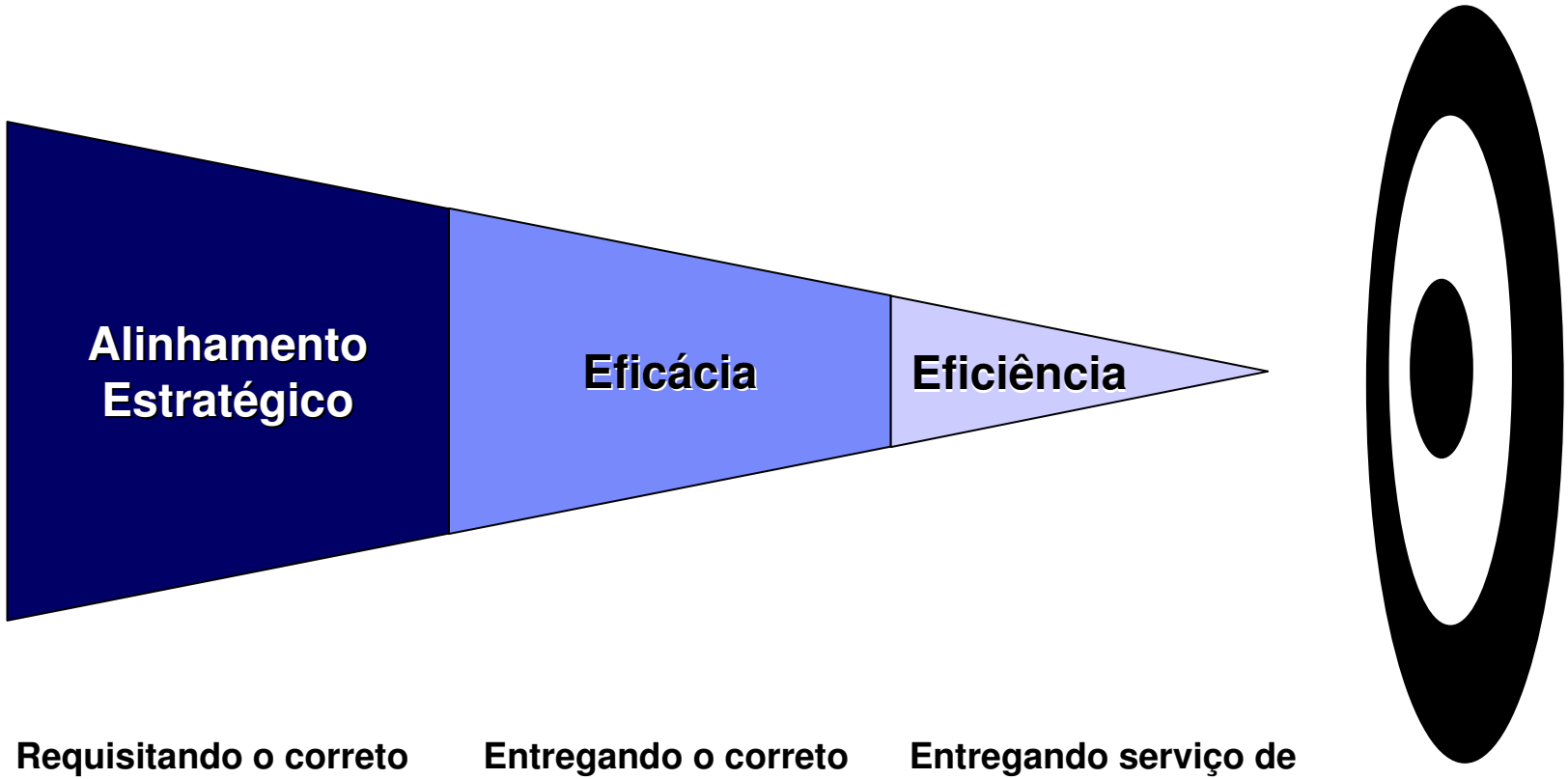
A Governança de TI permite a organização a aumentar o seu retorno sobre os investimentos em tecnologias, assegurando que :



- Os investimentos sejam baseados nos benefícios para o negócio
- Previsão de custos, benefícios e riscos dos investimento de forma mais precisa
- Reação mais rápida e antecipada diante de problemas e riscos antecipados
- Os requisitos são comunicados de forma eficiente evitando que a entrega dos resultados dos projetos não atendam as expectativas

Benefícios da Governança de TI

O valor entregue pela TI pode ser gerenciado em 3 camadas:

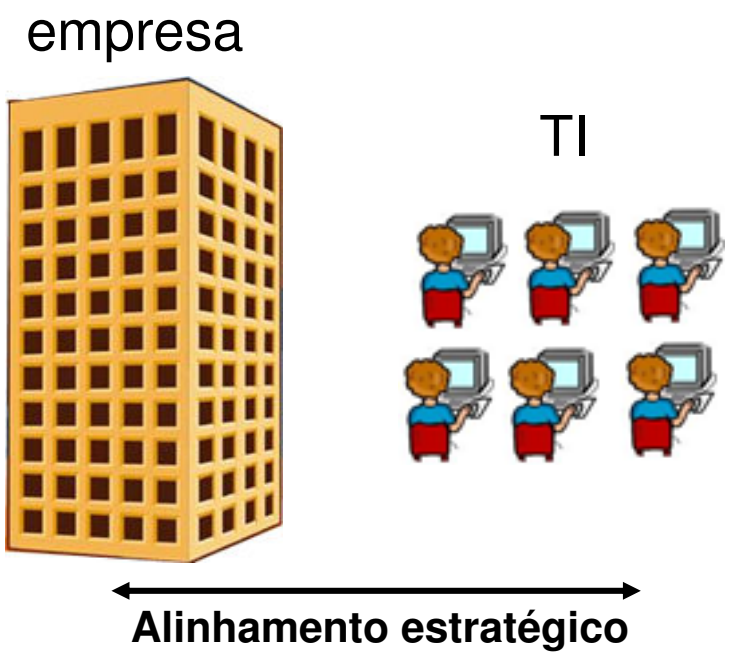


Benefícios da Governança de TI

Serviços mais confiáveis

A Governança de TI assegura que os processos críticos e os serviços de TI sejam monitorados, e qualquer incidente ou falha de alta prioridade seja encaminhada e resolvida. O serviços requerem que níveis mais alto de confiança sejam implementados para minimizar a probabilidade de uma falha ou interrupção de um serviço.

A Governança de TI assegura riscos menores, melhor qualidade dos serviços e aumento da satisfação do cliente.



Benefícios da Governança de TI

Mais transparência

Uma boa governança de TI irá trazer transparência das atividades de TI, gastos relacionados com os recursos e serviços de TI, com um claro conhecimento como a TI entrega valor para o negócio da organização.

A transparência irá fornecer oportunidade para refinar os processos de TI para gerar valor ao negócio. Sem saber a verdade, as organizações jamais vão conseguir otimizar a forma que elas operam e como poderão gerar valor a partir dos seus investimentos.



Curso Online

COBIT

FUNDAMENTOS EM GOVERNANÇA DE TI



Todos os direitos de cópia reservados. Não é permitida a distribuição física ou eletrônica deste material sem a permissão expressa do autor.

Objetivos

Este módulo irá apresentar os conceitos relacionados ao COBIT, estrutura, aplicações e benefícios.

Durante este módulo iremos:

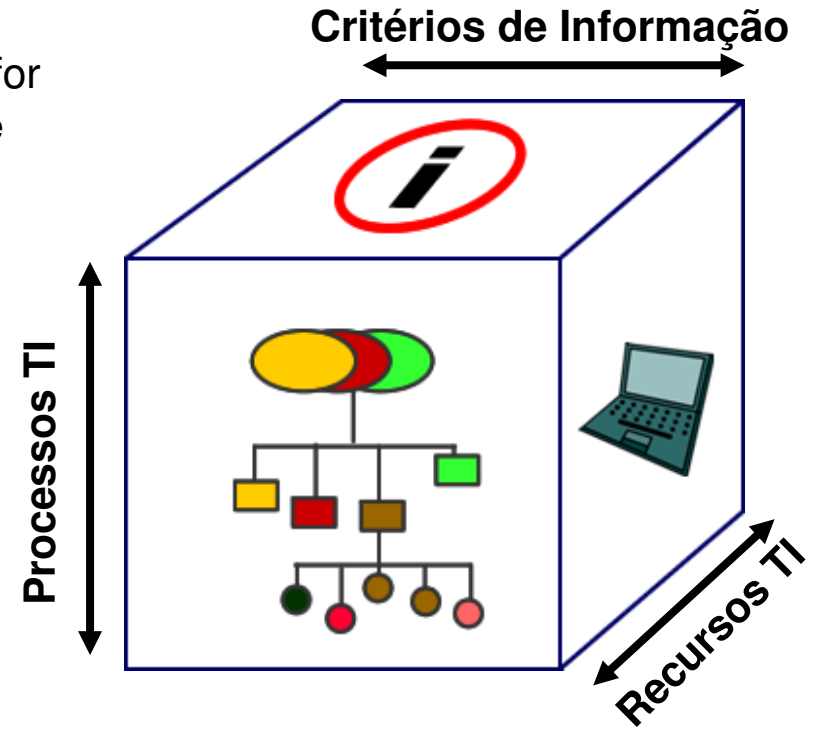
- **Entender o que é o COBIT e quais suas aplicações**
- **Entender como o COBIT está estruturado**
- **Entender como o COBIT atende os requisitos para um framework de controle**
- **Entender como o COBIT está relacionado com os requisitos regulatórios**
- **Descrever como o COBIT ajuda os administradores do negócio e auditores em uma organização**

Princípios do Framework

Framework do COBIT

O acrônimo COBIT significa **C**ontrol **Ob**jectives for **I**nformation and related **T**echnology - Objetivos de Controle para Informações e Tecnologias relacionadas.

O COBIT é um framework de governança e controle, que foca no que precisa ser alçado ao invés de se preocupar em como alcançar.

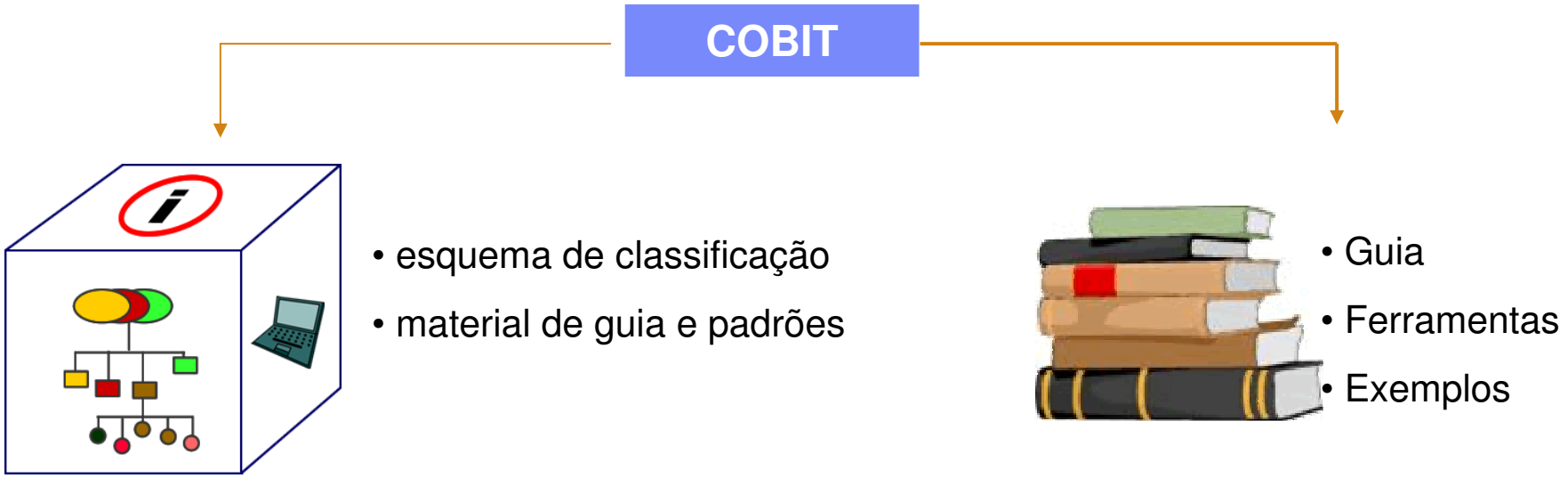


Vamos apresentar a seguir os componentes do framework do COBIT.

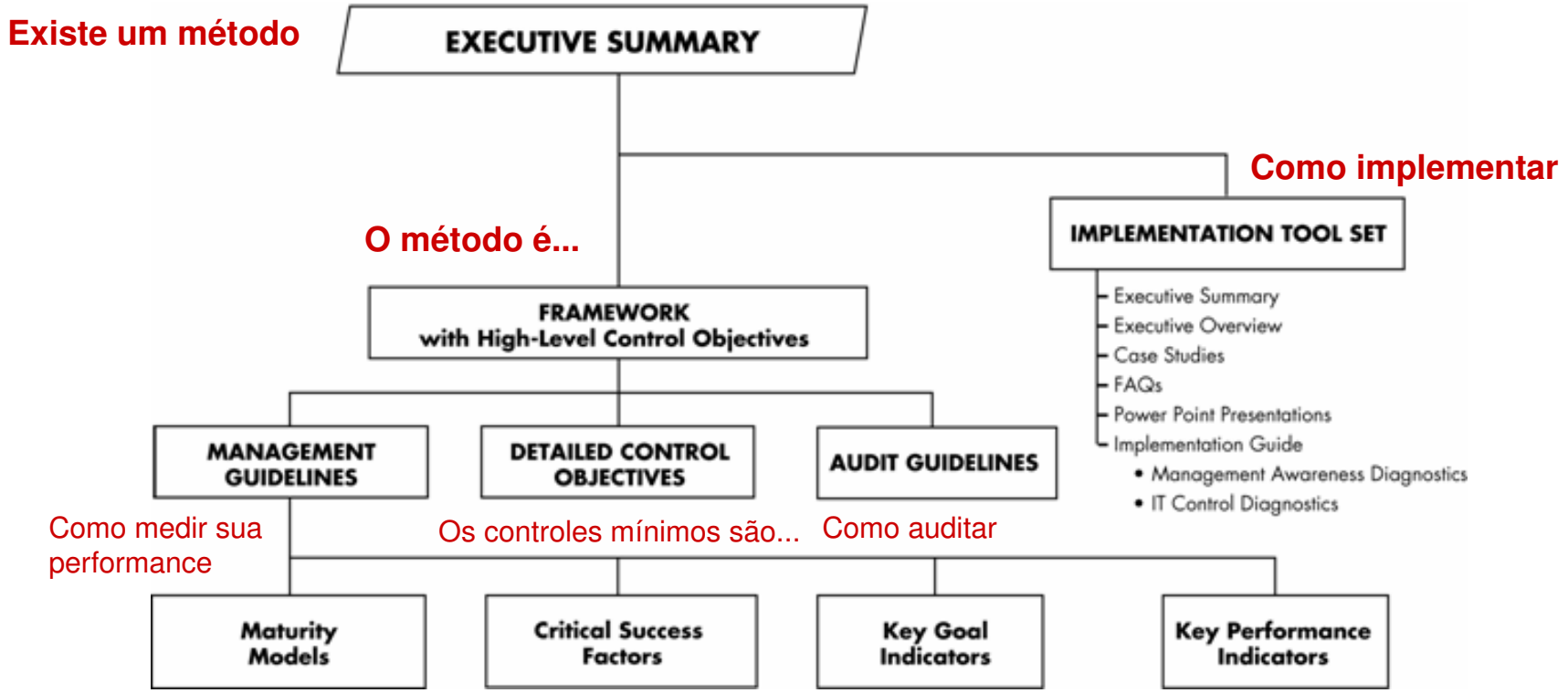
O que é o COBIT?

O COBIT é um framework que fornece as melhores práticas para o gerenciamento de processos de TI, estruturados de uma forma gerenciável e lógica, atendendo as várias necessidades de gestão da organização, tratando os riscos de negócio, questões técnicas, necessidades de controle e métricas de desempenho.

O COBIT não é um padrão definitivo, ele serve como apoio para a implementação de controles na Governança de TI.



Família de Produtos do COBIT



Sumário Executivo – para Executivos Seniores (CEO, COO, CFO, CIO)

Framework – para Gerência Operacional Seniores (Diretores de Segurança da Informação e Auditoria)

Objetivos de Controle – para a Gerência Intermediária (Gerentes de Controle e auditoria intermediário)

Diretrizes de Auditoria – para gerentes de linha e especialistas (gerentes de aplicações e operações)

Conjunto de Ferramentas de Implementação – para qualquer um acima

Diretrizes de Gerenciamento – para a Gerência e Auditores em geral

COBIT como modelo de controle

O COBIT é um framework das melhores práticas de controle, entretanto nem todas as práticas que ele defende podem existir na maioria da empresas. É muito importante usar o framework do COBIT para encorajar a equipe de TI a se inspirar nas melhores práticas.

Como um modelo de controle, o COBIT deve adaptado para empresa, plataforma de TI e padrões de sistemas

Missão do COBIT

“Pesquisar, desenvolver, publicar e promover um conjunto de objetivos de controle para tecnologia que seja embasado, atual, internacional e aceito em geral para o uso do dia-a-dia de gerentes de negócio e auditores”



Aplicação do COBIT

O COBIT foi projetado para utilização por três distintos públicos:

- **Administradores**: para auxiliá-los na ponderação entre risco e investimento e controle de ambientes muitas vezes imprevisíveis como o de TI;
- **Usuários**: para se certificarem da segurança e dos controles dos serviços de TI fornecidos internamente ou por terceiros;
- **Auditores de Sistemas**: para subsidiar suas opiniões e/ou prover aconselhamento aos administradores sobre controles internos.

COBIT como Framework de Controle

O COBIT é um framework de controle que tem o propósito de assegurar que os recursos de TI estarão alinhados com os objetivos da organização. Entre seus benefícios, estão o aumento na qualidade de serviços e informações e o direcionamento de ações para um equilíbrio entre risco e retorno.

O COBIT foca na Governança Corporativa e na necessidade de controles de melhorias nas empresas. Os controles de TI são necessários para prestar contas dos gastos financeiros. O COBIT fornece um framework para controlar a TI e suporta 5 requisitos de um Framework de Controle:

- **Define uma linguagem comum para a área de TI e negócio**
- **Ajuda a atender os requisitos regulatórios**
- **É um padrão aceito entre empresas**
- **É orientado a processos**
- **É focado nos requisitos de negócio**

Evolução do COBIT

O COBIT foi criado para atender a necessidade de um framework de controle de TI compreensivo para o negócio, gerência de TI, auditores, e eliminar as disparidades de controles e guias de avaliação.

1996	**Primeira edição do CobiT**	ISACA (*Information Systems Audit and Control Association – www.isaca.org*) lança um conjunto de objetivos de controle para as aplicações de negócio
1998	**A segunda versão do CobiT**	Inclui uma ferramenta de suporte à implementação e a especificação de objetivos de alto nível e de detalhe
2000	**A terceira versão do CobiT**	Inclui normas e guias associadas à gestão. O ITGI (*IT Governance Institute –www.itgi.org*) torna-se o principal editor do framework
2002	**Sarbanes-Oxley Act**	O *Sarbanes-Oxley Act* foi aprovado. Este acontecimento teve um impacto significativo na adoção do COBIT nos Estados Unidos e empresas globais que atuam nos EUA
2005	**A quarta versão do COBIT**	Melhoria dos controles para assegurar a segurança e disponibilidade dos ativos de TI na organização

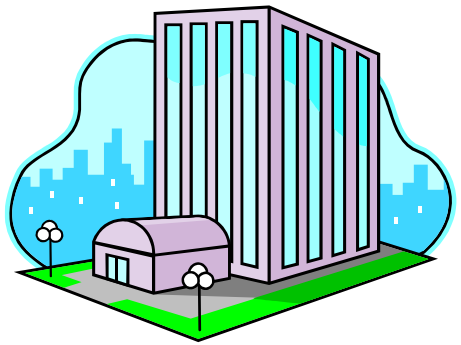
Origens do COBIT

O COBIT foi desenvolvido a partir do Committee of Sponsoring Organizations of the Treadway Commission-Internal Control — Integrated Framework (COSO), o Controle de Objetivos original do ISACA, e mais de 50 padrões e práticas de mercado em TI. O COBIT preenche a lacuna entre os modelos de controle de negócio e as melhores práticas em TI e oferece um modelo para a Governança de TI. Veja abaixo as principais fontes do COBIT:

- **Padrões Profissionais** para o controle e auditoria interna (COSO, IFAC, AICPA, IIA, etc)
- **Padrões Técnicos** (ISSO, EDIFACT, etc)
- **Códigos de Conduta**
- **Critérios de Qualificação** para os sistemas e processos de TI (ISSO 9000, ITSEC, TCSEC, etc)
- **Práticas da Indústria**
- **Requisitos específicos de alguns negócios emergentes** como bancos e e-commerce.

Evolução do COBIT

A 3ª. Edição do COBIT liberada em 2000 teve o desenvolvimento das diretrizes de gerenciamento e a atualização da segunda edição baseada em novas e revisadas referências internacionais. Ainda, o Framework do COBIT foi revisado e aprimorado para suportar uma necessidade de controle maior, introduzir o gerenciamento da performance e ajudar na implementação da Governança de TI.







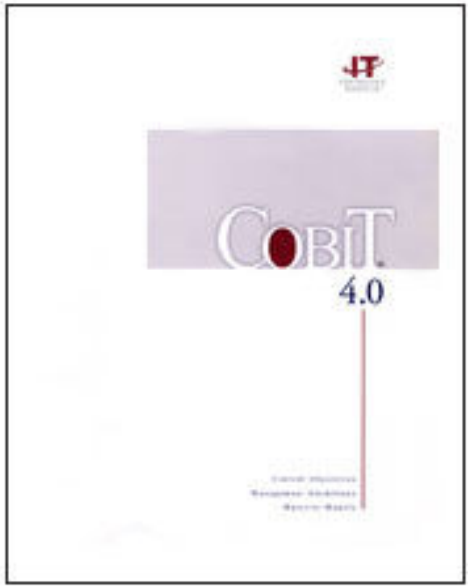
Empresas que usam COBIT

Maior valor entregue e controle

Novidades no COBIT 4.0

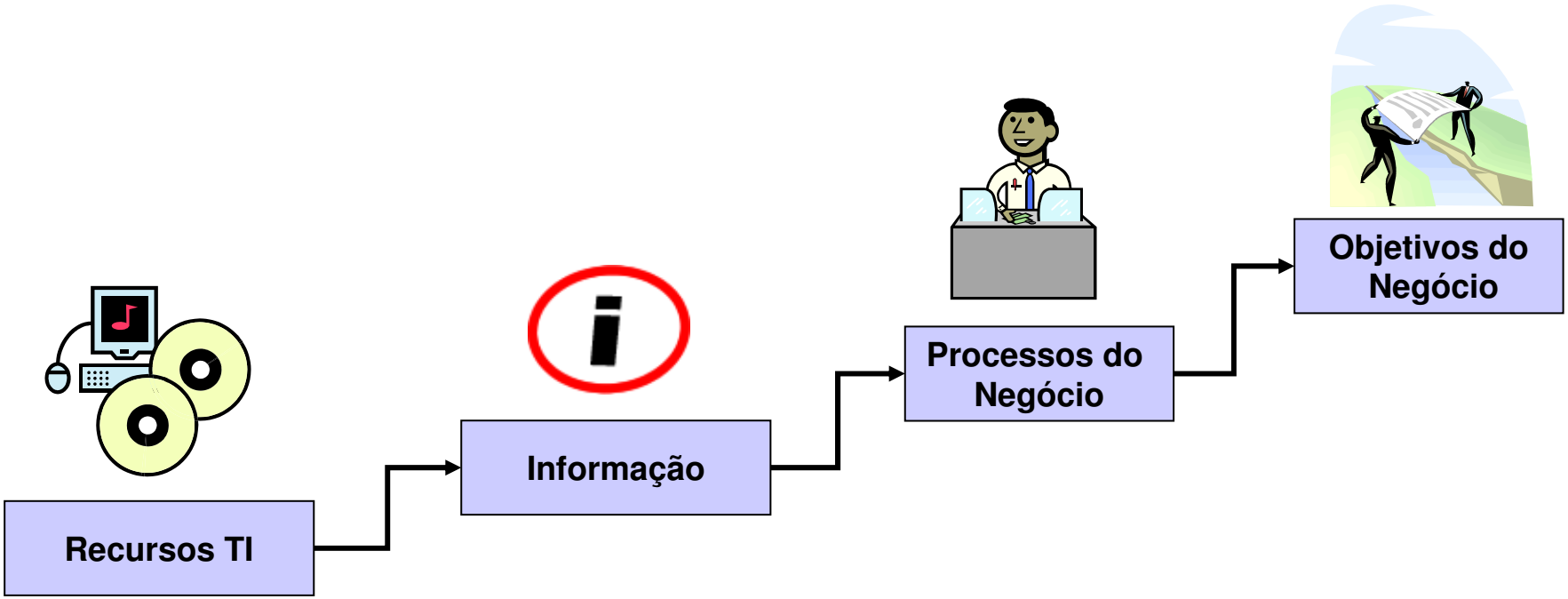
O nova versão do COBIT 4.0 teve várias melhorias e simplificações em seu uso. Veja abaixo as principais mudanças:

- Aperfeiçoamento de métricas - KGIs e KPIs
- Novas metas de negócio, metas de TI e metas de processos
- Aperfeiçoamento dos modelos de maturidade
- Gráficos RACI para indicar as funções de cada um em cada atividade
- Agrupamento dos Objetivos de Controle e Diretrizes de Gerenciamento em um só volume
- Redução de 30% dos Objetivos de Controle detalhados. Na versão anterior tínhamos 318 Objetivos de Controle detalhados, agora temos 214.
- Melhor alinhamento com as melhores práticas da ITIL



Qual é a Filosofia do COBIT?

O COBIT é baseado na filosofia que os recursos de TI precisam ser gerenciados por um conjunto de processos agrupados naturalmente com o objetivo de fornecer informação pertinente e confiável para que a organização consiga alcançar seus objetivos.

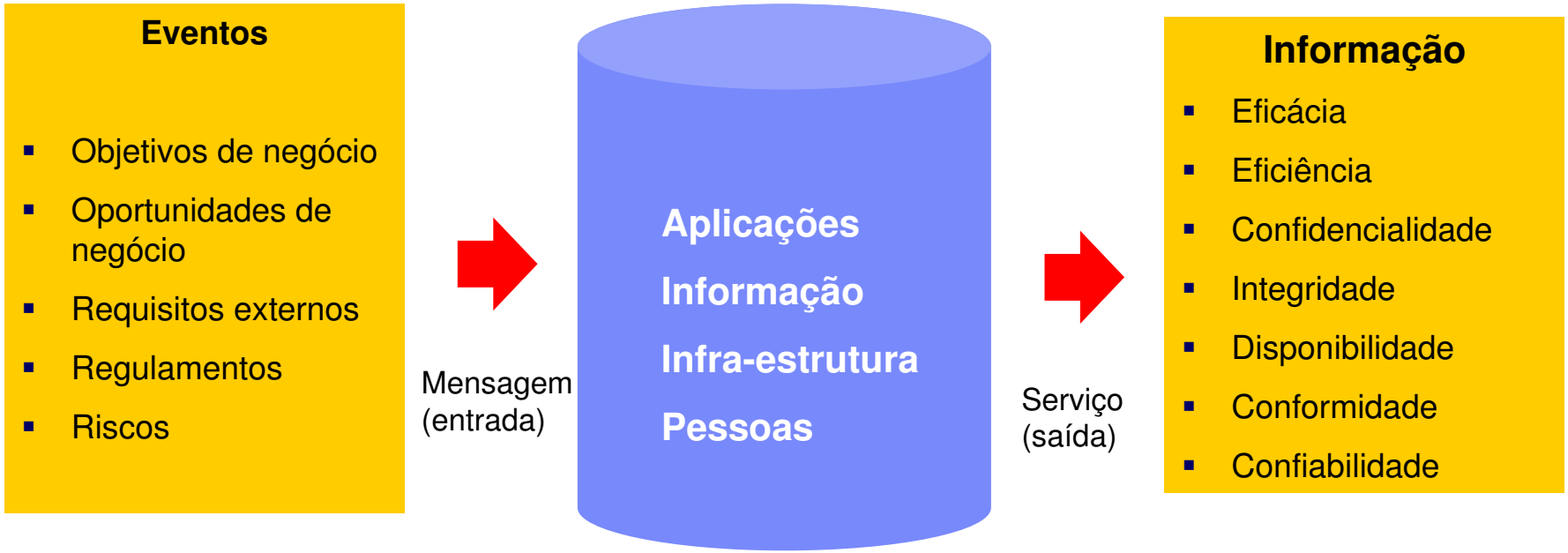


O framework do COBIT ajuda a alinhar a TI com o negócio, focando nas necessidades de informação que o negócio precisa e organizando os recursos de TI. O COBIT fornece um framework e serve como guia para implementar a Governança de TI.

Qual é o Princípio do Framework do COBIT?

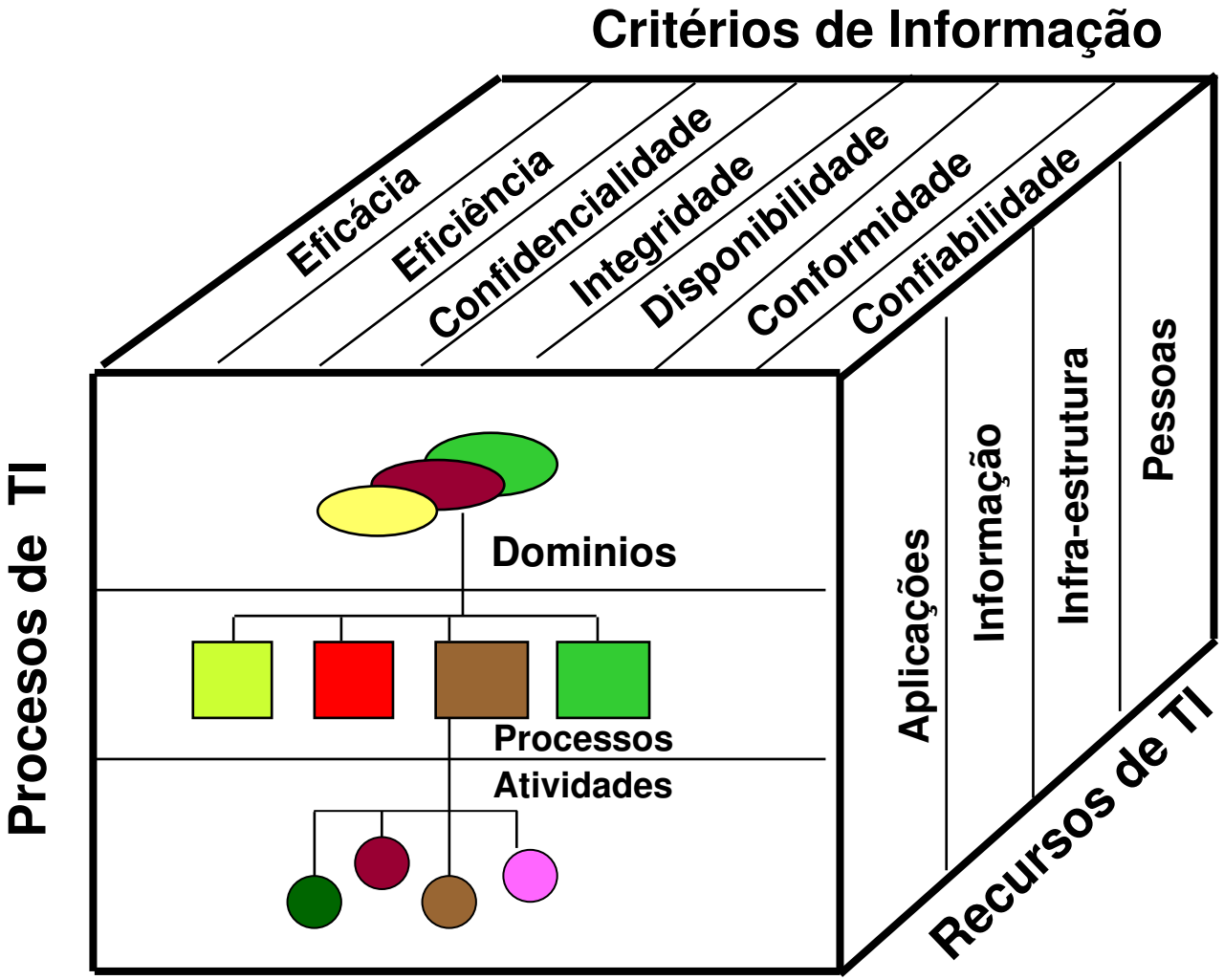
O princípio do framework do COBIT é vincular as expectativas dos gestores de TI com as responsabilidades dos gestores de TI. O objetivo é facilitar a Governança de TI – gerar valor em TI enquanto se gerencia os riscos de TI.

O princípio do framework é derivado de um modelo que mostra a informação com qualidade sendo produzida por eventos através de recursos de TI.

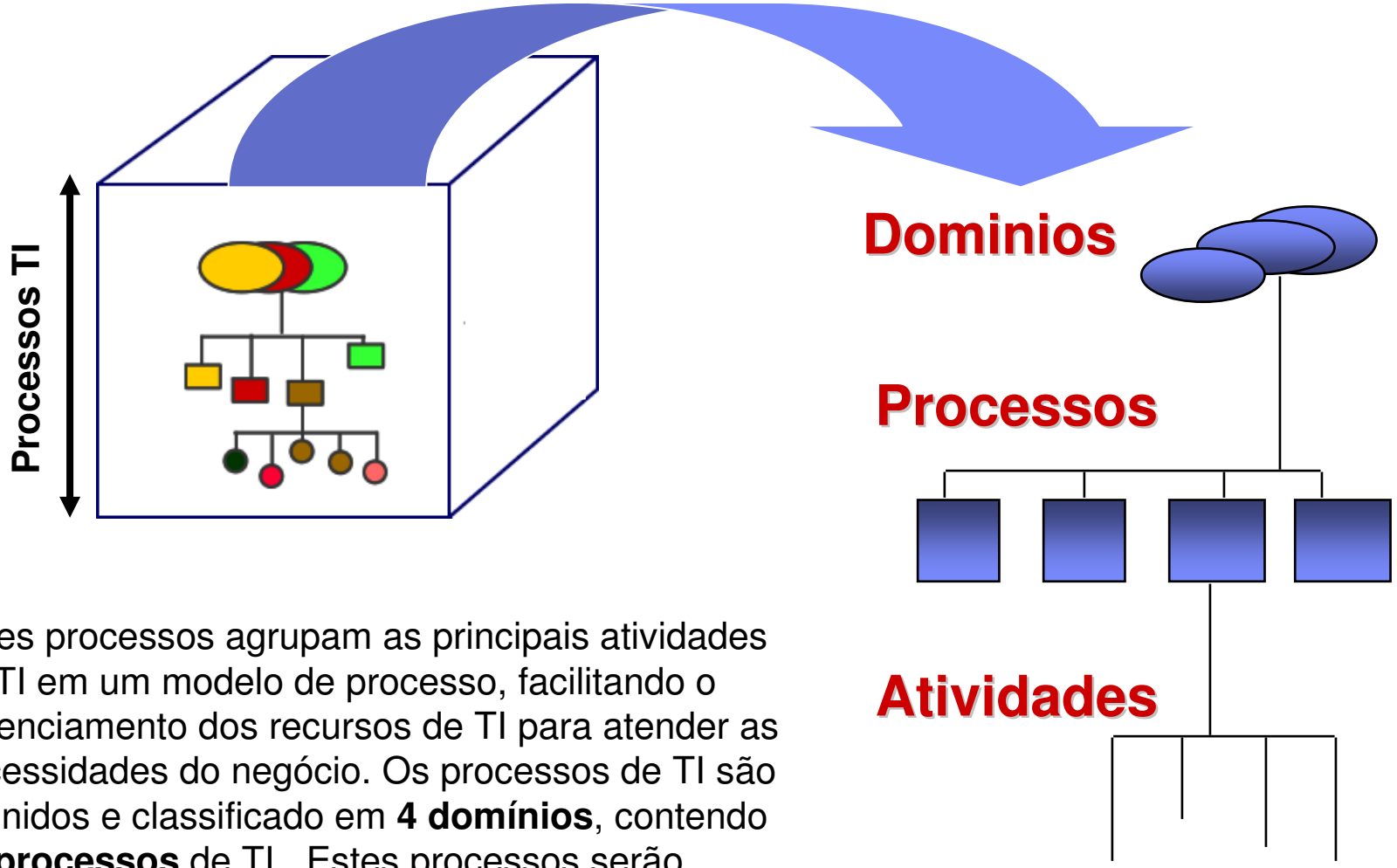


Componentes do Framework do COBIT

Os três componentes do framework do COBIT formam as três dimensões do cubo do COBIT.



Processos de TI

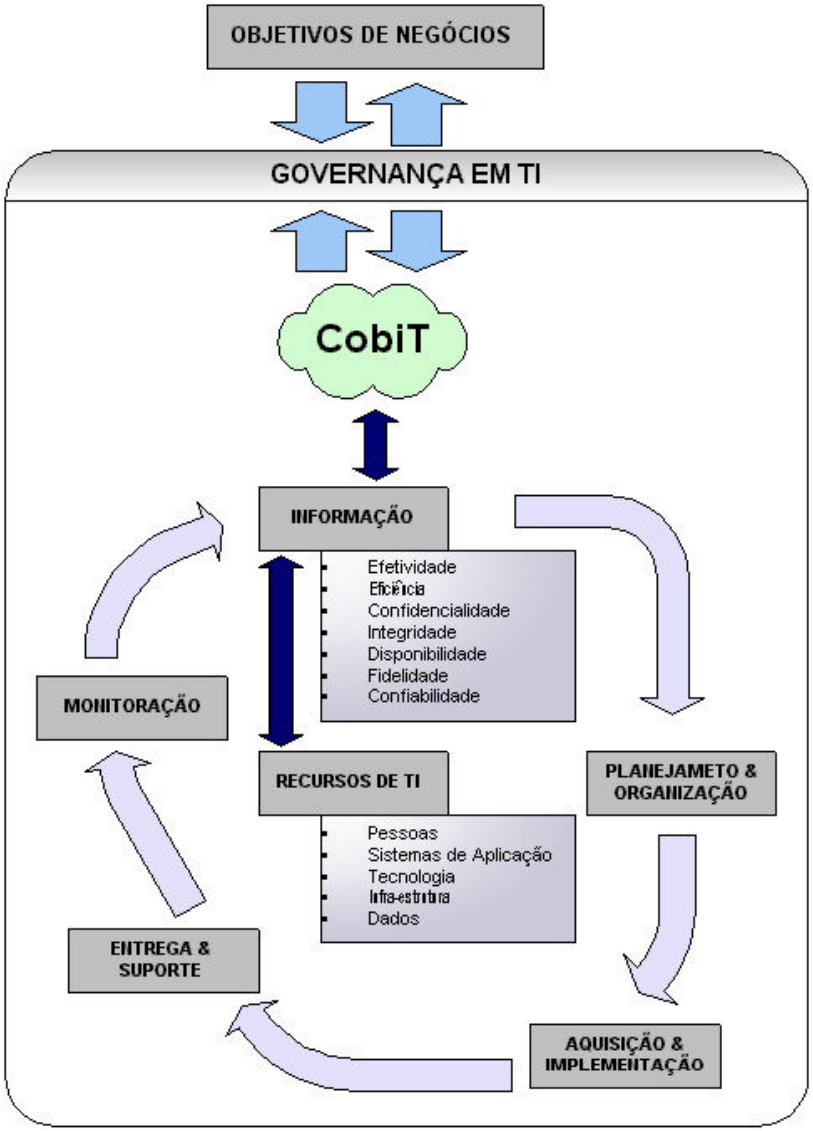


Estes processos agrupam as principais atividades de TI em um modelo de processo, facilitando o gerenciamento dos recursos de TI para atender as necessidades do negócio. Os processos de TI são definidos e classificado em **4 domínios**, contendo **34 processos** de TI. Estes processos serão desmembrados e definidos em atividades e tarefas na organização.

Domínios

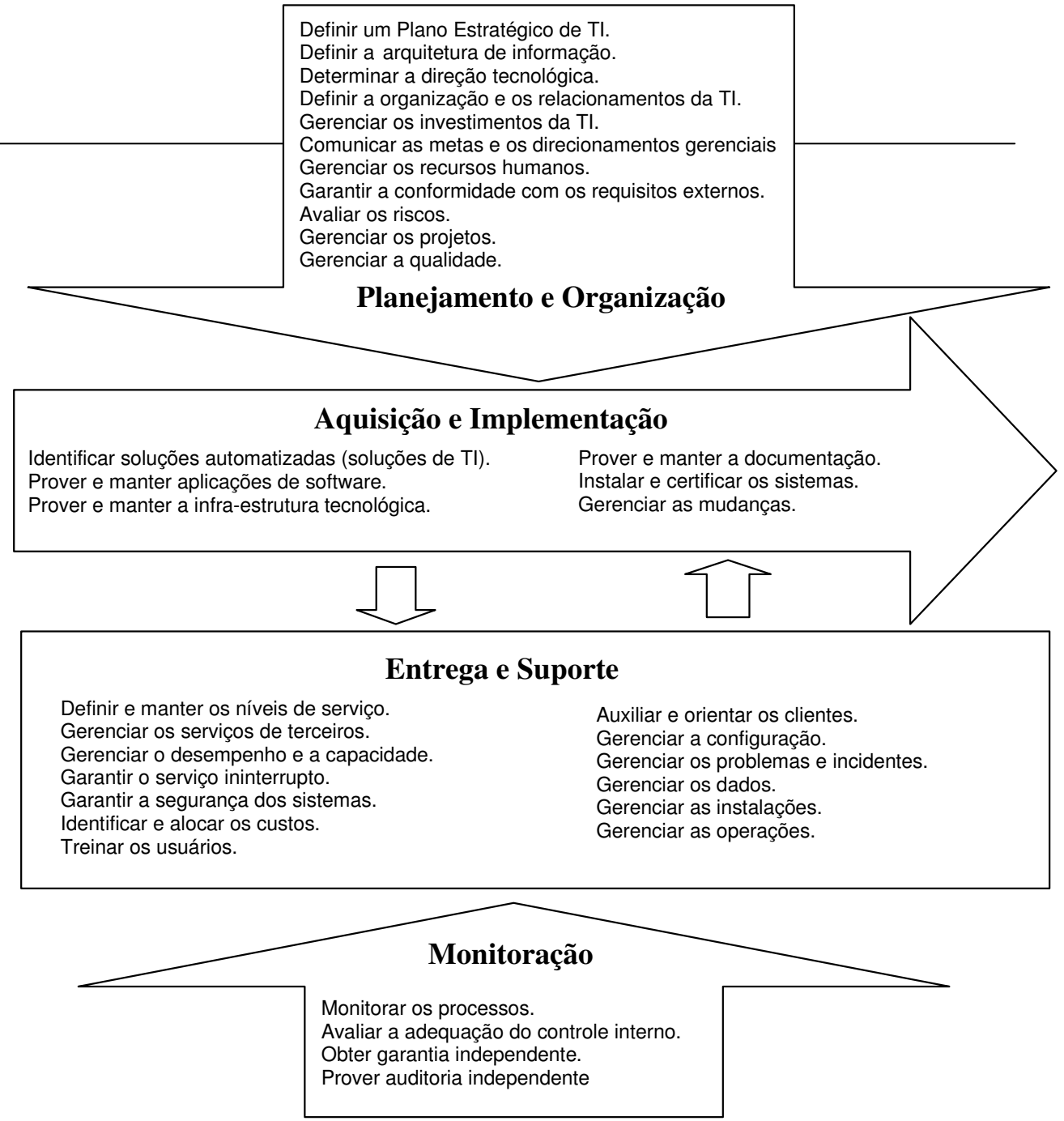
Os processos do COBIT são agrupados em **4 domínios**:

1. **Planejamento e Organização**
2. **Aquisição e Implementação**
3. **Entrega e suporte**
4. **Monitoração e avaliação**



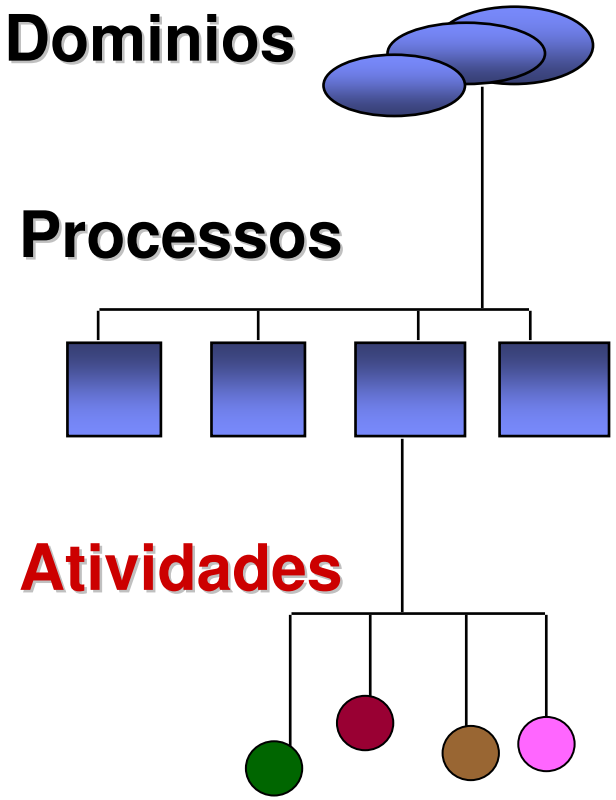
Processos

Os 4 domínios possuem 34 Processos. Estes processos especificam o que o negócio precisa para alcançar seus objetivos. A entrega de informação é controlada por 34 objetivos de controle de alto nível, um para cada processo.



Atividades

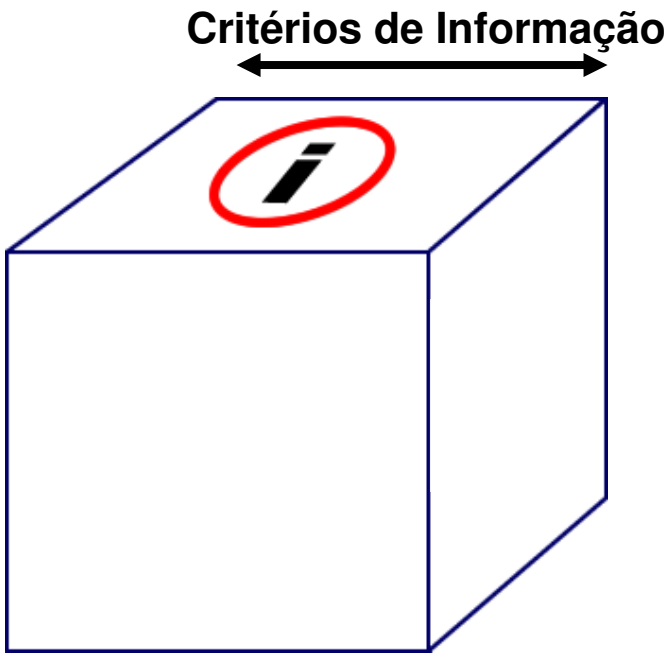
Existem ações que são necessárias para alcançar resultados mensuráveis. As atividades tem ciclos de vida, mas as tarefas não.



Critérios de Informação

Para satisfazer os objetivos de negócio, as informações precisam estar em conformidade com os critérios chamados **requisitos de negócio**.

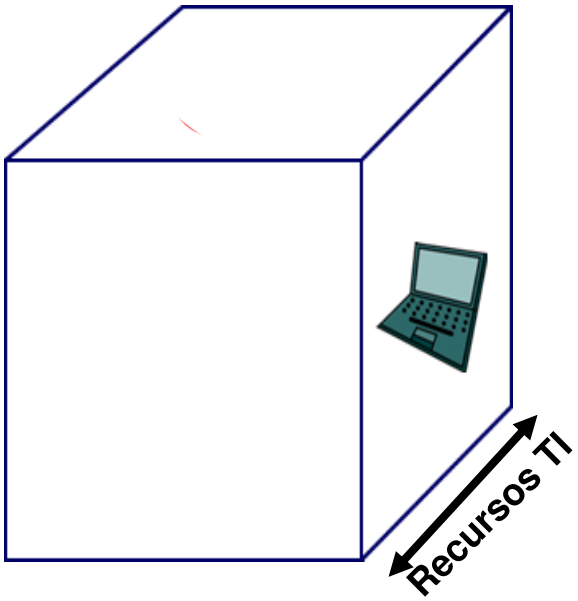
- **Requisitos de Qualidade**
  - →Qualidade
  - →Custo
  - →Entrega
- **Requisitos Fiduciários (Relatório do COSO)**
  - →Eficácia e eficiência das Operações
  - →Confiabilidade das Informações
  - →Conformidade com Leis e Regulamentos
- **Requisitos de Segurança**
  - →Confidencialidade
  - →Integridade
  - →Disponibilidade



Requisitos de negócio = Critérios de Informação

Recursos de TI

Os recursos de TI são gerenciados pelos processos de TI para fornecer informação que a organização precisa para alcançar seus objetivos.



- **Aplicações**: sistemas automatizados e procedimentos manuais para processar informações
- **Informação**: os dados de todos os formulários de entrada, processados e exibidos pelos sistemas de informação, podendo ser qualquer formulário que é usado pelo negócio.
- **Infra-estrutura**: inclui hardware, sistemas operacionais, sistemas de banco de dados, rede, multimídia, etc. É tudo que é necessário para o funcionamento das aplicações.
- **Pessoas**: pessoal necessário para planejar, organizar, adquirir, implementar, entregar, dar suporte, monitorar e avaliar os sistemas de informação e serviços. Eles podem ser internos ou terceirizados.

O COBIT para a Governança de TI

O COBIT para Governança de TI

Agora vamos aprender como o COBIT atende os requisitos para um Framework de Controle ou Governança de TI.

Todas as empresas usam o suporte de TI para realizar suas operações e estratégias. Desta forma, a Governança de TI e os Frameworks de Controle como o COBIT são necessários. Vamos ver mais agora sobre os componentes do COBIT e como o COBIT é usado na Governança de TI.

Componentes das Diretrizes de Gerenciamento

As diretrizes de gerenciamento do COBIT fornecem ferramentas para criar painéis, scorecards, benchmarking para ajudar a responder questões relacionadas a TI e o negócio. Os principais componentes das diretrizes são os seguintes:

- **Entradas e saídas de processos**
- **Atividades dos Processos e gráficos RACI**
- **Objetivos de Negócio, TI, processo, e atividades**
- **Métricas – indicadores de meta**
- **Métricas - indicadores de desempenho**
- **Modelos de Maturidade**

Key Goal Indicators (KGIs)

Indicadores de meta – são medidas pré-definidas que indicam se um processo de TI alcançou o requisito do negócio em termos de critérios de informação.

Os KGIs para TI são os drivers de negócio, usualmente suportam as perspectivas financeiras e clientes, são medidas que refletem se atingiu-se a meta, são medidas após o fato ocorrido, usualmente expressos nos seguintes termos:

- Disponibilidade das informações necessárias para suportar as necessidades de negócios;
- Riscos de falta de integridade e confidencialidade das informações;
- Eficiência nos custos dos processos e operações;
- Confirmação de confiabilidade, efetividade e conformidade das informações.



Key Goal Indicators

Key Goal Indicators (KGIs)

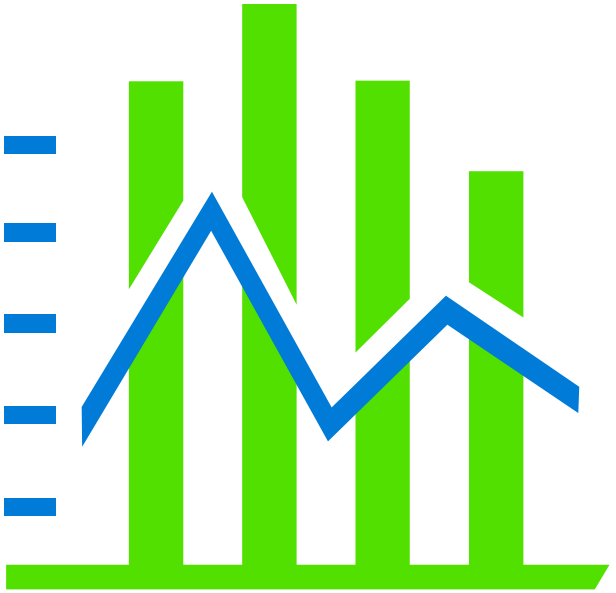
Exemplos de KGIs:

- Aumento do Nível de entrega de serviço
- Número de clientes e custo por cliente atendido
- Disponibilidade dos sistemas e serviços
- Ausência de integridade e riscos de confidencialidade
- Confirmação da confiabilidade e eficácia
- Aderência ao custo de desenvolvimento e prazo
- Custo-eficiência do processo
- Produtividade da equipe
- Número de mudanças aplicadas na hora certa nos processos e sistemas
- Aumento da produtividade

Key Performance Indicators (KPIs)

Indicadores de Performance – são medidas pré-definidas que determinam quanto o processo de TI conseguiu atingir em relação aos objetivos.

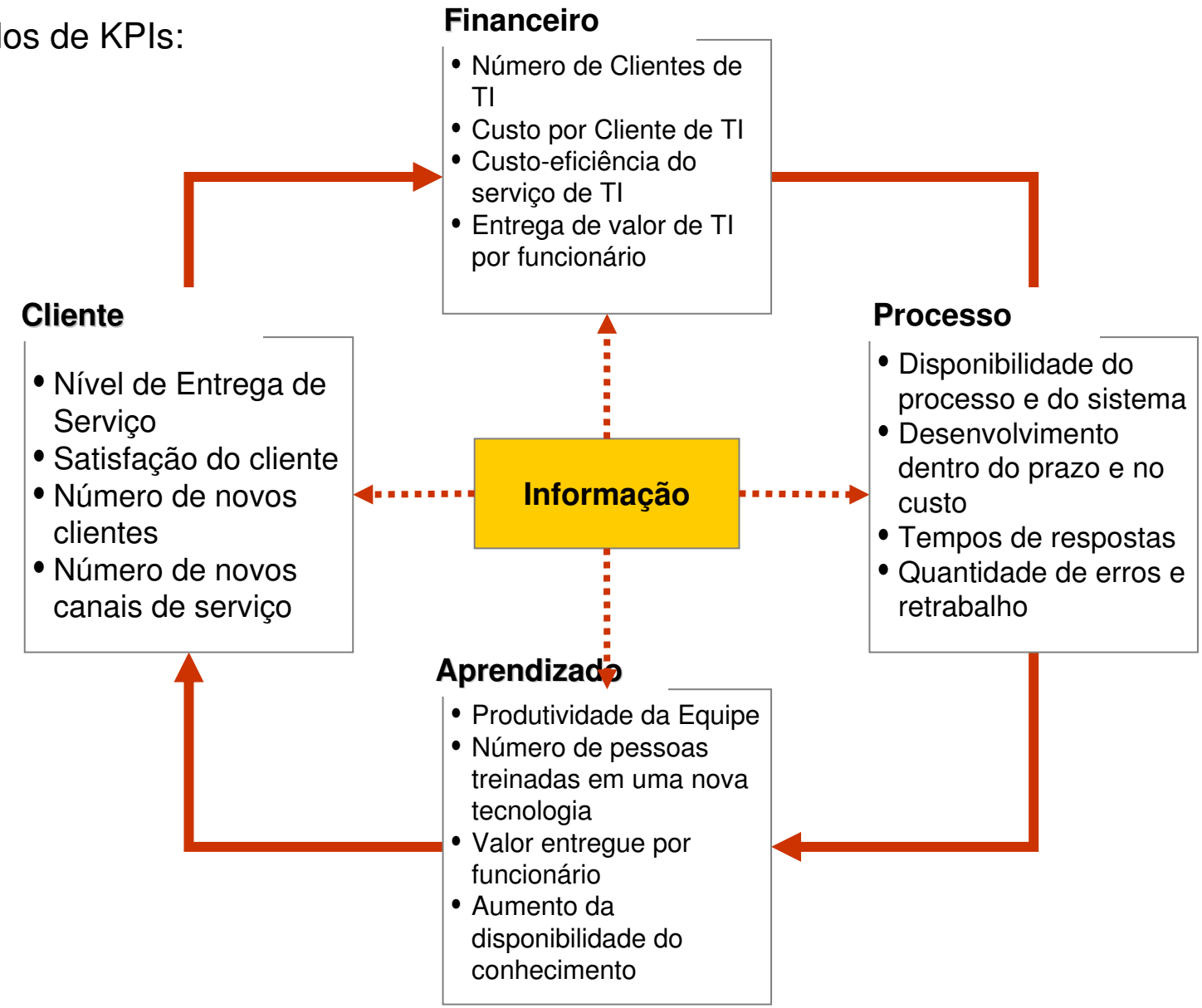
Os KPIs referem-se às perspectivas dos processos e da inovação, são medidas que refletem as tendências em termos de atingir ou não a meta no futuro, são medidas antes do fato.



Key Performance Indicators

Key Performance Indicators (KPIs)

Exemplos de KPIs:



Atividades dos Processos e Gráficos RACI

Atividades dos Processos e gráficos RACI mostram várias funções que existem para as atividades chaves, podendo ser do tipo:

- **Responsible** (Responsável),
- **Accountable** (Deve prestar Conta),
- **Consulted** (Deve ser Consultado),
- **Informed** (Deve ser informado).

RACI Chart

Activities \ Functions	CEO	CFO	Business Executive	CIO	Business Process Owner	Head Operations	Chief Architect	Head Development	Head IT Administration	PMO	Compliance, Audit, Risk and Security
Link business goals to IT goals.	C	I	A/R	R	C						
Identify critical dependencies and current performance.	C	C	R	A/R	C	C	C	C	C		C
Build an IT strategic plan.	A	C	C	R	I	C	C	C	C	I	C
Build IT tactical plans.	C	I		A	C	C	C	C	C	R	I
Analyse programme portfolios and manage project and service portfolios.	C	I	I	A	R	R	C	R	C	C	I

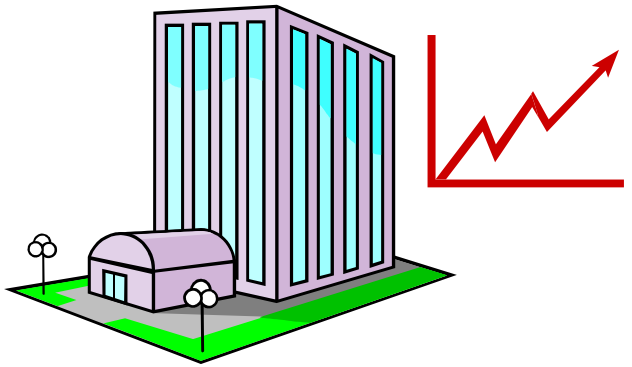
A **RACI** chart identifies who is **R**esponsible, **A**ccountable, **C**onsulted and/or **I**nformed.

Modelos de Maturidade

Os modelos de maturidade de governança são usados para o controle dos processos de TI e fornecem um método eficiente para classificar o estágio da organização de TI.

Essa abordagem é derivada do modelo de maturidade para desenvolvimento de software, *Capability Maturity Model for Software* (SW-CMM), proposto pelo *Software Engineering Institute* (SEI). A partir desses níveis, foi desenvolvido para cada um dos 34 processos do CobiT um roteiro:

- Onde a organização está hoje
- O atual estágio de desenvolvimento da indústria (*fazendo uma comparação da empresa com outras*)
- O atual estágio dos padrões internacionais
- Aonde a organização quer chegar e como ela planeja isto



Modelos de Maturidade

Modelos de Maturidade

A governança de TI e seus processos com o objetivo de adicionar valor ao negócio através do balanceamento do risco e retorno do investimento podem ser classificados, seguindo o modelo do CMM (Capability Maturity Model), da seguinte forma:

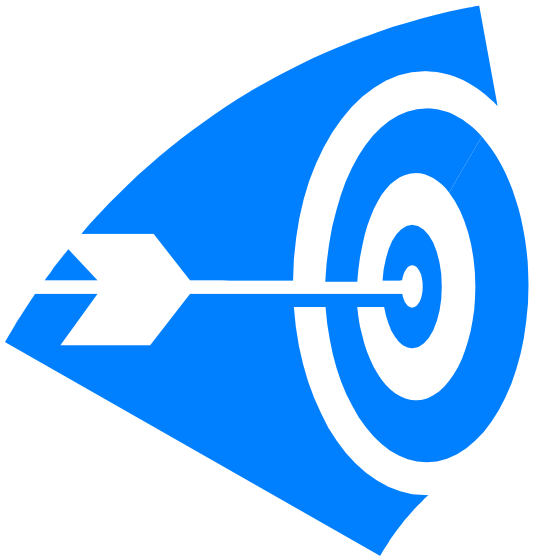


Orientado ao negócio

Orientação ao negócio é um dos temas principais do COBIT. Ele foi criado para não ser empregado apenas pelos provedores de serviço de TI, usuários e auditores, mas também, e mais importante, como um guia para os responsáveis pela gestão e negócios da empresa.

O COBIT ajuda a implementar um sistema de controle de gerenciamento, isto porque o COBIT atua abaixo da tecnologia utilizada pela empresa, tendo um foco maior sobre o negócio. O COBIT foca em dizer o “que precisa” ser feito, não se preocupando em “como fazer”. O COBIT irá trabalhar com padrões e melhores práticas na área de TI como questões ligadas a segurança, gerenciamento de projetos, e assim por diante.

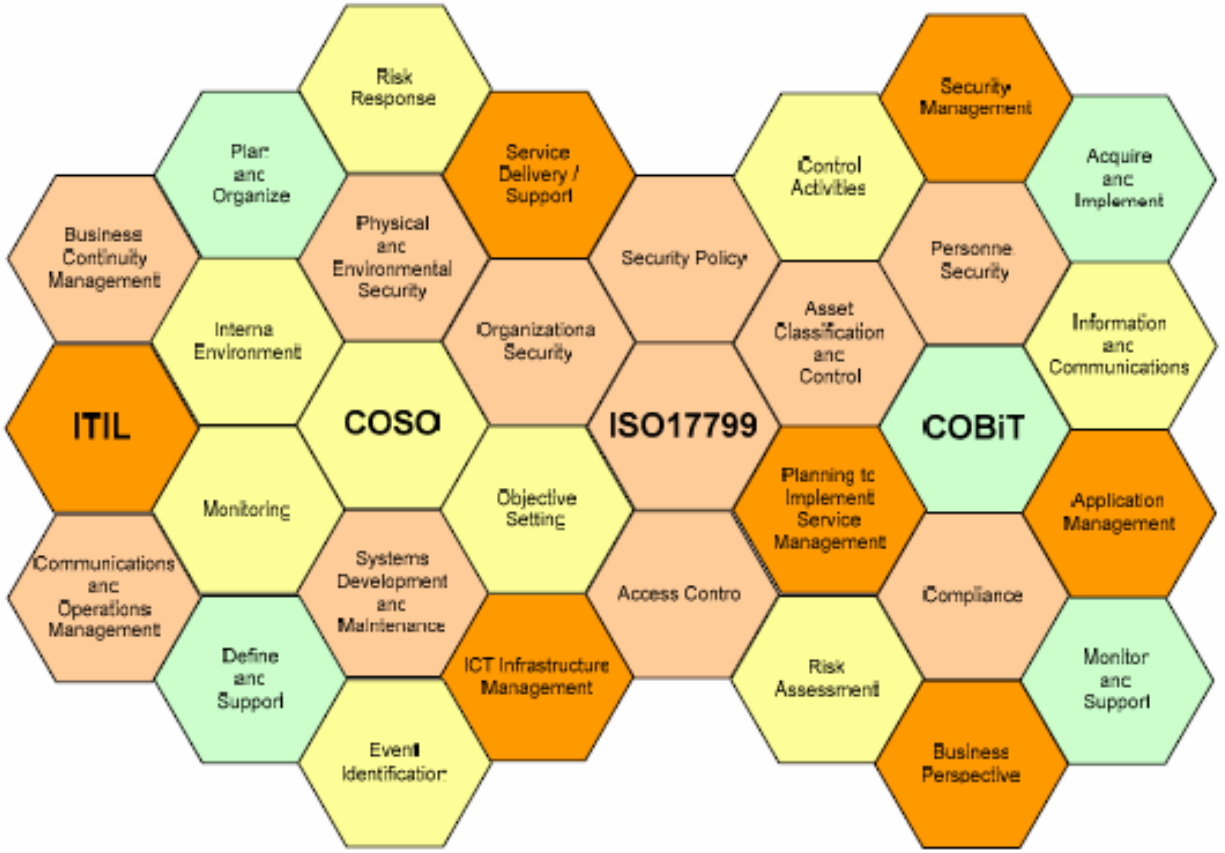
O COBIT diz **o que** fazer,
mas não **como** fazer.



O COBIT e outros Padrões de Mercado

Padrão de facto

O COBIT é um framework único, não tendo outro similar, pois ele acomoda os padrões internacionais mais importantes e é reconhecido como um padrão de facto para o controle de TI. O COBIT está sendo atualizado constantemente para contemplar os novos cenários nos negócios.



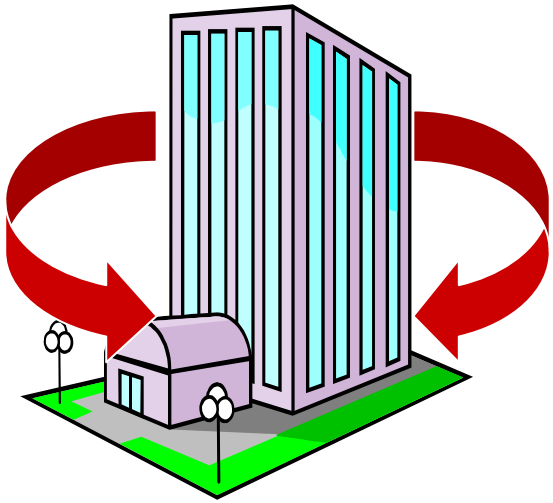
Relacionamento com outros Padrões

Muitas empresas acham conveniente usar o COBIT porque ele se relaciona com outros frameworks, tais como COSO, ITIL, ISO 17799, CMM e PMBOK.

ITIL	ISO 17799	CMM	COSO	PMBOK
O ITIL é uma biblioteca das melhores práticas para o gerenciamento de serviços de TI. Ele é focado em “como” deve ser os serviços e os processos de TI.	Fornece recomendações para gestão da segurança da informação, direcionado para quem é responsável pela introdução, implantação ou manutenção da segurança em suas organizações.	O SEI(Software Engineering Institute) é a organização que desenhou o Capability Maturity Model (CMM). Este modelo ajuda as empresas a melhorem seus processos de entrega de software e controle de processos.	O Framework COSO é uma padrão aceito para estabelecer controles internos na empresa e determinar sua eficácia, pode ser aplicado a TI como também a qualquer área da empresa.	O PMBOK, mantido pelo PMI, é uma coleção de processos e áreas de conhecimento geralmente aceitas com melhores práticas para o gerenciamento de projetos.

Vantagens da adoção do COBIT

O COBIT é totalmente compatível com outros frameworks.

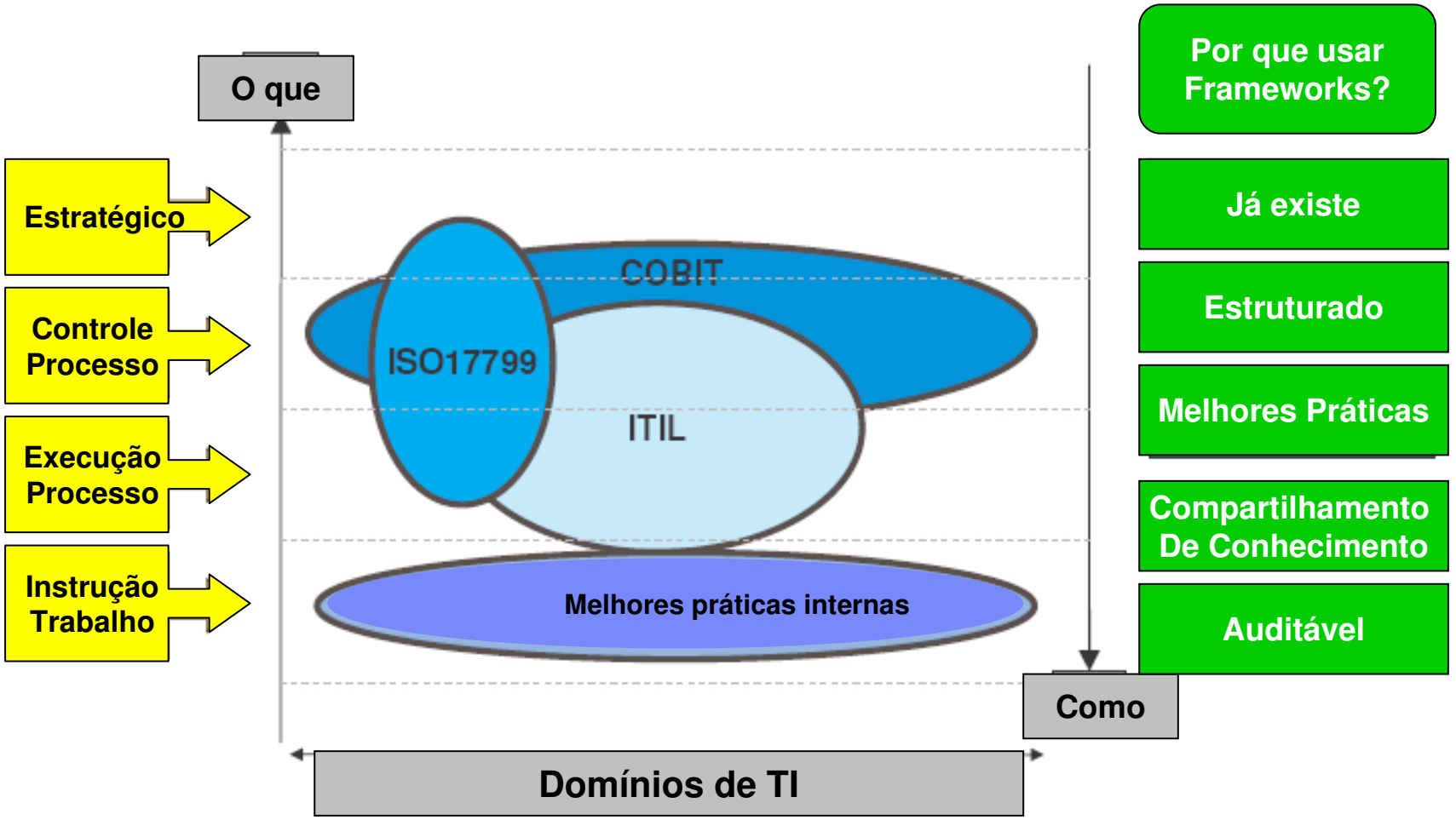


Estes frameworks fornecem um ambiente altamente controlado e flexível na organização.

Faz com que o ambiente de TI se torne mais responsivo às necessidades do negócio, fornecendo mais controle sobre suas responsabilidades.

Foco de atuação de cada padrão

Agora vamos discutir sobre as funções dos vários padrões em vários níveis de processos na empresa. Por exemplo, o ITIL foca na entrega de serviços e suporte, considerando os aspectos técnicos do controle do processo. O CMM foca na execução do processo de entrega de software e controle do processo. A ISO 17799 oferece orientações sobre a segurança dos processos e controles estratégicos. O COBIT foca tanto no controle do processo como no controle estratégico em uma empresa.



Benefícios dos Frameworks

Existem várias razões para adotar um padrão já definido:

A roda já existe: tempo é dinheiro! Por que gastar tempo e esforço para desenvolver um novo framework baseado na experiência limitada da empresa ao invés de adotar um padrão internacional já existente?

Estruturado: os modelos de framework fornecem uma excelente estrutura para que as organizações possam seguir.

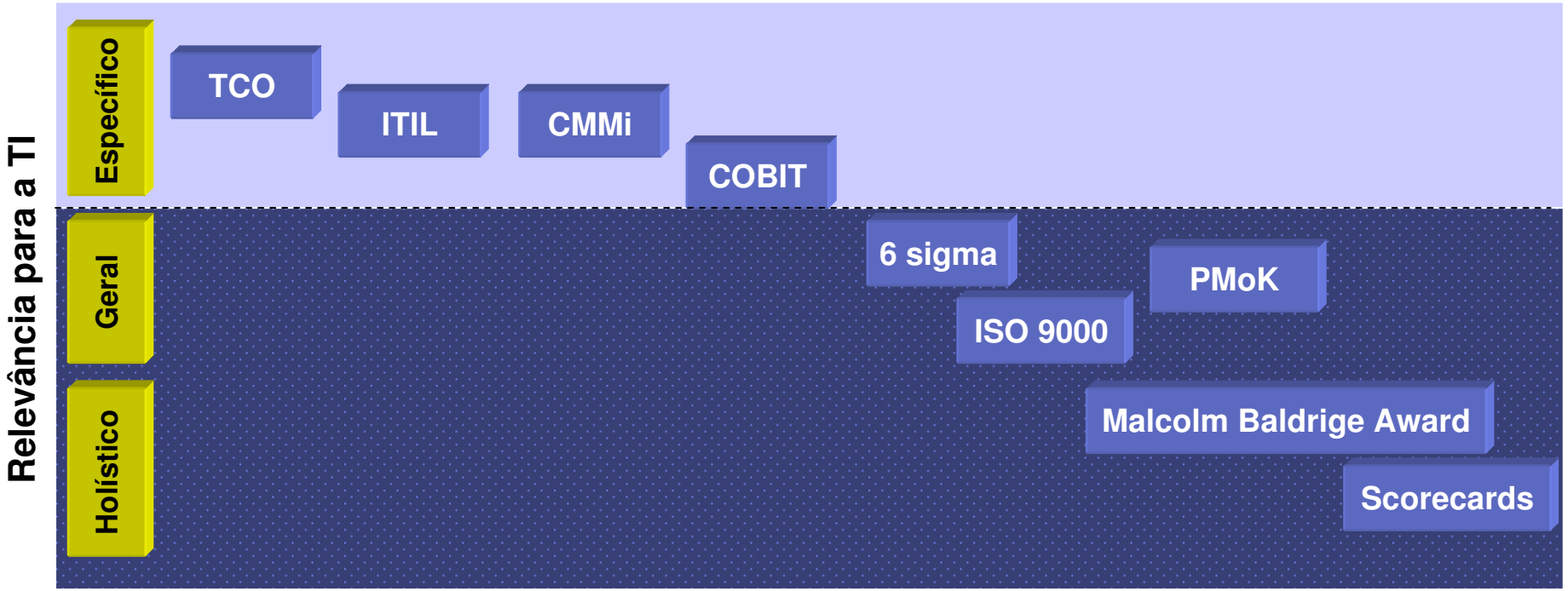
Melhores práticas: os padrões foram desenvolvidos ao longo do tempo a avaliados por centenas de pessoas e organizações em todo o mundo. Os anos de experiência nos modelos não são apenas de uma empresa.

Compartilhamento de Conhecimento: seguindo os padrões, as pessoas podem compartilhar as mesmas idéias entre as organizações através de grupos de usuários, sites, revistas, livros e assim por diante.

Auditável: sem padrões se torna difícil para os auditores, especialmente para os auditores que são terceirizados, para que estes possam avaliar o controle. Isto significa que os auditores podem seguir os padrões ao invés de utilizar práticas de auditorias ainda na fase inicial de uso.

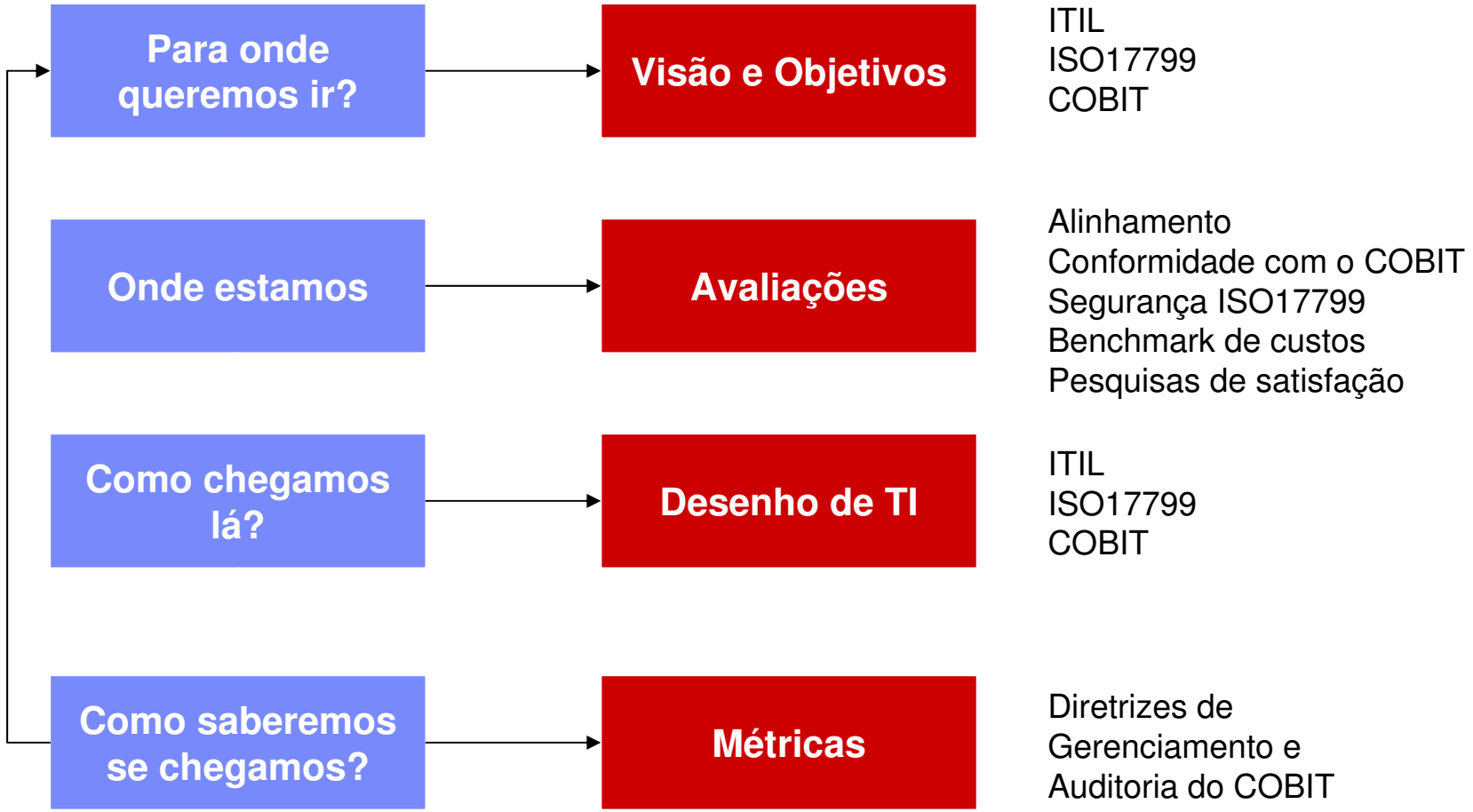
Relevância dos padrões

A relevância dos padrões e práticas variam em cada empresa conforme suas prioridades e expectativas. Uma empresa pode decidir adotar um padrão por inteiro ou somente parte dele para melhorar a performance de um processo de negócio ou promover a transformação no negócio. O COBIT está posicionado no centro como um nível Geral, ajudando a integrar a parte técnica, práticas específicas com o negócio de forma geral.



Melhoria Contínua em TI

A melhoria continua de TI exige um ciclo de ações



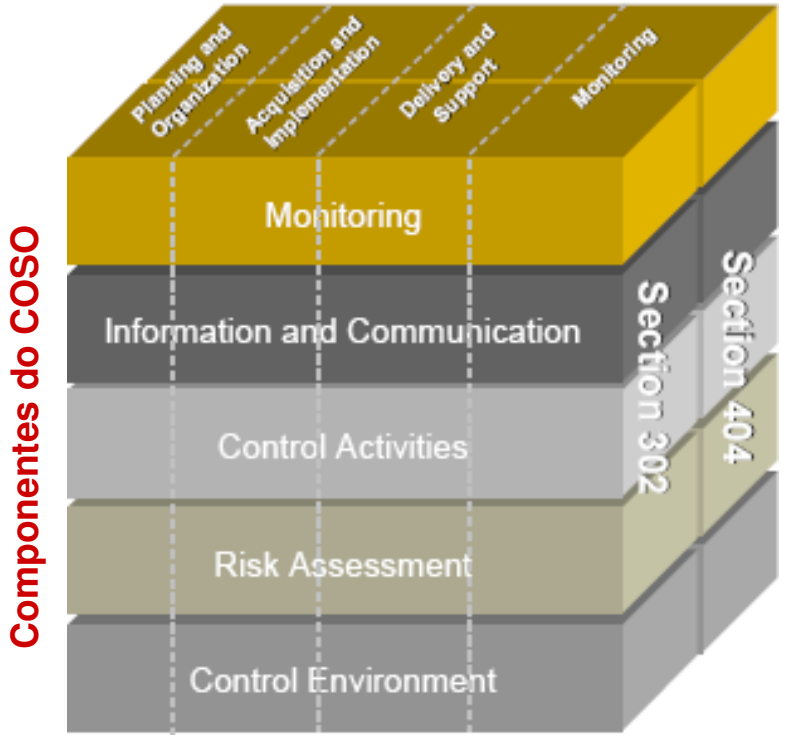
Relação com o COSO

O COSO declara que o controle interno é um processo estabelecido pelo conselho administrativo, gerentes e outros – desenhado para fornecer uma segurança razoável relacionada a realização dos objetivos declarados. É um framework aplicado para auditar processos em grandes empresas, em qualquer atividade.

O COBIT apresenta controles de TI se preocupando com a informação em geral - não apenas informação financeira – que é necessária para suportar os requisitos de negócio e os recursos e processos associados com TI.

Da mesma forma que COSO identifica 5 componentes de controle para alcançar os objetivos de reporte financeiro, o COBIT proporciona um guia detalhado para TI.

A diferença maior é que o COSO é genérico, pode ser utilizado em qualquer atividade da empresa, enquanto que o COBIT é voltado somente para a área de TI.



Relação com o ITIL

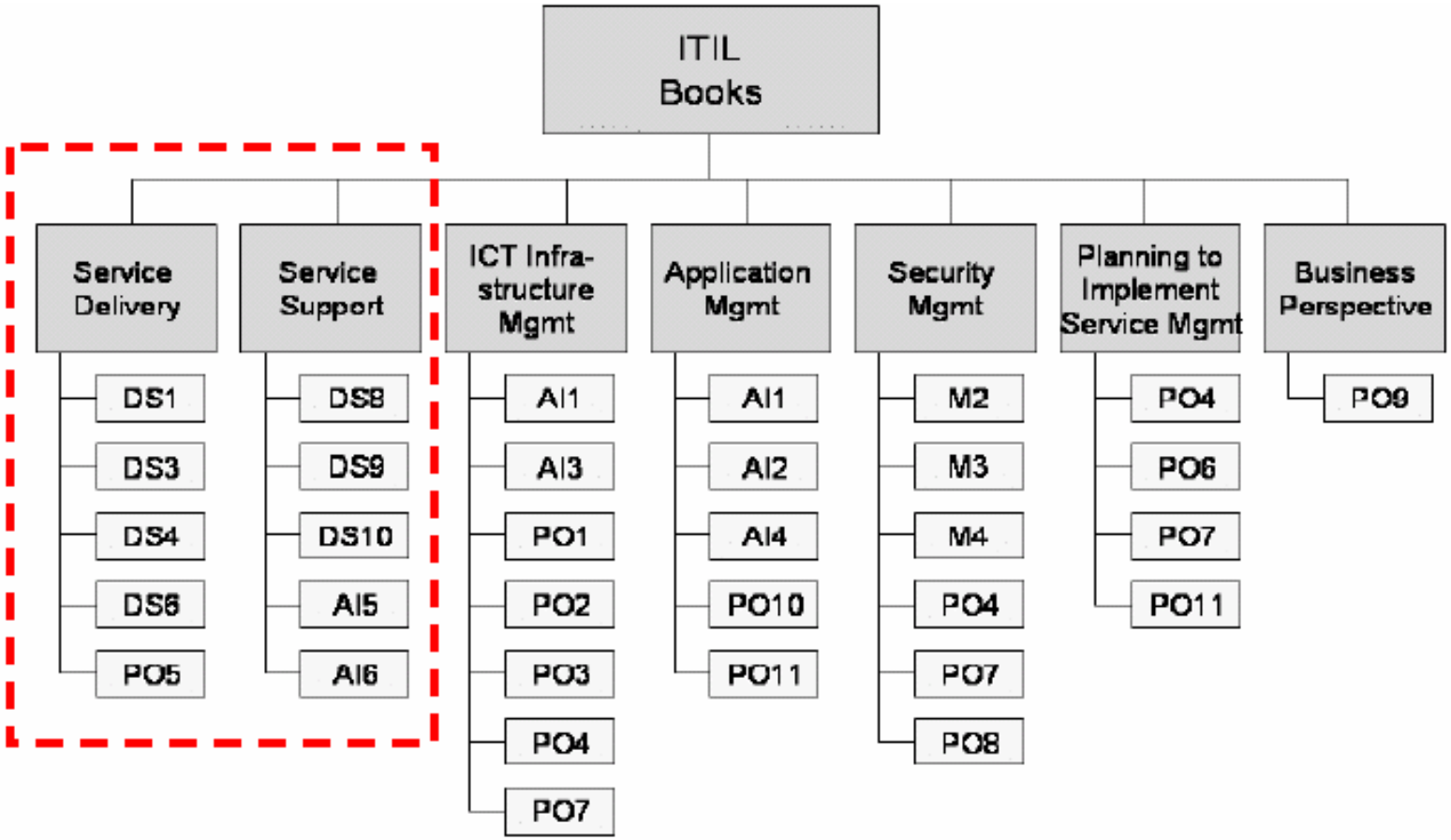
Tanto o ITIL como o COBIT são excelentes ferramentas para a TI aperfeiçoar processos e alinhar as funções de TI com o negócio e requisitos regulatórios. Em cada processo deve se utilizar as duas ferramentas juntas. Quando isto acontece, a empresa tem dois ganhos: a curto prazo terá um esforço de trabalho único e a longo prazo uma solução de processo e conformidade para TI.

Vejamos Principais características entre os dois:

- O COBIT fornece um framework que cobre todas as atividades de TI
- O ITIL é mais focado no gerenciamento de Serviços (domínio de Entrega e Suporte do Cobit)
- O ITIL é mais detalhado e orientado a processos
- O COBIT ajuda a vincular as melhores práticas do ITIL aos os requisitos de negócio e aos responsáveis do processo de TI
- As métricas do COBIT podem definir critérios de SLA (níveis de serviço)
- O COBIT e o ITIL não são mutuamente exclusivos e podem ser combinados para uma boa Governança de TI, controle e melhores práticas para o gerenciamento de TI.

Relação com o ITIL

O diagrama abaixo apresenta os principais livros da biblioteca do ITIL e o relacionamento com os objetivos de controle dos 4 domínios do COBIT. Em cada livro da biblioteca do ITIL existe Objetivos de Controle do COBIT que são aplicáveis ao processo do ITIL.

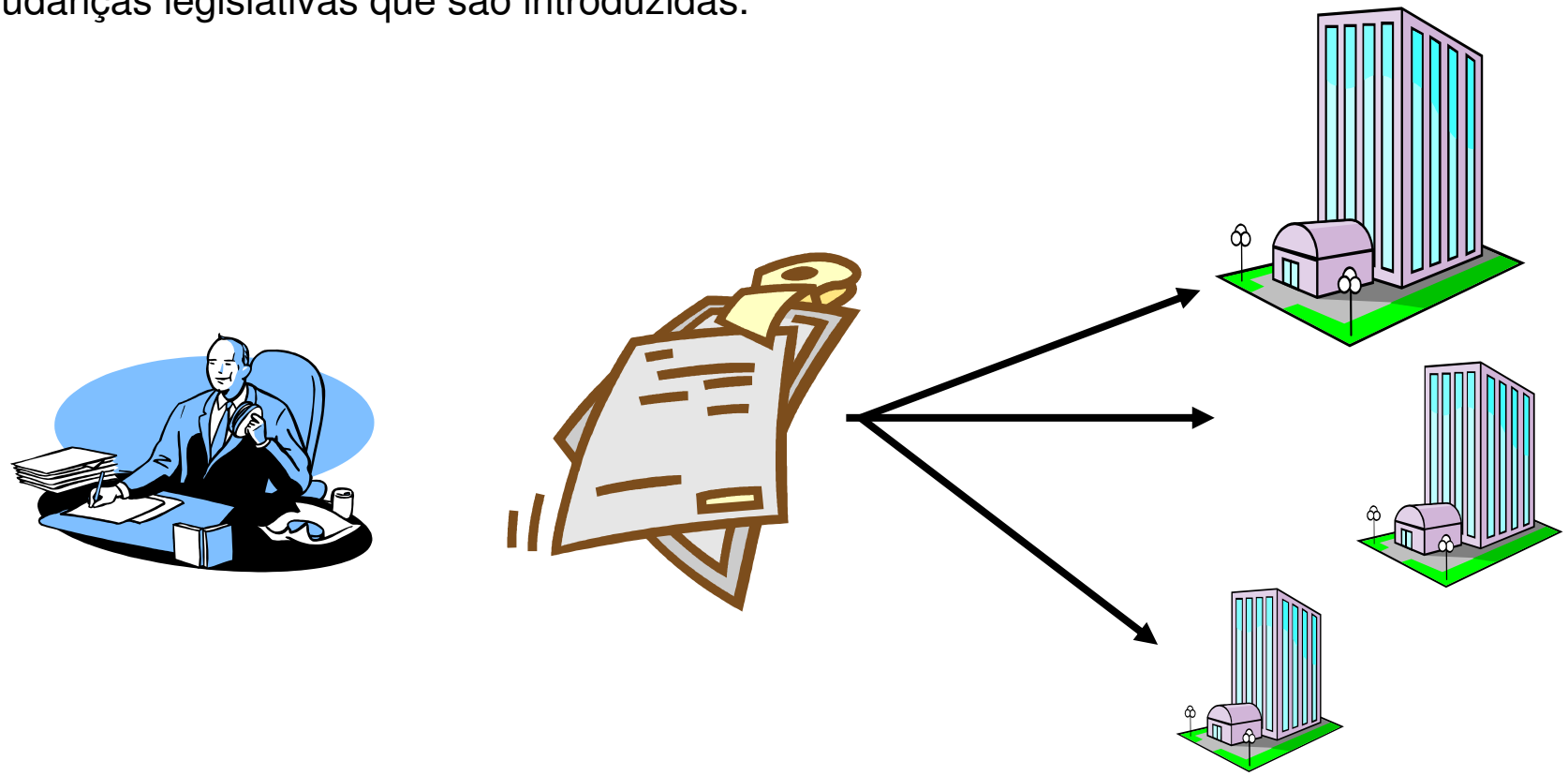


Funções e Componentes

COBIT x Requisitos regulatórios

A conformidade com os requisitos regulatórios na qual a empresa está submissa é agora visto como uma questão crítica para o negócio, e faz parte da iniciativa da governança corporativa.

O COBIT é um framework que inclui uma lista de controles que a organização deve seguir para assegurar que as suas práticas de negócio em TI estejam alinhadas com os requisitos regulatórios. Adotando o COBIT as organizações estarão em conformidade com as mudanças legislativas que são introduzidas.



Sarbanes Oxley

Com o resultado dos escândalos financeiros em grandes empresas em 2001, o Congresso americano decretou o Ato Sarbanes-Oxley de 2002. Este ato afeta como as empresas de capital aberto irão apresentar seus relatórios financeiros, e significativamente impacta a área de TI. A conformidade com a Sarbanes-Oxley requer mais do que documentação e estabelecimento de controles financeiros, ela tambem requer a avaliação da infra-estrutura de TI e suas operações e pessoal.

Principais Características da Sarbanes Oxley - Ato de 2002:

- Estabelece novos padrões de responsabilidade contábil corporativa, confiabilidade e transparência dos relatórios financeiros.
- Ênfase na transparência dos dados para análise e interpretação dos dados
- Ênfase no uso de um Framework de Controle para avaliação de controles internos.
- Penalidades rígidas no caso de danos – seja eles intencionais ou não
- Implementação de diretrizes do SEC (Securities and Exchange Commission)

Com mais de 300 seções, a SOX é provavelmente a legislação mais significante para os negócios nos EUA.

Sarbanes Oxley

A conformidade com a SOX (Sarbanes Oxley) irá impactar significativamente as organizações de TI na maioria das empresas de capital aberto. Entretanto, existe um grande problema: não existe nenhuma menção específica nas seções da SOX voltada para a TI, e mais importante ainda, não existe nenhuma especificação de quais controles precisam ser estabelecidos dentro da TI para estar em conformidade com a SOX.

Para resolver este problema muitas empresas acabam adotando o COBIT, pelo fato dele definir quais os objetivos de controle que precisam ser implementados na TI. Além disto, o COBIT é um modelo independente de plataforma, independe de tecnologia, podendo ser adotado em qualquer organização de TI.

O COBIT está sintonizado com os requisitos legais destas leis. O COBIT é o único modelo de controle que é compatível com o COSO, cobre todas as atividades de TI e é aceito geralmente pela comunidade de auditores.

Assegurando que a TI está em conformidade com o COBIT fará com que a maioria dos requisitos de conformidades já tenham sido implementados. Usando o COBIT fará com que a organização esteja atendendo a maioria dos requisitos das leis da SOX.

Processos do COBIT para a SOX

O COBIT possui processos que podem auxiliar na conformidade com a Sarbanes-Oxley:

1. **Adquirir e manter software aplicativo**
2. **Adquirir e manter arquitetura tecnológica**
3. **Desenvolver e manter procedimentos de TI**
4. **Instalar e certificar Soluções e Mudanças**
5. **Gerenciar mudanças**
6. **Definir e gerenciar níveis de serviço**
7. **Gerenciar serviços de terceiros**
8. **Assegurar a segurança dos sistemas**
9. **Gerenciar a configuração**
10. **Gerenciar Problemas**
11. **Gerenciar Dados**
12. **Gerenciar Operações**

Como o COBIT ajuda os Auditores e Diretores

O Framework do COBIT ajuda não apenas os usuários técnicos mas também aqueles que são responsáveis pelo uso efetivo de TI, tais como diretores e auditores. O Framework do COBIT ajuda estes usuários a assegurar que:

- Seus requisitos estão sendo entendidos e definidos de forma apropriada.
- Eles obtenham informação necessária para realizar os seus trabalhos.

Benefícios do COBIT

Vamos tentar resumir os principais benefícios do COBIT:

- O COBIT lida com todos os aspectos dos problemas relacionados com a Governança de TI
- O COBIT foi criado por um grande número de especialistas e experts qualificados
- O ITGI ajudou com os seus 35 anos de experiência em segurança em TI no desenvolvimento do COBIT
- O COBIT está em manutenção contínua. Periodicamente uma nova versão é publicada.
- Os patrocinadores do COBIT são organizações sem fins lucrativos, sua missão é ajudar seus clientes a alcançar seus objetivos principais.
- O COBIT pode ser aplicado em empresas de pequeno e grande porte.
- Usando o COBIT pode ser introduzido ordem e qualidade em uma política de TI

Problemas relacionados a implementação

A implementação do COBIT pode trazer alguns problemas relacionados ao seu uso.

O COBIT é um framework de controle com Diretrizes de Auditoria, Então ele:

- NÃO é um plano de auditoria
- NÃO é um programa de trabalho
- NÃO fornece passos /técnicas / procedimentos para auditoria
- NÃO define padrões
- NÃO define níveis aceitáveis para os Processos de TI

O uso do COBTI requer uma experiência suficiente com os controles de TI porque ele não detalha a verificação de controles e passos de testes de fato.



Curso Online

COBIT

FUNDAMENTOS EM GOVERNANÇA DE TI



Todos os direitos de cópia reservados. Não é permitida a distribuição física ou eletrônica deste material sem a permissão expressa do autor.

Objetivos

Este módulo descreve os componentes do Framework do COBIT e os objetivos de controle.

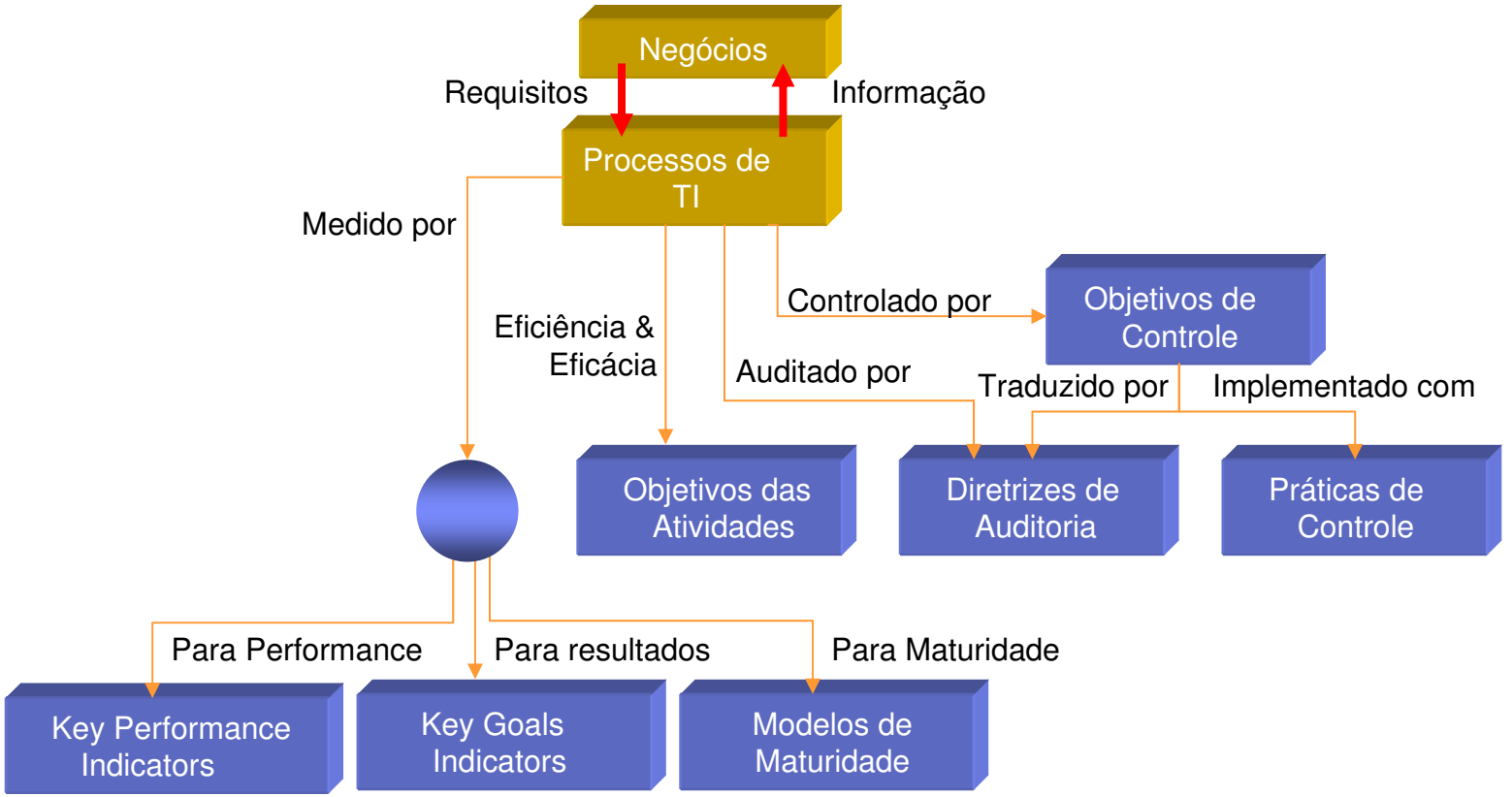
No final deste módulo você conseguirá:

- **Identificar as funções do Framework do COBIT.**
- **Identificar as características dos 4 domínios de TI.**
- **Descrever as funções dos Processos de TI.**
- **Descrever os 7 critérios de informação.**
- **Descrever como o COBIT define os recursos em um ambiente de TI.**
- **Descrever os Objetivos de Controle do COBIT.**

Framework do COBIT

Framework do COBIT

O Framework do COBIT fornece informações necessárias para suportar os objetivos de negócio e seus requisitos. O Framework explica como os Processos de TI entregam informações que o negócio necessita para alcançar seus objetivos. A entrega de informação acontece através de 34 objetivos de controle, um para cada processo de TI dos 4 domínios já vistos.



Áreas de foco

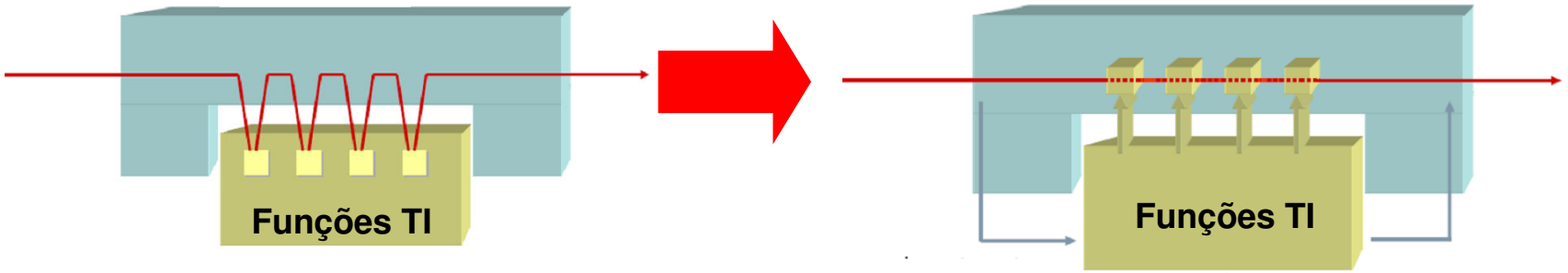
Como um framework de controle e governança de TI, o COBIT foca 2 áreas chaves:

1. Fornecer informações necessárias para suportar os objetivos e requisitos de negócio.
2. Tratar informações como sendo o resultado combinado de aplicações de TI e recursos que precisam ser gerenciados por processos de TI.

O Framework do COBIT descreve como os processos de TI entregam informações que o negócio precisa para alcançar seus objetivos. Esta entrega é controlada através de 34 objetivos de controle, um para cada processo dos 4 domínios. O Framework do COBIT tem 3 componentes chaves.

Organização das atividades

As organizações organizam suas atividades de TI em grupos, times, células ao invés de organizar em entorno de processos bem definidos que são interconectados, interdependentes, e mutuamente reforçados. Isto causa lacunas (gaps) e inconsistências.

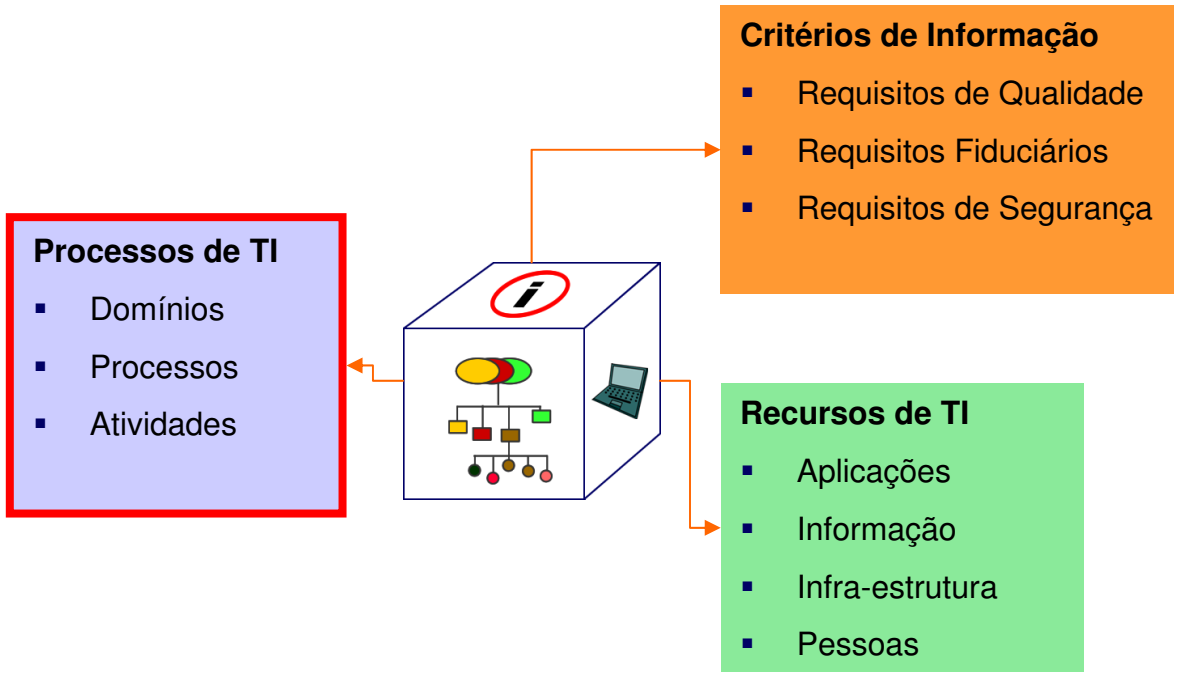


Atividades Independentes **Atividade inter-relacionadas**

O COBIT promove a organização das atividades de TI ao entorno dos processos e fornece um modelo para as organizações adotarem e adaptarem conforme necessário. Após os processos estarem definidos, eles podem ser alocados a indivíduos e gerentes que são responsáveis e deverão prestar contas por cada processo. Com esta estrutura implementada, as atividades de TI podem ser melhor entendidas, organizadas, e mais fáceis de controlar.

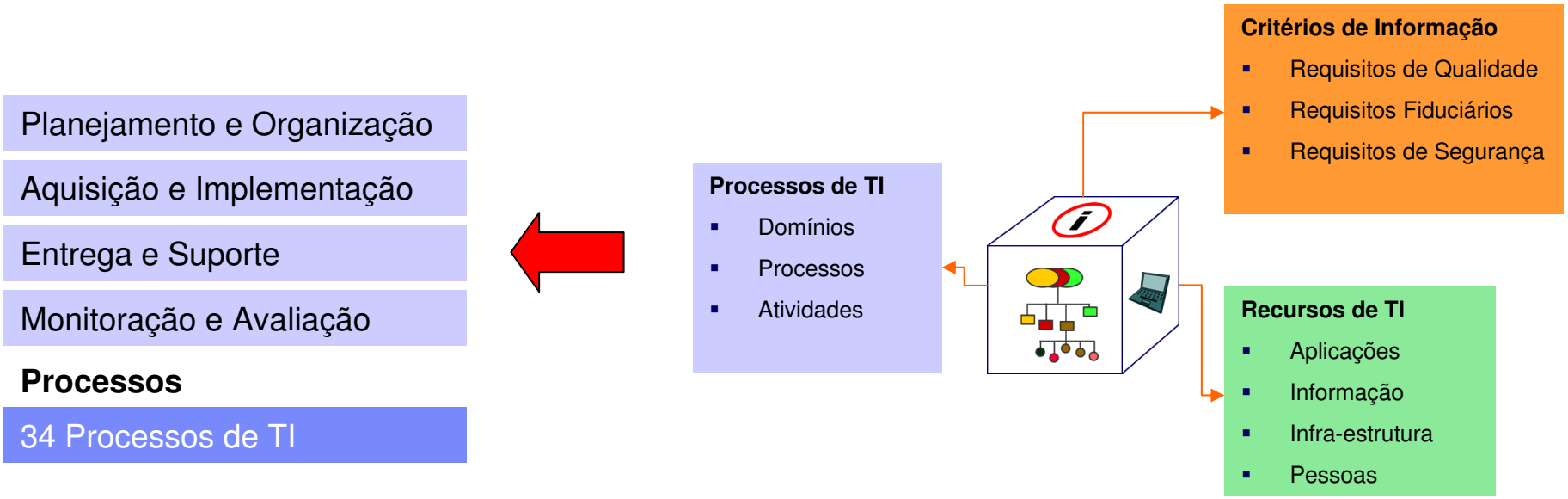
Processos de TI

Para começar, iremos aprender mais sobre os Processos de TI em detalhes.



Processos de TI

O Framework contem 34 processos de TI, os quais são organizados por domínios.



Alguns objetivos de controle existentes no framework

Requisitos de Controle Genérico

Cada processo do COBIT tem 6 requisitos de controle genérico que são comuns para todos os processos, os quais são definidos no framework. Eles podem ser analisados em conjunto com os objetivos de controle do processo de forma detalhada para que se possa ter uma visão dos requisitos de controle.

Controles de Aplicações

O COBIT assume que o projeto e implementação de controles de aplicações automatizadas devem ser de responsabilidade da TI, coberto no domínio de Aquisição e Implementação, baseado nos requisitos de negócio definidos usando os critérios de informação do COBIT.

A TI entrega e suporta os serviços das aplicações, banco de dados de informação e infra-estruturas. Os processos de TI do COBIT cobre os controles gerais da TI mais não suporta os controles de aplicações.

Requisitos de Controle Genérico

PC1 Responsável pelo Processo

Determina um proprietário para o processo do COBIT, fazendo com que a responsabilidade seja clara.

PC2 Repetitividade

Define cada processo do COBIT como sendo repetível.

PC3 Metas e Objetivos

Estabelece metas e objetivos claros para cada processo do COBIT para a execução eficaz.

PC4 Funções e Responsabilidades

Define funções, atividades e responsabilidades para cada processo do COBIT para a execução eficiente.

PC5 Performance do Processo

Mede a performance de cada processo do COBIT em relação às suas metas.

PC6 Política, Planos e Procedimentos

Documenta, revisa, mantém atualizado, comunica todas as partes envolvidas em qualquer política, plano, ou procedimentos que guiam os processos do COBIT.

Controles de Aplicações

AC1 Transação de Entrada de Dados e Autorização
A transação de entrada de dados dentro das aplicações de negócio devem ser preparadas corretamente por pessoas seguindo políticas internas ou contratos externos incluindo a prevenção e detecção de erros.

AC2 Coleção de Documentos de Origem e Entrada de Dados
A Entrada de dados é realizada na hora certa pelos membros autorizados da equipe.

AC3 Exatidão, Integridade e Verificação de Autorização durante o Processamento
Os dados que são entrados no processamento (sejam eles gerados por pessoas ou por sistemas), devem ser verificados quanto a sua exatidão, integridade e validade.

AC4 Integridade e Validade do Processamento de Dados
Verifica se os controles de processamento estão sendo executados corretamente. Executa a validação, autenticação e edição o mais próximo possível do ponto de origem dos dados.

AC5 Revisão de Saída, Reconciliação e Gerenciamento de Erros
A exatidão e integridade do processamento de dados podem ser verificados através de relatórios que podem fornecer informações relevantes e identificação de possíveis erros.

AC6 Autenticação e Integridade da Transação
Assegura que exista um processo para identificação de transações não autenticadas.

Domínio de Planejamento e Organização

Objetivo

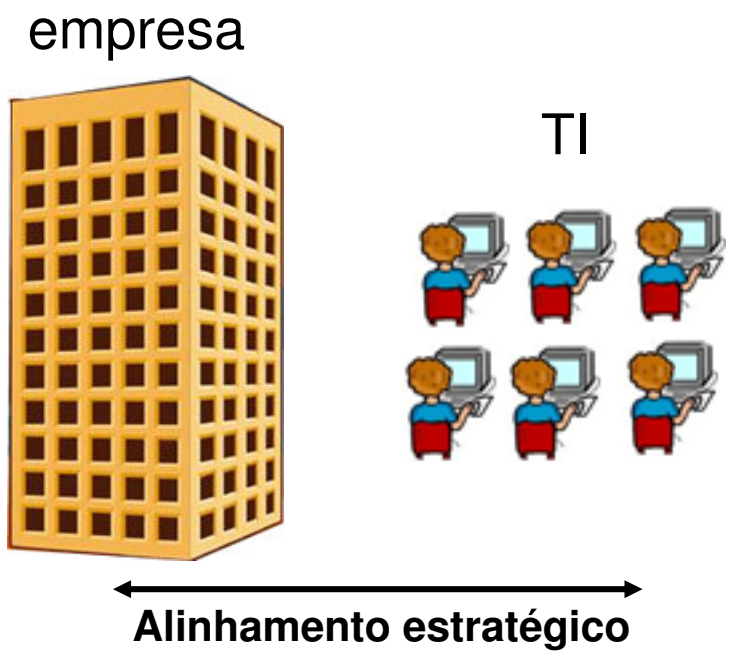
Este domínio cobre estratégias e táticas, e se preocupa com a melhor forma com a que TI pode contribuir para atingir os objetivos do negócio. Além disto, a realização da visão estratégica precisa ser planejada, comunicada e gerenciada por diferentes perspectivas.

Escopo do Domínio

Estratégias e Táticas: alinha a TI e a estratégia de negócio. Otimiza o uso dos recursos da empresa.

Visão Estratégica: faz com que todos na organização entendam os objetivos da TI.

Organização e Infra-estrutura: se preocupa em verificar se os riscos de TI estão sendo gerenciados, se qualidade dos sistemas de TI são apropriadas para as necessidades do negócio.



Domínio de Aquisição e Implementação

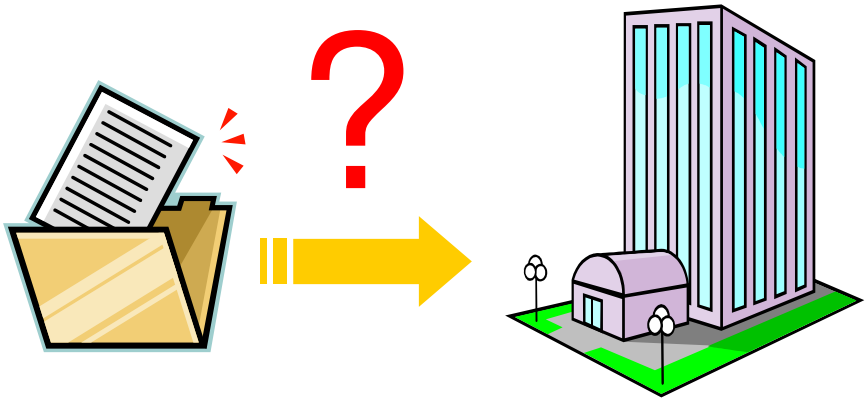
Objetivo

Para conseguir cumprir a estratégia de TI, as soluções de TI precisam ser identificadas, desenvolvidas ou adquiridas, e implementadas e integradas nos processos de negócio. O domínio da Aquisição e Implementação cobre mudanças e manutenções nos sistemas existentes para assegurar que eles operem sem interrupções.

Escopo do Domínio

Soluções de TI: verifica se os novos projetos atendem as necessidades do negócio, se eles estão dentro do prazo e orçamento.

Mudanças e Manutenções: verifica se os novos sistemas estão funcionando corretamente quando implementados. Verifica se as mudanças podem ser realizadas sem interromper as operações de negócio.



Novos Projetos **Empresa**

Domínio de Entrega e Suporte

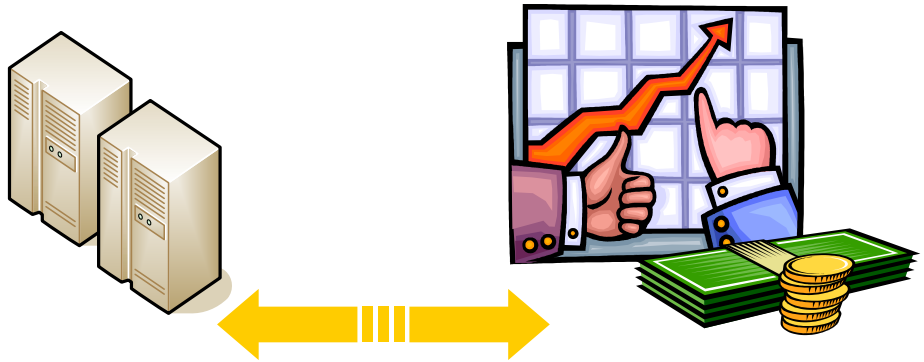
Objetivo

Esse domínio se preocupa com as entregas reais dos serviços requeridos que abrangem as operações tradicionais sobre aspectos de segurança e continuidade até treinamento. Para poder entregar os serviços será necessário criar processos de suporte. Este domínio também inclui o processamento de dados pelos sistemas de aplicações.

Escopo do Domínio

Entrega dos Serviços requisitados: verifica se os serviços de TI estão alinhados com as prioridades do negócio.

Configuração dos Processos de Suporte: verifica se os custos estão otimizados. Verifica se há confidencialidade, integridade e disponibilidade adequada. Verifica se as cargas de uso dos sistemas de TI são aceitáveis e seguras.



Serviços de TI **Prioridades do Negócio**

Domínio de Monitoração e Avaliação

Objetivo

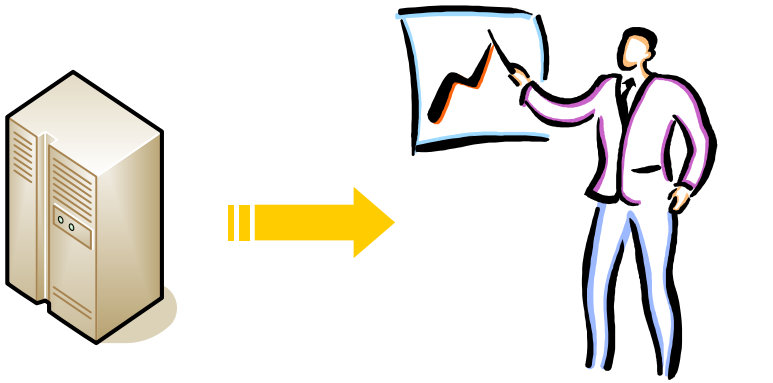
Este é o domínio que controla os processos de TI que devem ser avaliados regularmente nos aspectos de qualidade e conformidade.

Escopo do Domínio

Avaliação regular, entrega de garantias: A performance de TI pode ser medida e os problemas podem ser detectados antes de ser tarde demais?

Os controles internos são eficientes e eficazes?

Medição da Performance: A performance da TI pode ser relacionada com as metas do negócio? O risco, controle, conformidade e performance são medidos e reportados?

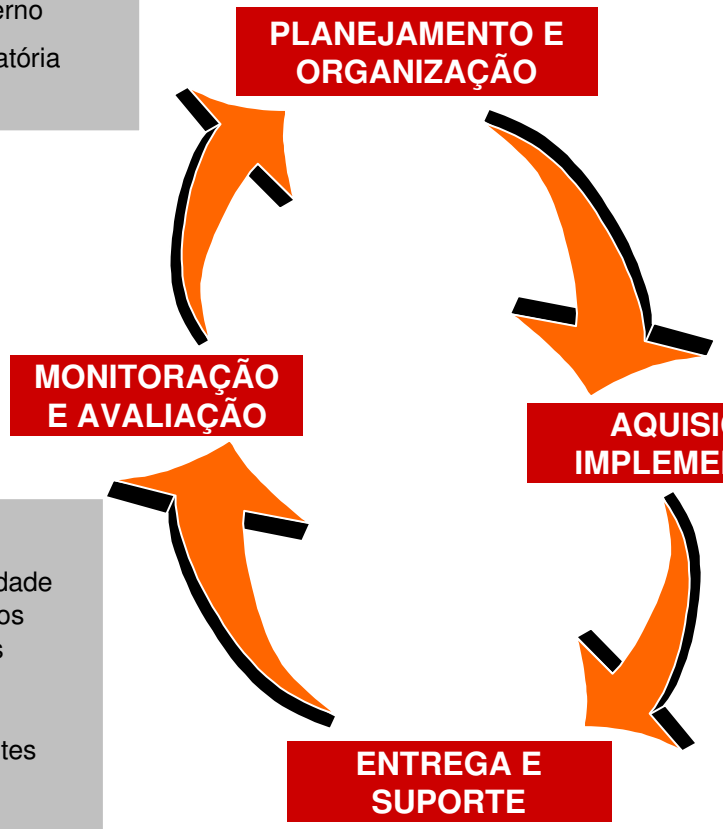


TI **Performance**

Modelo de Processo do COBIT

Vamos dar uma olhada no modelo de processo do COBIT, o qual contempla 34 processos de TI definidos em 4 domínios. Estes processos podem ser aplicados em vários níveis na organização. Por exemplo, alguns destes processos podem ser aplicados a nível corporativo, outros ao nível de função de TI, e outros a nível do responsável pelo processo de negócio.

ME1 Monitorar e Avaliar a Performance de TI
ME2 Monitorar e Avaliar Controle Interno
ME3 Assegurar Conformidade Regulatória
ME4 Fornecer Governança de TI



PO1 Definir um Plano Estratégico de TI
PO2 Definir a Arquitetura de Informação
PO3 Determinar a Direção Tecnológica
PO4 Definir Processos de TI, Organização e Relacionamento
PO5 Gerenciar o Investimento em TI
PO6 Comunicar Metas e Diretivas Gerenciais
PO7 Gerenciar Recursos Humanos
PO8 Gerenciar Qualidade
PO9 Avaliar e Gerenciar Riscos
PO10 Gerenciar Projetos

DS1 Definir níveis de Serviços
DS2 Gerenciar Serviços de Terceiros
DS3 Gerenciar Performance e Capacidade
DS4 Garantir Continuidade dos Serviços
DS5 Garantir Segurança dos Sistemas
DS6 Identificar e Alocar Custos
DS7 Educar e Treinar usuários
DS8 Gerenciar Service Desk e Incidentes
DS9 Gerenciar a Configuração
DS10 Gerenciar Problemas
DS11 Gerenciar Dados
DS12 Gerenciar os Ambientes Físicos
DS13 Gerenciar Operações

AI1 Identificar soluções
AI2 Adquirir e manter software aplicativo
AI3 Adquirir e manter arquitetura tecnológica
AI4 Desenvolver e manter procedimentos de TI
AI5 Obter Recursos de TI
AI6 Gerenciar mudanças
AI7 Instalar e certificar Soluções e Mudanças

Medidas de Controle

As medidas de controle para cada processo de TI não satisfaz todos os requisitos de negócio no mesmo grau. O Framework do COBIT define 3 graus de controle.

Primário	Impacta diretamente o critério de informação a que se refere.
Secundário	Satisfaz parcialmente ou indiretamente o critério de informação a que se refere.
Em Branco	Pode ser aplicável; entretanto, os requisitos são satisfeitos de forma mais apropriada por um outro critério neste processo e/ou ainda por outro processo.

Medidas de Controle

A tabela abaixo fornece uma indicação por processo de TI e domínio, informando qual critério de informação é impactado (**P** = Primário, **S** = Secundário) por um objetivo controle de alto nível e quais recursos de TI são aplicáveis.

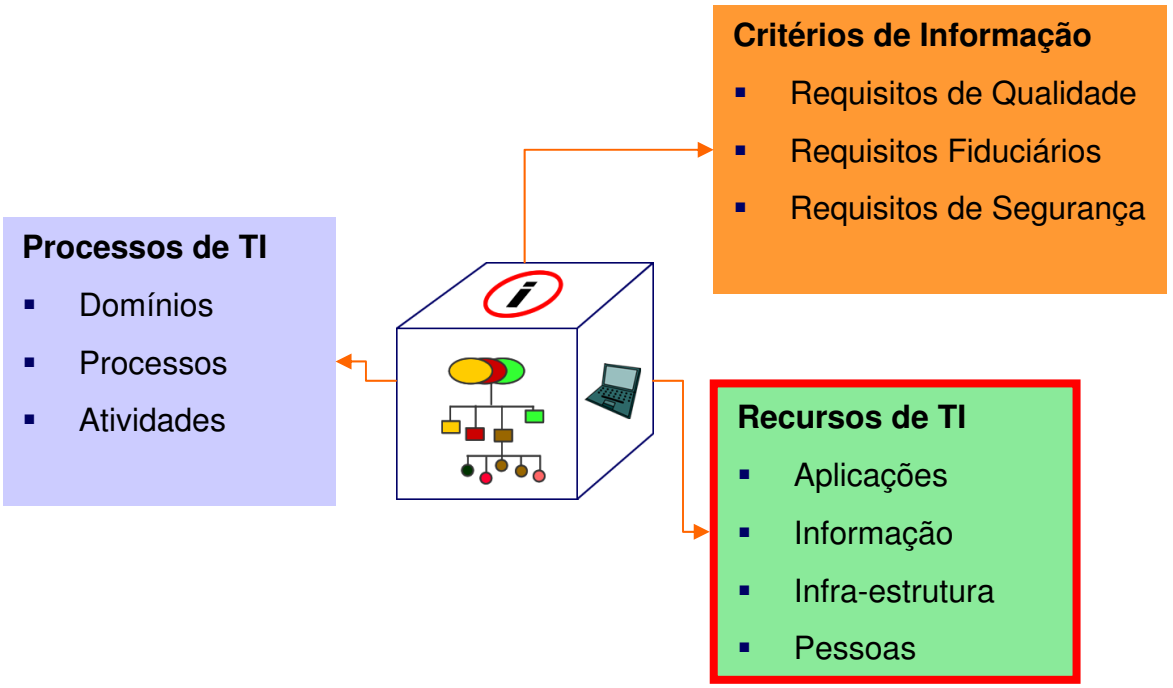
DOMÍNIO		PROCESSO	Critérios de Informação							Recursos de TI			
			Eficácia	Eficiência	Confidencialidade	Integridade	Disponibilidade	Conformidade	Confiabilidade	Aplicações	Informações	Infra-estrutura	Pessoas
Planejamento & Organização	PO1	Definir um Plano Estratégico de TI	P	S						✓	✓	✓	✓
	PO2	Definir a Arquitetura de Informação	P	S	S	S				✓	✓		
	PO3	Determinar a Direção Tecnológica	P	S						✓		✓	
	PO4	Definir Processos TI, Organ e Relacion.	P	S									✓
	PO5	Gerenciar o Investimento em TI	P	P					S	✓		✓	✓
	PO6	Comunicar Metas e Diretivas Gerenciais	P					S			✓		✓
	PO7	Gerenciar Recursos Humanos	P	P									✓
	PO8	Gerenciar Qualidade	P					P	S	✓	✓	✓	✓
	PO9	Avaliar e Gerenciar Riscos	P	S	P	P	P	S	S	✓	✓	✓	✓
	PO10	Gerenciar Projetos	P	P						✓		✓	✓
Aquisição & Implementação	AI1	Identificar soluções	P	S						✓		✓	
	AI2	Adquirir e Manter software aplicativo	P	P		S		S	S	✓			
	AI3	Adquirir e Manter arquitetura tecnológica	P	P		S						✓	
	AI4	Desenvolver e Manter Proced.de TI	P	P		S		S	S	✓		✓	✓
	AI5	Obter Recursos de TI	P			S	S			✓	✓	✓	✓
	AI6	Gerenciar mudanças	P	P		P	P		S	✓	✓	✓	✓
	AI7	Instalar e certificar Soluções e Mudanças	P	P		S	S			✓	✓	✓	✓

Medidas de Controle (continuação)

DOMÍNIO		PROCESSO	Critérios de Informação							Recursos de TI			
			Eficácia	Eficiência	Confidencialidade	Integridade	Disponibilidade	Conformidade	Confiabilidade	Aplicações	Informações	Infra-estrutura	Pessoas
Entrega & Suporte	DS1	Definir níveis de Serviços	P	P	S	S	S	S	S	✓	✓	✓	✓
	DS2	Gerenciar Serviços de Terceiros	P	P	S	S	S	S	S	✓	✓	✓	✓
	DS3	Gerenciar Performance e Capacidade	P	P			S				✓		✓
	DS4	Garantir Continuidade dos Serviços	P	S			P			✓	✓	✓	✓
	DS5	Garantir Segurança dos Sistemas			P	P	S	S	S	✓	✓	✓	✓
	DS6	Identificar e Alocar Custos		P					P	✓	✓	✓	✓
	DS7	Educar e Treinar usuários	P	S									✓
	DS8	Gerenciar Service Desk e Incidentes	P	P						✓			✓
	DS9	Gerenciar a Configuração	P				S		S	✓	✓	✓	
	DS10	Gerenciar Problemas	P	P			S			✓	✓	✓	✓
	DS11	Gerenciar Dados				P			P		✓		
	DS12	Gerenciar os Ambientes Físicos				P	P					✓	
	DS13	Gerenciar Operações	P	P		S	S			✓	✓	✓	✓
Monitoração & Avaliação	M1	Monitorar e Avaliar a Performance de TI	P	P	S	S	S	S	S	✓	✓	✓	✓
	M2	Monitorar e Avaliar Controle Interno	P	P	S	S	S	P	S	✓	✓	✓	✓
	M3	Assegurar Conformidade Regulatória	P	P	S	S	S	P	S	✓	✓	✓	✓
	M4	Fornecer Governança de TI	P	P	S	S	S	P	S	✓	✓	✓	✓

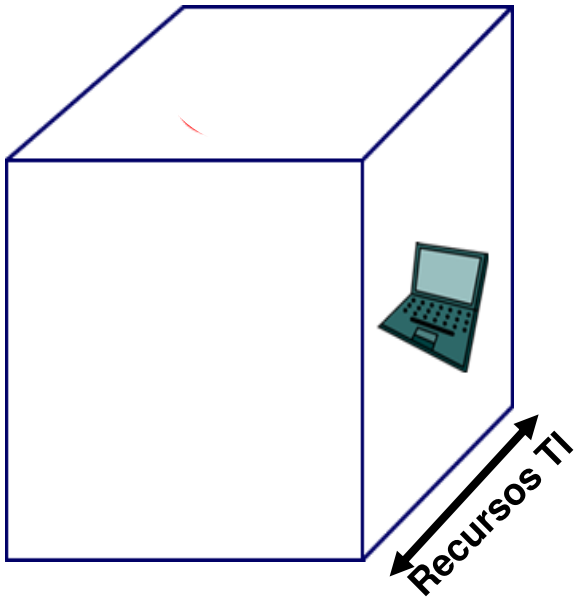
Recursos de TI

Vamos agora aprender sobre o segundo componente do framework do COBIT, Recursos de TI.



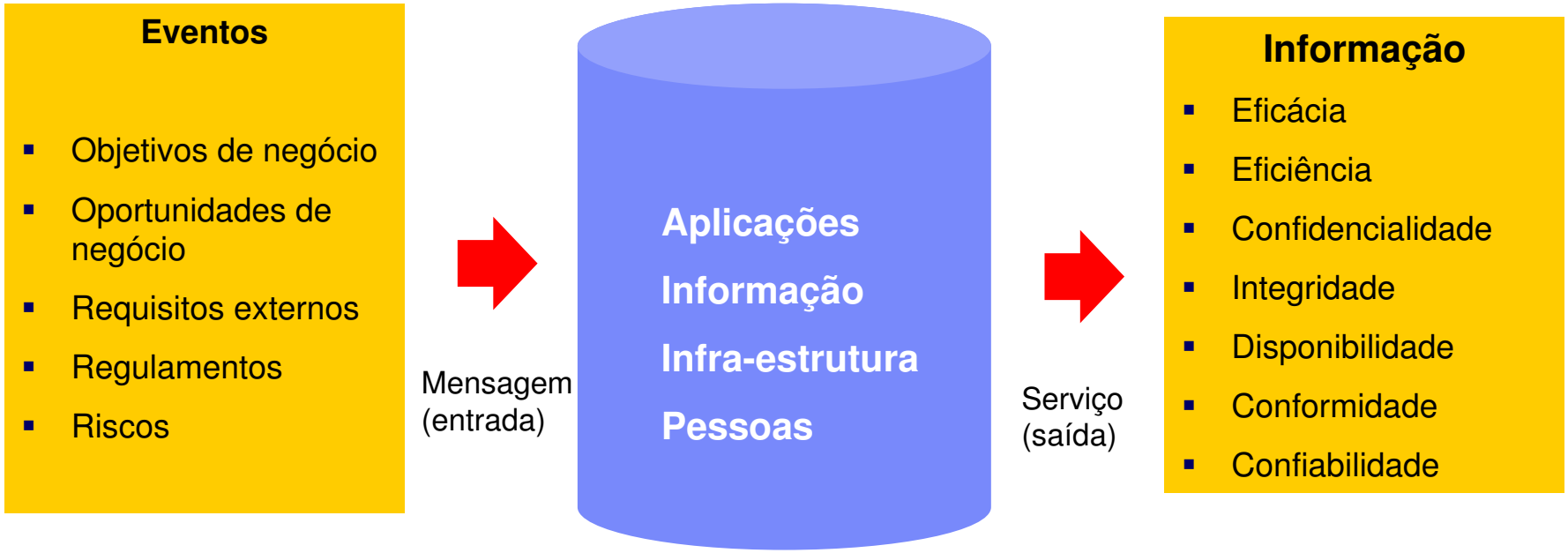
Recursos de TI

- **Aplicações**: sistemas automatizados e procedimentos manuais para processar informações
- **Informação**: os dados de todos os formulários de entrada, processados e exibidos pelos sistemas de informação, podendo ser qualquer formulário que é usado pelo negócio.
- **Infra-estrutura**: inclui hardware, sistemas operacionais, sistemas de banco de dados, rede, multimídia, etc. É tudo que é necessário para o funcionamento das aplicações.
- **Pessoas**: pessoal necessário para planejar, organizar, adquirir, implementar, entregar, prestar suporte, monitorar e avaliar os sistemas de informação e serviços. Eles podem ser internos ou terceirizados.



Recursos de TI x Entrega de serviços

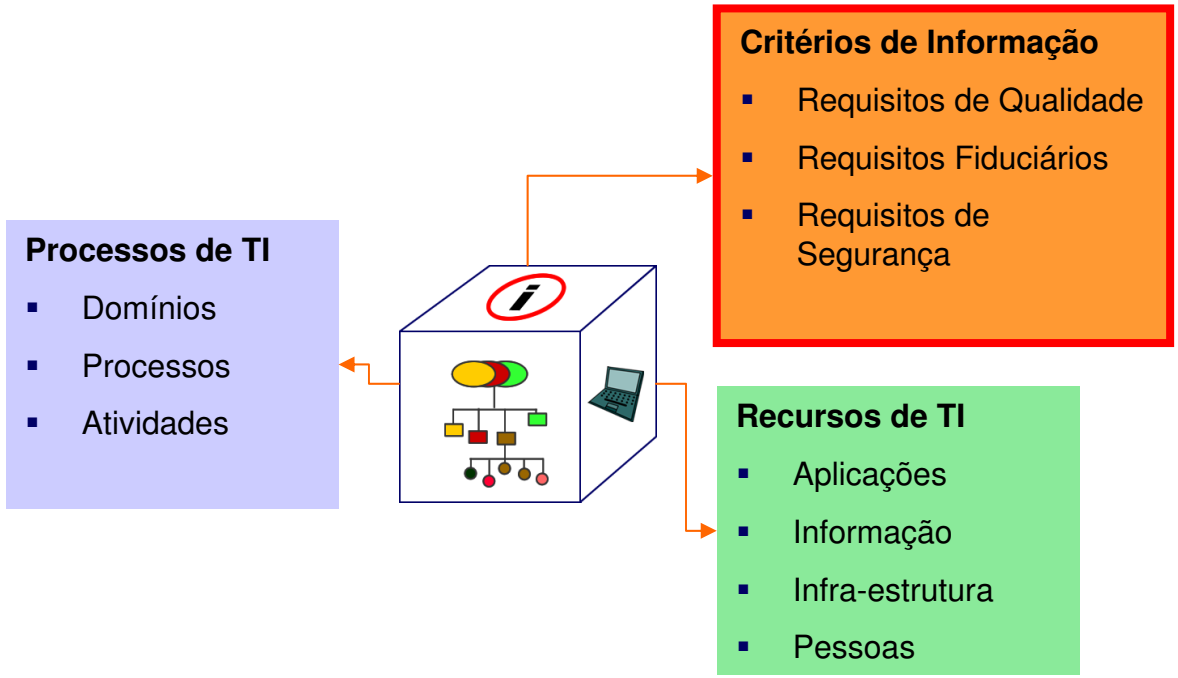
Vamos analisar uma outra forma de interpretação o relacionamento dos recursos de TI com a entrega de serviços.



Para assegurar que os requisitos de negócio em relação a informação sejam alcançados, medidas de controle adequadas precisam ser definidas, implementadas e monitoradas para estes recursos. Apenas um framework de Controle de Objetivos de TI poderia assegurar que as organizações recebam informações que satisfaçam seus objetivos.

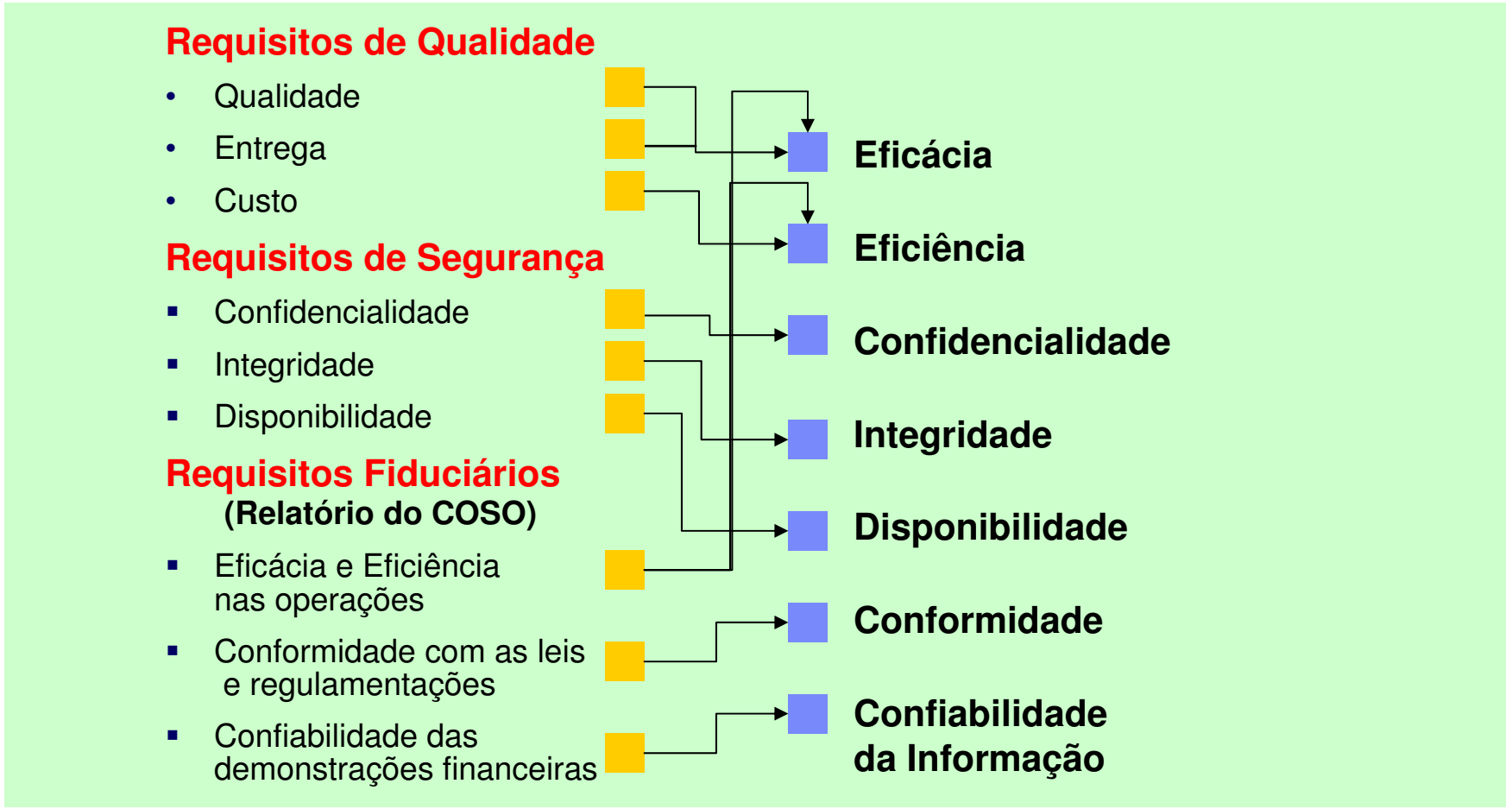
Critérios de Informação

Vamos agora aprender sobre o próximo componente do framework do COBIT, Critérios de Informação.



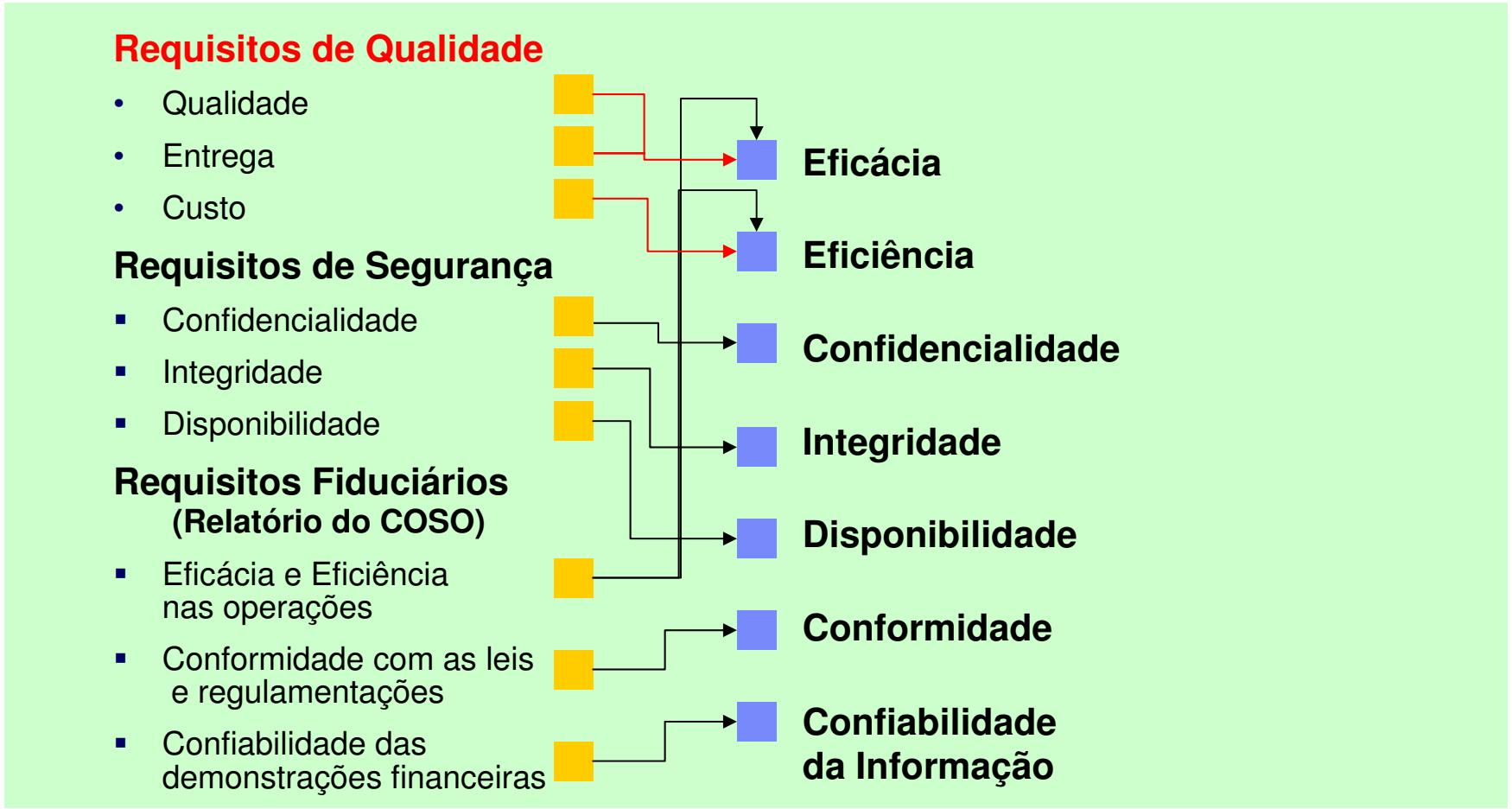
Critérios de Informação

Para satisfazer os objetivos de negócio, a informações precisam estar em conformidade com um critério específico. No COBIT estes critérios são chamados de requisitos de negócio para informação. Para estabelecer a lista de requisitos, o COBIT combina os princípios embutidos nos modelos de referências existentes e conhecidos. Estes 3 requisitos são: Requisitos de Qualidade, Requisitos de Segurança e Requisitos de Fiduciários.



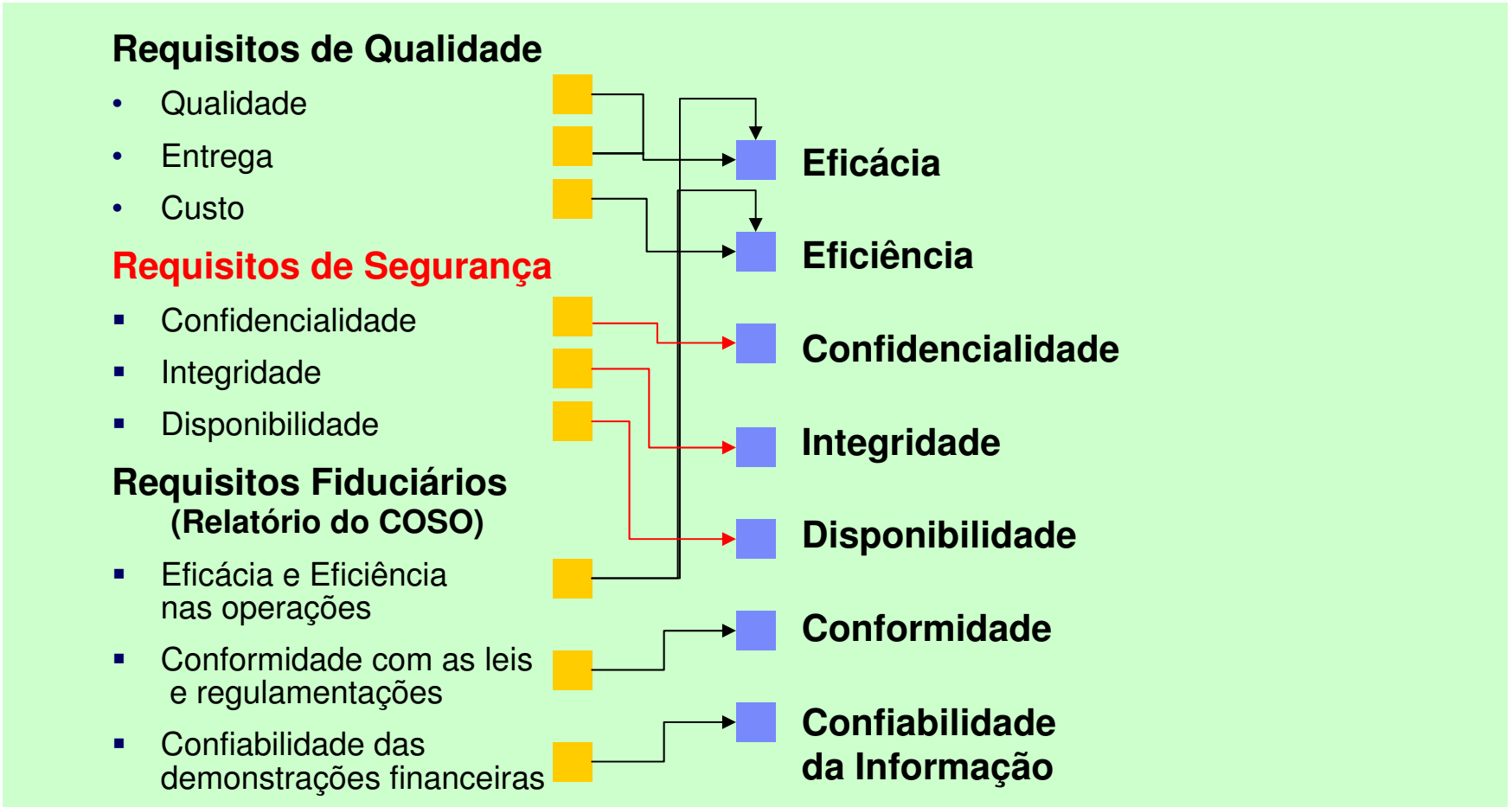
Requisitos de Qualidade

Os requisitos de Qualidade asseguram que o sistema está preparado para o seu propósito e que o processo irá ocorrer com o mínimo de erros possível. Os requisitos de qualidade incluem: qualidade, entrega e custo.



Requisitos de Segurança

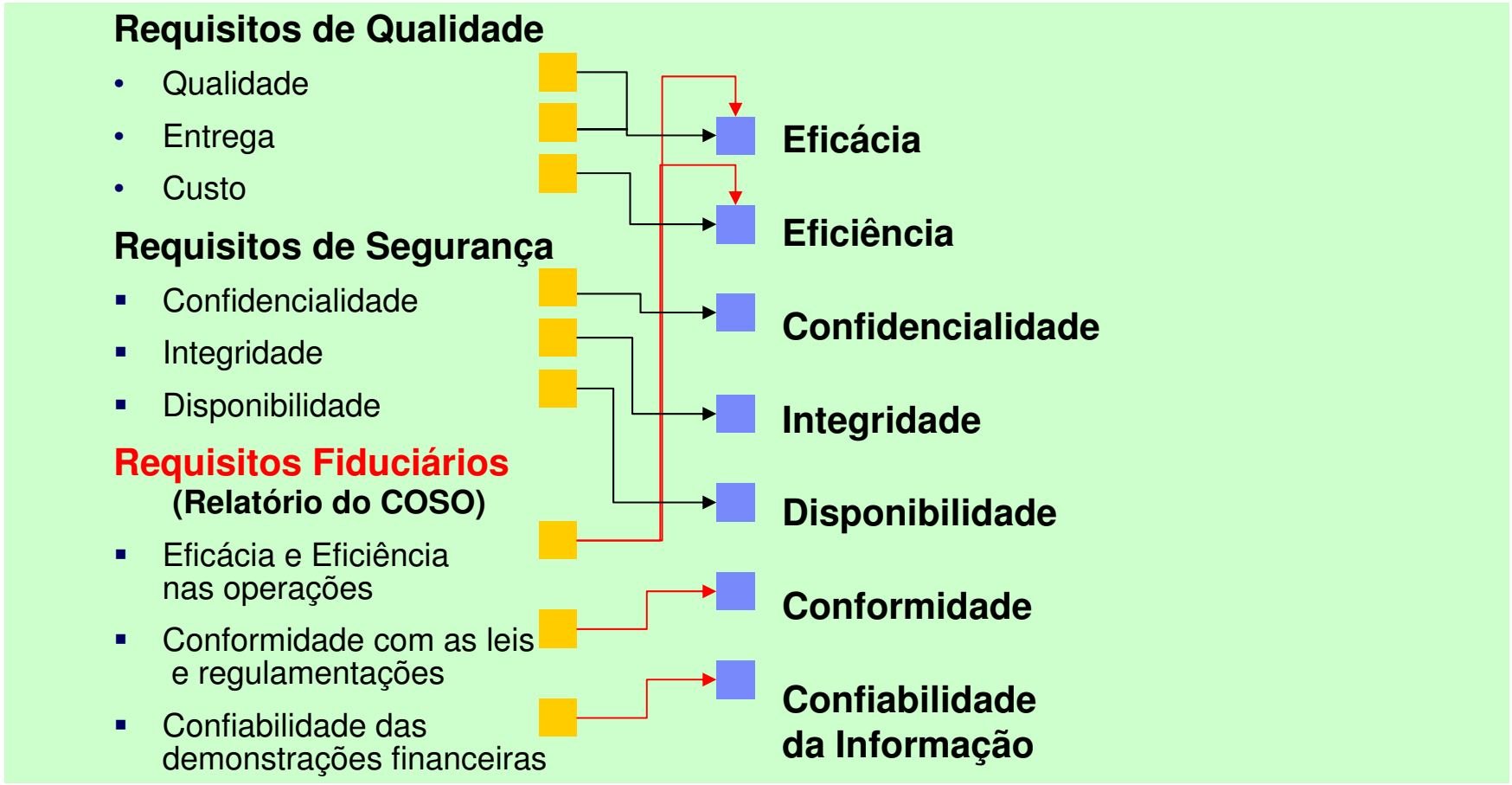
Os requisitos de Segurança incluem: confidencialidade, integridade e disponibilidade.



Requisitos Fiduciários

Os requisitos Fiduciários são focados em satisfazer os requisitos corporativos, do setor público, legal e regulatórios.

Os requisitos Fiduciários incluem eficiência e eficácia das operações, conformidades com leis e regulamentos, confiabilidade dos relatórios financeiros. Para satisfazer os requisitos regulatórios o COBIT se baseia nas definições do COSO. Entretanto, o COBIT expandiu o escopo para incluir todas informações, não somente informações financeiras.



Categorias

Os 3 requisitos – Qualidade, Segurança e Fiduciário – são divididos em 7 categorias distintas que podem se sobrepor.

Eficácia: É a capacidade de alçar metas e resultados propostos. Trata da informação que está sendo relevante e pertinente ao processo de negócio, bem como que esteja sendo entregue de um modo oportuno, correto, consistente e útil.

Eficiência: Capacidade de Produzir o máximo nos resultados com o mínimo de recursos. Diz respeito à provisão da informação através do uso otimizado (mais produtivo e econômico) dos recursos. Tem foco na otimização de custos.

Confiabilidade: Relaciona-se à provisão de informação apropriada para a gerência operar a entidade e para a gerência exercer suas responsabilidades de relatar aspectos de conformidade e finanças .

Conformidade: Trata do cumprimento das leis, dos regulamentos e arranjos contratuais aos quais o processo de negócio está sujeito.

Confidencialidade: Diz respeito à proteção da informação sigilosa contra a revelação não autorizada

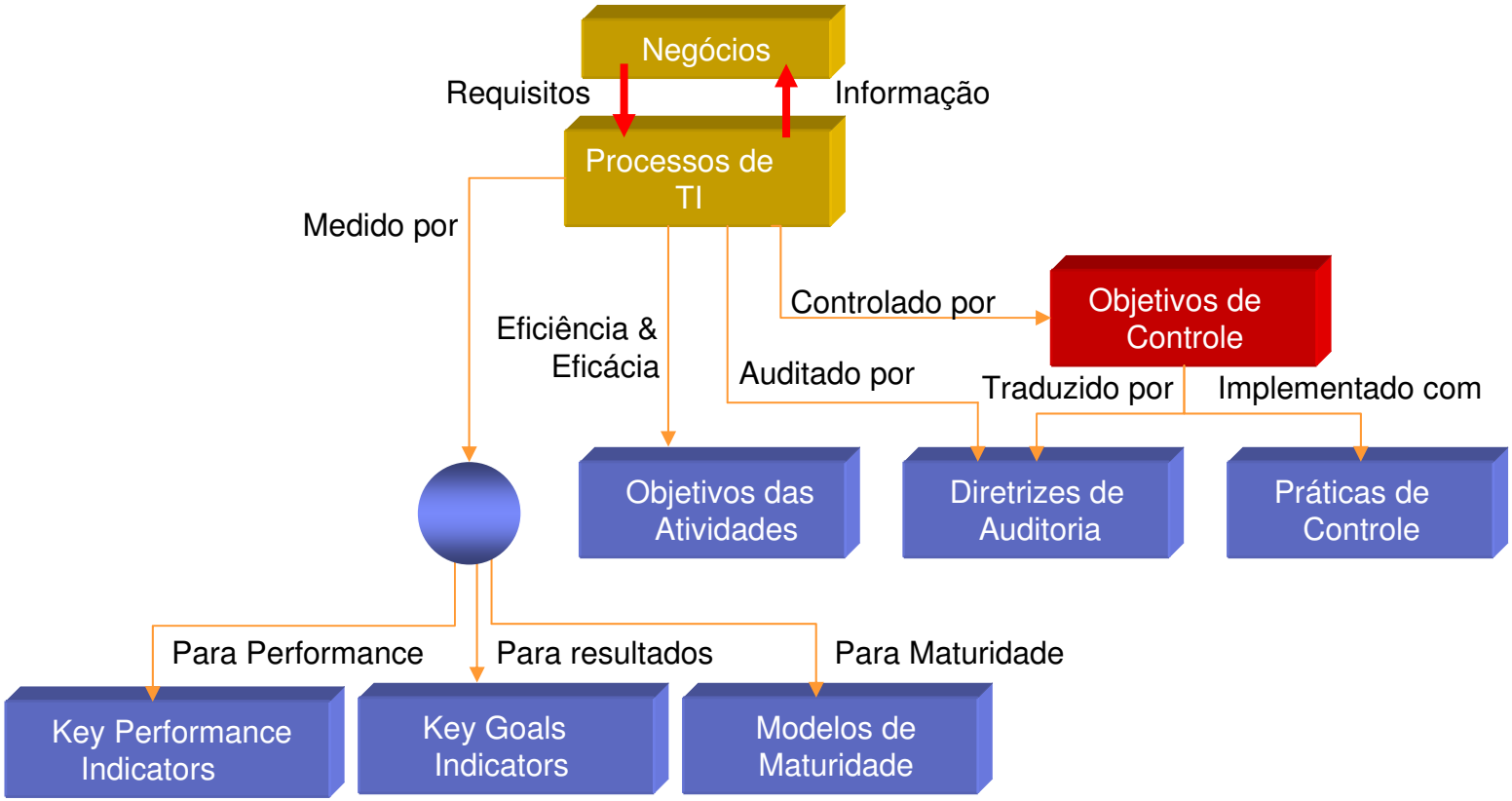
Integridade: Relaciona-se à exatidão e à inteireza da informação bem como à sua validez de acordo com os valores e expectativas do negócio

Disponibilidade: Relaciona-se à informação que está sendo disponibilizada quando requerida pelo processo de negócio agora e no futuro. Também diz respeito à salvaguarda dos recursos necessários e às capacidades associadas. Tem foco na Entrega de serviços

Objetivos de Controle

Objetivos de Controle

Entendido o framework do COBIT, vamos estudar os conceitos dos objetivos de controle.



Definições

Definição de Controle

Controle envolve as políticas, procedimentos, práticas e estruturas organizacionais projetadas para fornecer segurança para que os objetivos do negócio sejam alcançados e eventos não desejados sejam prevenidos ou detectados e corrigidos.

Definição de Objetivos de Controle

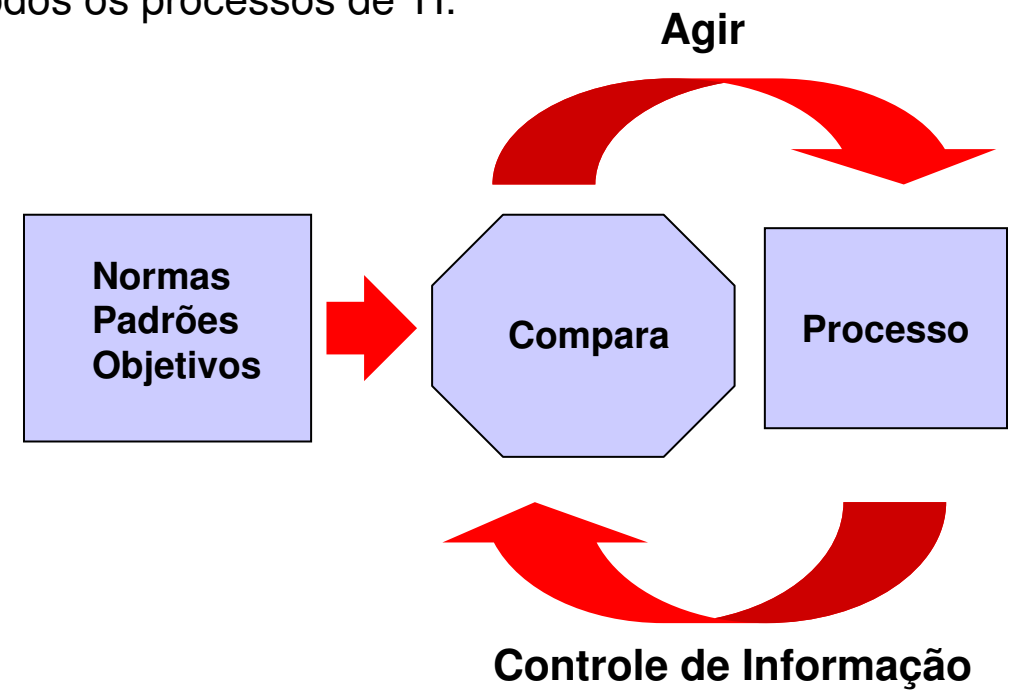
Definição de determinados objetivos ou resultados a serem obtidos ao implementar procedimentos de controle em uma determinada atividade de TI



Os processos precisam de controle

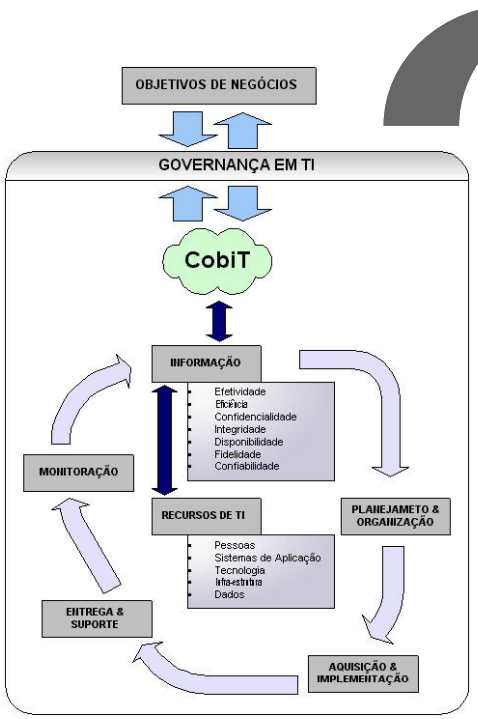
Cada processo de TI precisa ser controlado para que ele possa atingir seus objetivos. O gerenciamento operacional usa os processos para organizar as atividades de TI. O COBIT fornece um modelo genérico de processo que representa todos os processos normalmente encontrados dentro das funções de TI. Para conseguir uma governança efetiva, é necessário ser implementado controles pelos gerentes de operações dentro de um framework de controle definido para todos os processos de TI.

Como exemplo temos o modelo de controle ao lado, podemos fazer uma analogia com o controle de temperatura de uma sala, quando a temperatura ideal é atingida (padrão) o ar condicionado é desligado e constantemente o sistema (processo) deve comparar a temperatura do ambiente (controle de informação) e acionar (agir) novamente ser esta se alterar.



Conceitos de Objetivos de Controle

Cada processo de TI tem um objetivo de controle de alto nível definido, o qual contem vários objetivos de controle.



Consiste em 4 domínios

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

PO2 Definir a Arquitetura de Informação

PO3 Determinar a Direção Tecnológica

PO4 Definir Processos de TI, Organização e Relacionamento

PO5 Gerenciar o Investimento em TI

PO6 Comunicar Metas e Diretivas Gerenciais

PO7 Gerenciar Recursos Humanos

PO8 Gerenciar Qualidade

PO9 Avaliar e Gerenciar Riscos

PO10 Gerenciar Projetos

Objetivo de Controle de Alto Nível

Objetivos de Controle Detalhados

Tipos de Objetivos de Controle

Nós vimos como o framework do COBIT define os 34 processos de TI em 4 domínios. Cada processo de TI tem um objetivo de controle de alto nível, o qual pode conter vários objetivos de controle. Existem 2 tipos de objetivos de controle: objetivo de controle de alto nível e objetivos de controle detalhados.



Objetivo de Controle de Alto Nível

Um objetivo de controle de alto nível é uma declaração de um resultado desejado a ser alcançado através da implementação de procedimentos de controle dentro de uma atividade de TI específica.



Objetivos de Controle detalhados

Objetivos de controle detalhados se baseiam em objetivos de controle de alto nível, focando no controle de tarefas chaves e atividades que estão relacionadas com os processos de TI.

Objetivos de Controle

- **Objetivos de controle de alto-nível**
  - →1 por processo
- **Objetivos de controle detalhado**
  - →3 a 15 por processo
- **Práticas de Controle**
  - →5 a 10 por objetivo de controle

4 Domínios - 34 Processos - 214 Objetivos de Controle

Planejamento e Organização

Objetivos de controle alto-nível:

PO1 Definir um Plano Estratégico de TI

PO2 Definir a Arquitetura de Informação

PO3 Determinar a Direção Tecnológica

PO4 Definir Processos de TI, Organização e Relacionamento

PO5 Gerenciar o Investimento em TI

PO6 Comunicar Metas e Diretivas Gerenciais

PO7 Gerenciar Recursos Humanos

PO8 Gerenciar Qualidade

PO9 Avaliar e Gerenciar Riscos

PO10 Gerenciar Projetos

Aquisição e Implementação

Objetivos de controle de alto-nível:

AI1 Identificar soluções

AI2 Adquirir e manter software aplicativo

AI3 Adquirir e manter arquitetura tecnológica

AI4 Desenvolver e manter procedimentos de TI

AI5 Obter Recursos de TI

AI6 Gerenciar mudanças

AI7 Instalar e certificar Soluções e Mudanças

Entrega e Suporte

Objetivos de controle de alto-nível:

DS1 Definir níveis de Serviços

DS2 Gerenciar Serviços de Terceiros

DS3 Gerenciar Performance e Capacidade

DS4 Garantir Continuidade dos Serviços

DS5 Garantir Segurança dos Sistemas

DS6 Identificar e Alocar Custos

DS7 Educar e Treinar usuários

DS8 Gerenciar Service Desk e Incidentes

DS9 Gerenciar a Configuração

DS10 Gerenciar Problemas

DS11 Gerenciar Dados

DS12 Gerenciar os Ambientes Físicos

DS13 Gerenciar Operações

Monitoração e Avaliação

Objetivos de controle de alto-nível:

ME1 Monitorar e Avaliar a Performance de TI

ME2 Monitorar e Avaliar Controle Interno

ME3 Assegurar Conformidade Regulatória

ME4 Fornecer Governança de TI

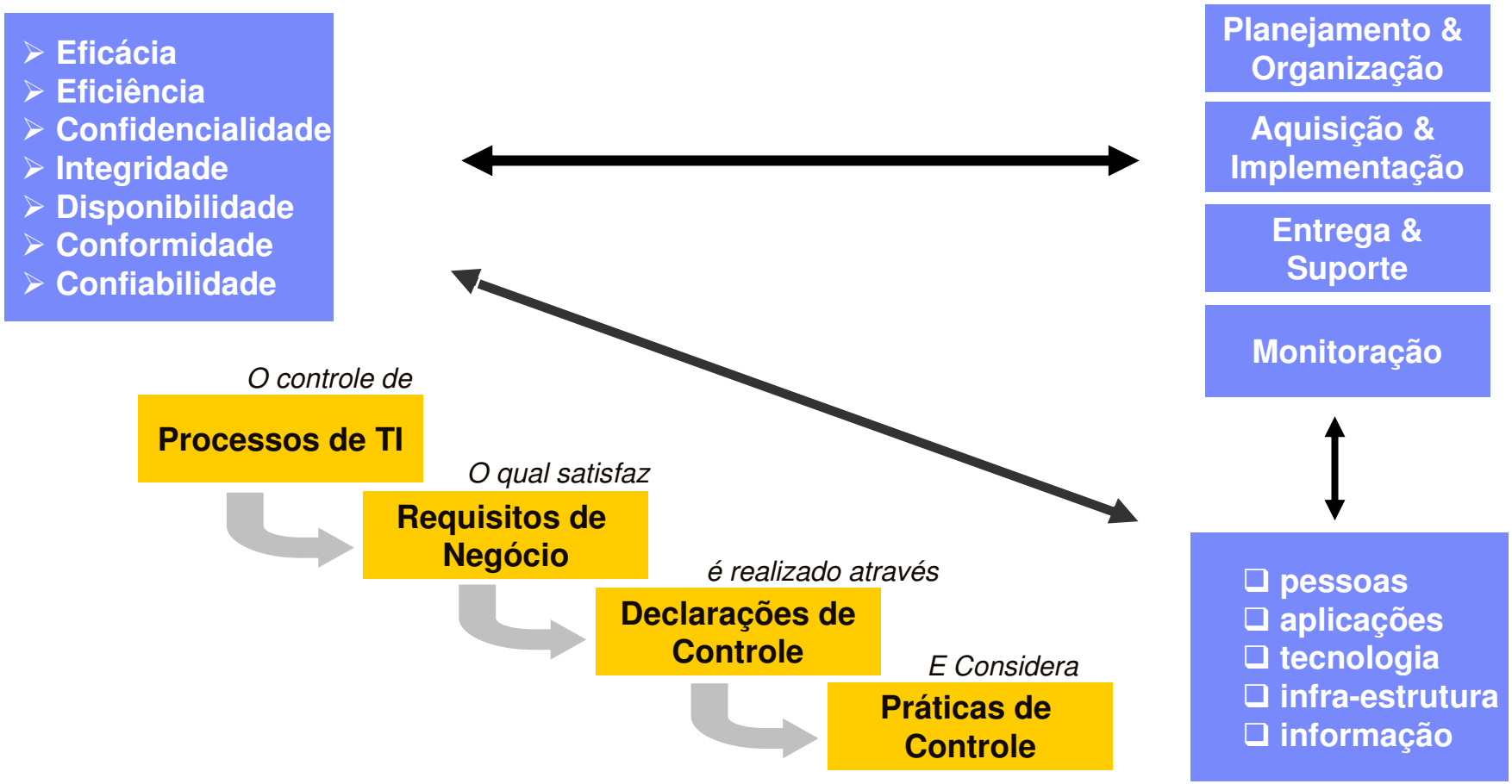
Práticas de Controle

Traduz os objetivos de controle do COBIT em práticas detalhadas, implementáveis e fornece uma argumentação de negócio para a implementação, a partir de uma perspectiva de valor e risco.

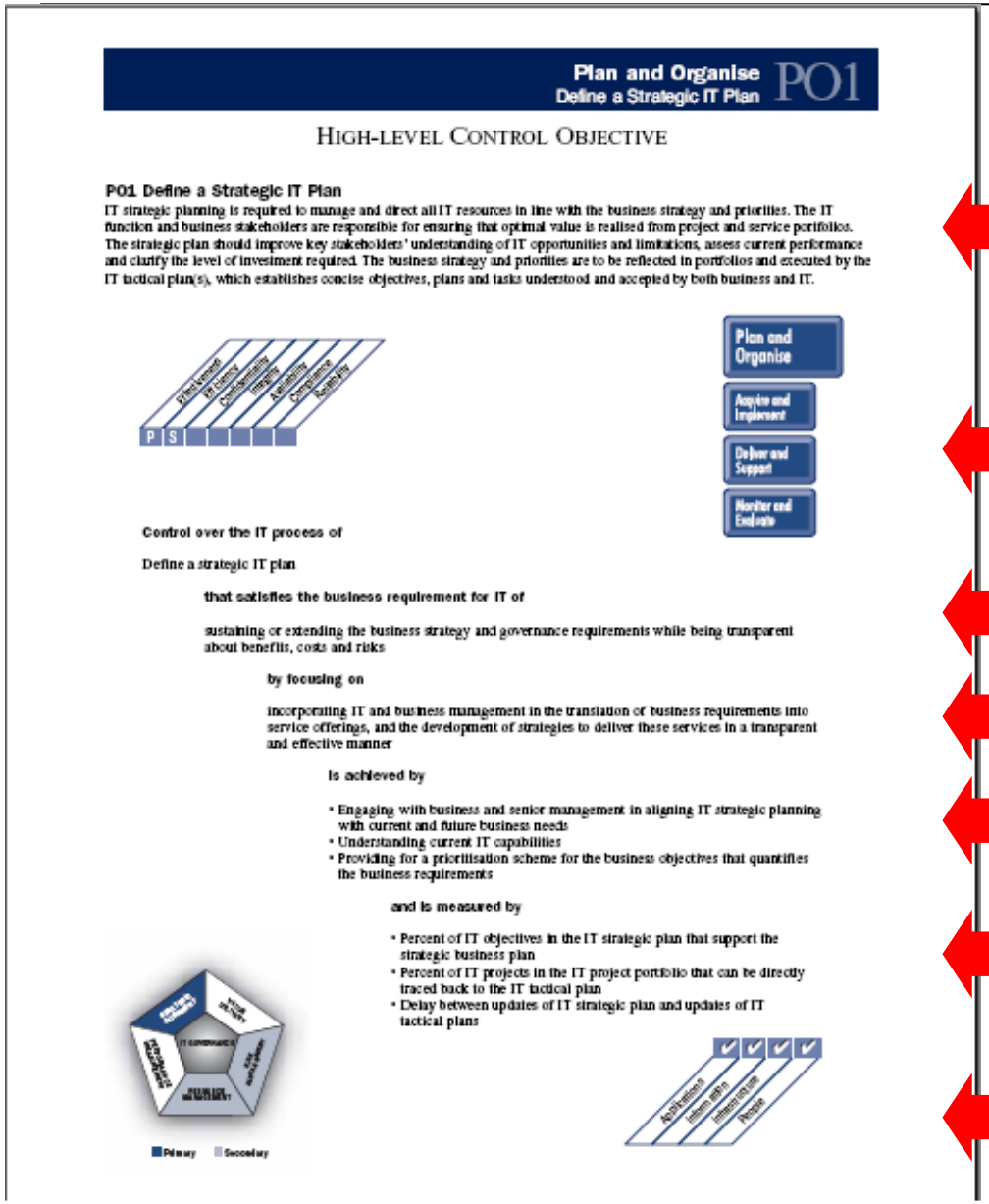
- **Práticas de controle são mecanismos chaves que suportam:**
  - A realização dos objetivos de controle
  - Prevenção, detecção e correção de eventos não desejados
- **Práticas de controle são alcançadas através de:**
  - Uso responsável dos recursos
  - Gerenciamento de riscos apropriado
  - Alinhamento da TI com o negócio

Framework do COBIT – vínculos

A representação abaixo mostra os vínculos entre os Critérios de Informação, Processos e Recursos



Exemplo do COBIT® 4.0 - DS5 (página 1)



Plan and Organise
Define a Strategic IT Plan PO1

HIGH-LEVEL CONTROL OBJECTIVE

PO1 Define a Strategic IT Plan

IT strategic planning is required to manage and direct all IT resources in line with the business strategy and priorities. The IT function and business stakeholders are responsible for ensuring that optimal value is realised from project and service portfolios. The strategic plan should improve key stakeholders' understanding of IT opportunities and limitations, assess current performance and clarify the level of investment required. The business strategy and priorities are to be reflected in portfolios and executed by the IT tactical plan(s), which establishes concise objectives, plans and tasks understood and accepted by both business and IT.

Plan and Organise
Acquire and Implement
Deliver and Support
Monitor and Evaluate

Control over the IT process of

Define a strategic IT plan

that satisfies the business requirement for IT of

sustaining or extending the business strategy and governance requirements while being transparent about benefits, costs and risks

by focusing on

incorporating IT and business management in the translation of business requirements into service offerings, and the development of strategies to deliver these services in a transparent and effective manner

is achieved by

- Engaging with business and senior management in aligning IT strategic planning with current and future business needs
- Understanding current IT capabilities
- Providing for a prioritisation scheme for the business objectives that quantifies the business requirements

and is measured by

- Percent of IT objectives in the IT strategic plan that support the strategic business plan
- Percent of IT projects in the IT project portfolio that can be directly traced back to the IT tactical plan
- Delay between updates of IT strategic plan and updates of IT tactical plans

Primary Secondary

Applications
Infrastructure
Information
People

Descrição do Processo

Domínios de TI & Indicadores de Informação

Metas de TI

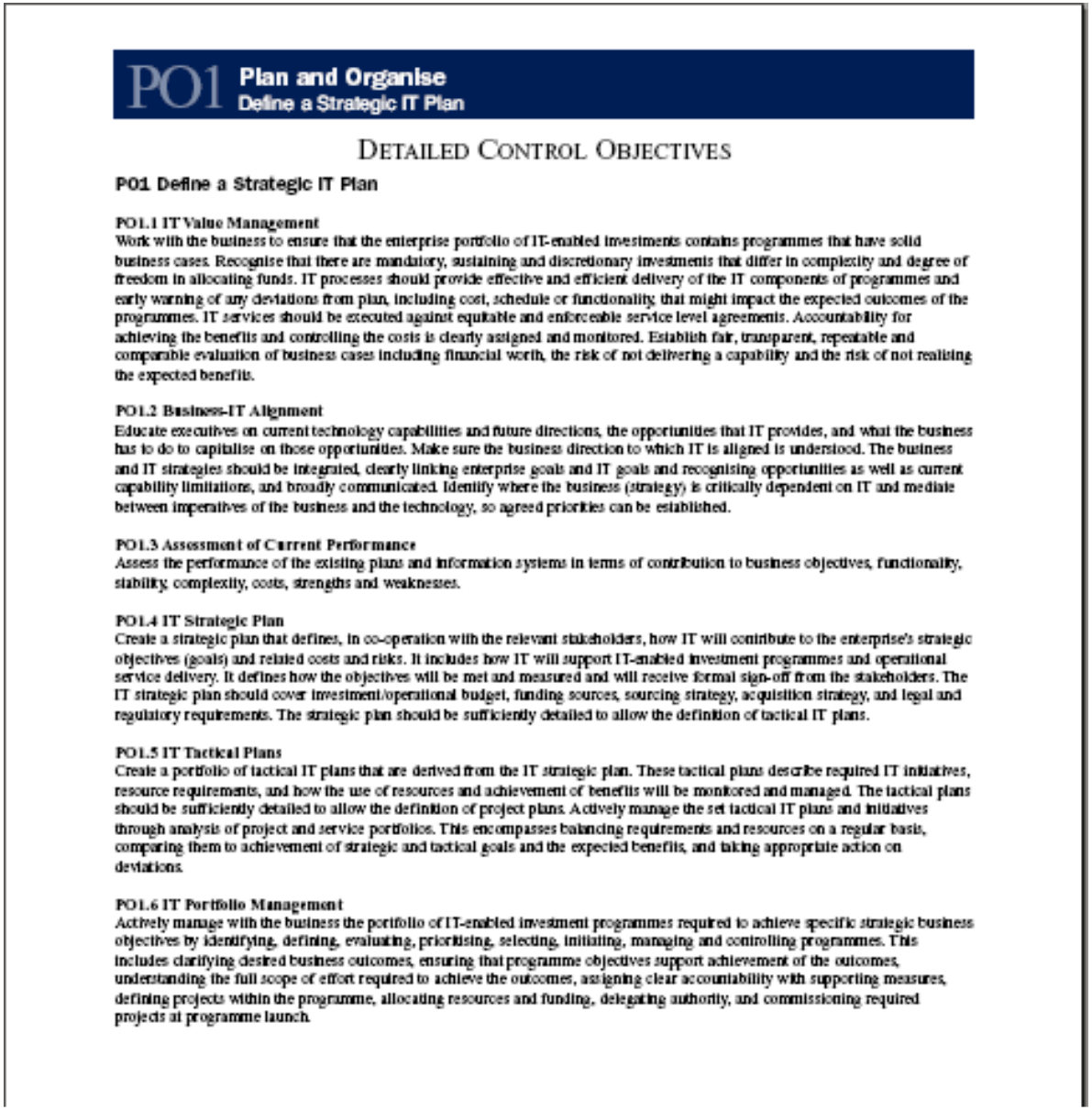
Metas do Processo

Práticas Chaves

Métricas Chaves

Indicadores de Recursos de TI

Exemplo do COBIT® 4.0 - DS5 (página 2)



PO1 Plan and Organise
Define a Strategic IT Plan

DETAILED CONTROL OBJECTIVES

PO1 Define a Strategic IT Plan

PO1.1 IT Value Management
Work with the business to ensure that the enterprise portfolio of IT-enabled investments contains programmes that have solid business cases. Recognise that there are mandatory, sustaining and discretionary investments that differ in complexity and degree of freedom in allocating funds. IT processes should provide effective and efficient delivery of the IT components of programmes and early warning of any deviations from plan, including cost, schedule or functionality, that might impact the expected outcomes of the programmes. IT services should be executed against equitable and enforceable service level agreements. Accountability for achieving the benefits and controlling the costs is clearly assigned and monitored. Establish fair, transparent, repeatable and comparable evaluation of business cases including financial worth, the risk of not delivering a capability and the risk of not realising the expected benefits.

PO1.2 Business-IT Alignment
Educate executives on current technology capabilities and future directions, the opportunities that IT provides, and what the business has to do to capitalise on those opportunities. Make sure the business direction to which IT is aligned is understood. The business and IT strategies should be integrated, clearly linking enterprise goals and IT goals and recognising opportunities as well as current capability limitations, and broadly communicated. Identify where the business (strategy) is critically dependent on IT and mediate between imperatives of the business and the technology, so agreed priorities can be established.

PO1.3 Assessment of Current Performance
Assess the performance of the existing plans and information systems in terms of contribution to business objectives, functionality, stability, complexity, costs, strengths and weaknesses.

PO1.4 IT Strategic Plan
Create a strategic plan that defines, in co-operation with the relevant stakeholders, how IT will contribute to the enterprise's strategic objectives (goals) and related costs and risks. It includes how IT will support IT-enabled investment programmes and operational service delivery. It defines how the objectives will be met and measured and will receive formal sign-off from the stakeholders. The IT strategic plan should cover investment/operational budget, funding sources, sourcing strategy, acquisition strategy, and legal and regulatory requirements. The strategic plan should be sufficiently detailed to allow the definition of tactical IT plans.

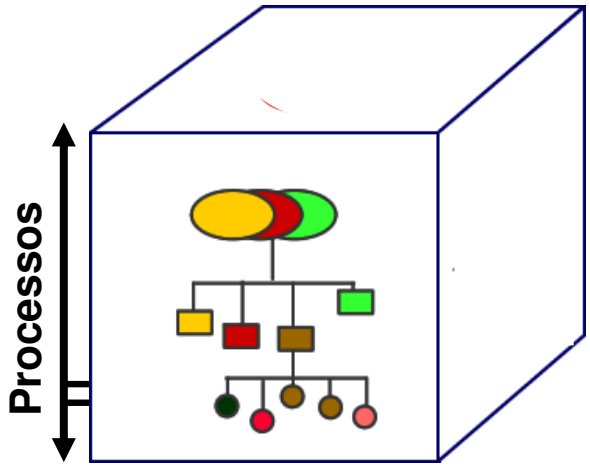
PO1.5 IT Tactical Plans
Create a portfolio of tactical IT plans that are derived from the IT strategic plan. These tactical plans describe required IT initiatives, resource requirements, and how the use of resources and achievement of benefits will be monitored and managed. The tactical plans should be sufficiently detailed to allow the definition of project plans. Actively manage the set tactical IT plans and initiatives through analysis of project and service portfolios. This encompasses balancing requirements and resources on a regular basis, comparing them to achievement of strategic and tactical goals and the expected benefits, and taking appropriate action on deviations.

PO1.6 IT Portfolio Management
Actively manage with the business the portfolio of IT-enabled investment programmes required to achieve specific strategic business objectives by identifying, defining, evaluating, prioritising, selecting, initiating, managing and controlling programmes. This includes clarifying desired business outcomes, ensuring that programme objectives support achievement of the outcomes, understanding the full scope of effort required to achieve the outcomes, assigning clear accountability with supporting measures, defining projects within the programme, allocating resources and funding, delegating authority, and commissioning required projects at programme launch.

Objetivos de Controle Detalhado

Objetivos de Controle relacionados com cada Domínio

Vamos considerar alguns exemplos de processos chaves que precisam ser controlados em cada um dos 4 domínios. Elencamos 1 processo de exemplo em cada domínio, isto nos ajuda a entender como está estruturado o Framework do COBIT. Veja abaixo os objetivos de controle que iremos apresentar como exemplo:



Domínios de TI	Objetivos de Controle
Planejamento e Organização	PO10 Gerenciar Projetos
Aquisição e Implementação	AI4 Desenv. e Manter Procedimentos
Entrega e Suporte	DS2 Gerenciar Serviços de Terceiros
Monitoração e Avaliação	ME1 – Monitorar e Avaliar a Performance de TI

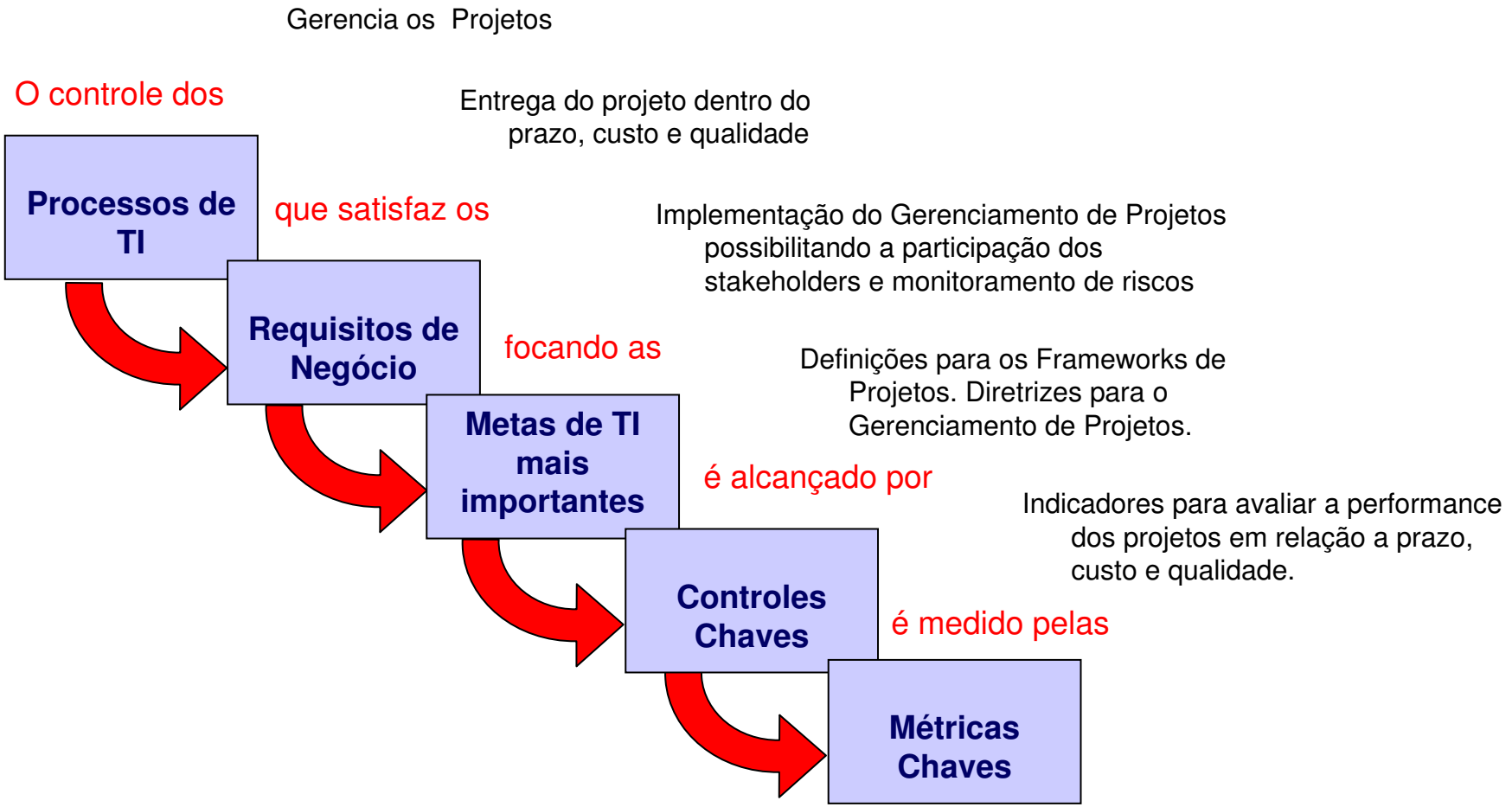
Vamos ver adiante estes objetivos de controle em detalhes em cada domínio.

Vale lembrar que a Prova do COBIT Foundation vai ter questões do processo PO10 e DS2.

Planejamento e Organização

PO10 Gerenciar Projetos

Foca no controle sobre o processo de Gerenciamento de Projetos para que satisfaça os requisitos de negócio para TI, na entrega de projetos para que resulte no cumprimento de prazo, orçamento e qualidade.



Planejamento e Organização

PO10 Gerenciar Projetos

Vamos ver agora objetivos de controle detalhados para o gerenciamento de projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Mantem o programa de projetos relacionado ao portfólio de programas de investimentos de TI através de identificação, definição, avaliação, priorização e controle dos projetos. Assegura que os projetos estão atendendo os objetivos do programa.

Coordena as atividades dos múltiplos projetos, gerencia a contribuição de todos os projetos dentro programa para o resultado esperado, resolve necessidades de recursos e conflitos.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Estabelece e mantem um framework de gerenciamento de projetos que defina o escopo e fronteiras do gerenciamento de projetos, bem como metodologias a serem adotadas e aplicadas em cada projeto.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Estabelece um gerenciamento de projetos apropriado ao tamanho, complexidade, requisitos regulatórios para cada projeto. A estrutura de governança de projetos pode incluir funções, responsabilidades, prestação de contas ao patrocinador, patrocinadores do projetos, comitê de avaliação, escritório de projetos e gerente projetos, e os mecanismos para que estes possam executar suas responsabilidades, tais como relatórios e estágios de revisão.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Obter comprometimento e participação dos stakeholders afetados na definição e execução do projeto dentro do contexto do programa de investimentos de TI.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Define e documenta a natureza e escopo do projeto para confirmar e desenvolver entre os stakeholders um entendimento comum do escopo do projeto e como ele se relaciona com outros projetos dentro do programa de investimentos de TI.

Planejamento e Organização

PO10 Gerenciar Projetos

- Framework de Gerenciamento de Programas
- Framework de Gerenciamento de Projetos
- Implementação Gerenciamento de Projetos
- Comprometimento dos Stakeholders
- Declaração do Escopo do Projeto
- **Fase de Iniciação do Projeto**
- Plano do Projeto Integrado
- Recursos do Projeto
- Gerenciamento de Riscos do Projeto
- Plano de Qualidade do Projeto
- Controle de Mudanças do Projeto
- Métodos de Planejamento de Segurança
- Avaliação de Desempenho do Projeto
- Encerramento do Projeto

Assegura que a iniciação das fases mais importantes do projetos estejam aprovadas formalmente e comunicadas para todos os stakeholders.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Estabelece um plano de projeto integrado aprovado e formal. Este plano de projeto integrado deve gerenciar os sistemas de informação e de negócio para dirigir a execução do projeto e controle do projeto durante o ciclo de vida do projeto.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Define as responsabilidades, relacionamentos, autoridades, critérios de performance do projeto e especifica bases para contratação e alocação dos membros da equipe e/ou contratados para o projeto.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Elimina ou minimiza os riscos específicos associados com determinado projetos através de um processo sistemático de planejamento, identificação, análise, monitoração e controle das áreas ou eventos que possam causar uma possível mudança não desejada.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Prepara o plano de gerenciamento de qualidade que irá descrever o sistema de qualidade do projeto e como ele irá ser implementado.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Estabelece um sistema de controle de mudanças para cada projeto, desta forma todas as mudanças na baseline do projeto, como por exemplo, custo, prazo, escopo e qualidade, são revisadas a aprovadas de forma apropriada dentro de um plano de projeto integrado.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Identifica as tarefas de segurança necessárias para segurar o credenciamento de sistemas novos ou modificados durante o planejamento do projeto e inclui estes no plano de projeto integrado.

Planejamento e Organização

PO10 Gerenciar Projetos

- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

Medidas de performance do projeto em relação a critérios chaves do projeto, como por exemplo, escopo, prazo, qualidade, custo e riscos para identificar qualquer desvio do plano do projeto.

Planejamento e Organização

PO10 Gerenciar Projetos

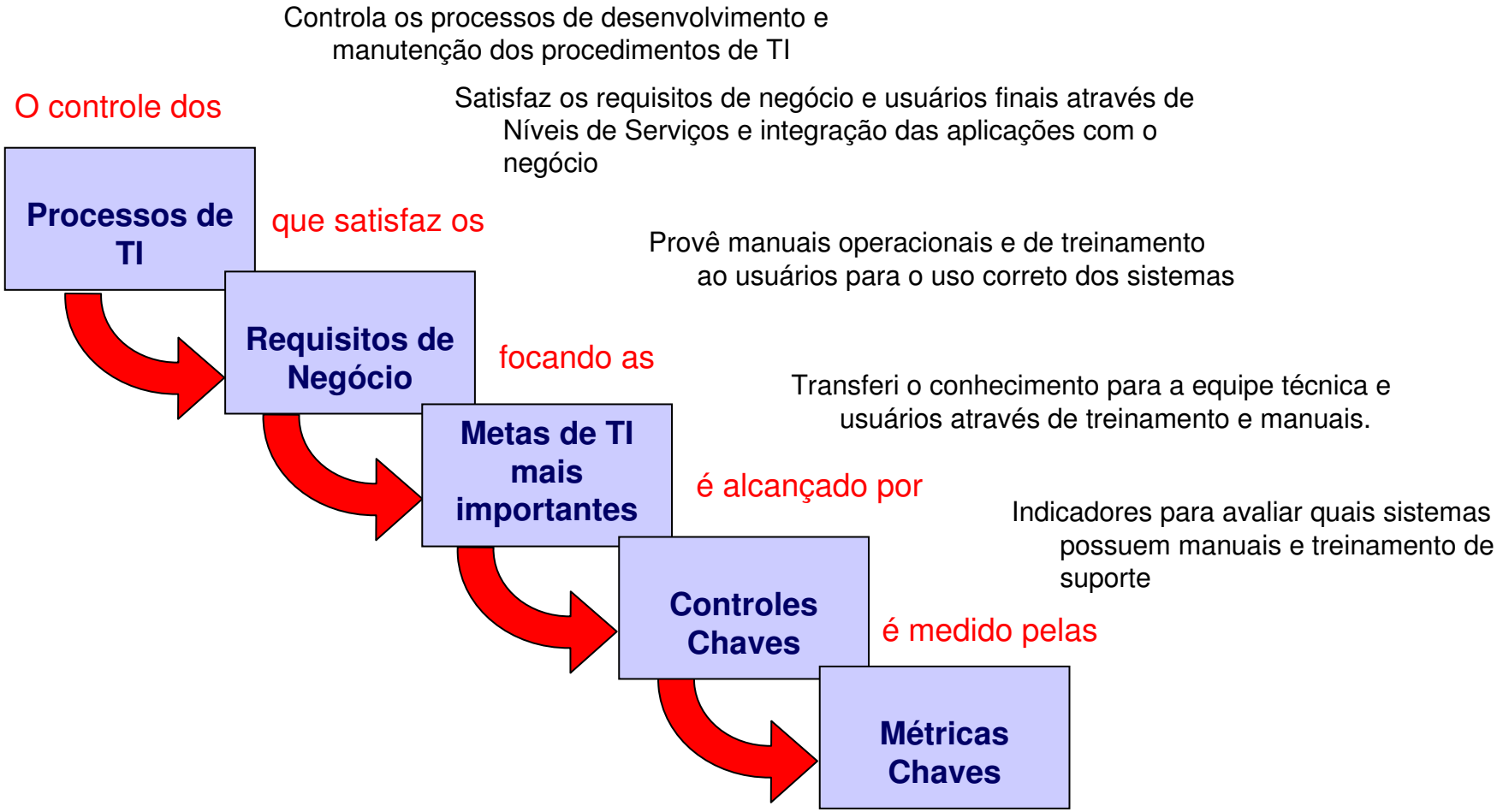
- **Framework de Gerenciamento de Programas**
- **Framework de Gerenciamento de Projetos**
- **Implementação Gerenciamento de Projetos**
- **Comprometimento dos Stakeholders**
- **Declaração do Escopo do Projeto**
- **Fase de Iniciação do Projeto**
- **Plano do Projeto Integrado**
- **Recursos do Projeto**
- **Gerenciamento de Riscos do Projeto**
- **Plano de Qualidade do Projeto**
- **Controle de Mudanças do Projeto**
- **Métodos de Planejamento de Segurança**
- **Avaliação de Desempenho do Projeto**
- **Encerramento do Projeto**

No final de cada projeto, requer que os stakeholders certifiquem os resultados entregues pelo projeto e os seus benefícios. Identifica e documenta as lições aprendidas para o uso em projetos e programas futuros.

Aquisição e Implementação

AI4 Desenvolver e manter procedimentos de TI

Vamos ver agora em detalhes objetivos de controle de alto nível para desenvolver e manter procedimentos no domínio de Aquisição e Implementação.



Aquisição e Implementação

AI4 Desenvolver e manter procedimentos de TI

Vamos ver os Objetivos de Controle Detalhados para Desenvolver e manter procedimentos de TI na fase de aquisição e implementação do projeto.

Planejamento para Soluções Operacionais

Transferência de Conhecimento para a Gerência de Negócio

Transferência de Conhecimento para os Usuários Finais

Transferência de Conhecimento para as Operações e Equipe de Suporte

Aquisição e Implementação

AI4 Desenvolver e manter procedimentos de TI

Planejamento para Soluções Operacionais	Desenvolve um plano para identificar e documentar todos os aspectos técnicos, capacidade operacional e níveis de serviços requeridos, sendo assim, todos os stakeholders podem tomar a responsabilidade na hora certa para os procedimentos operacionais.
Transferência de Conhecimento para a Gerência de Negócio	
Transferência de Conhecimento para os Usuários Finais	
Transferência de Conhecimento para as Operações e Equipe de Suporte	

Aquisição e Implementação

AI4 Desenvolver e manter procedimentos de TI

Planejamento para Soluções Operacionais

Transferência de Conhecimento para a Gerência de Negócio

Transferência de Conhecimento para os Usuários Finais

Transferência de Conhecimento para as Operações e Equipe de Suporte

Transfere o conhecimento para a gerência de negócio permitindo que estes assumam a propriedade do sistema e da informação e exerçam a responsabilidade pela entrega de serviço e qualidade, controle interno e processos de administração de aplicação.

Aquisição e Implementação

AI4 Desenvolver e manter procedimentos de TI

Planejamento para Soluções Operacionais
Transferência de Conhecimento para a Gerência de Negócio
Transferência de Conhecimento para os Usuários Finais
Transferência de Conhecimento para as Operações e Equipe de Suporte

Transfere o conhecimento e habilidades para os permitir os usuários finais a usar as aplicações de um modo eficiente para suportar os processos do negócio.

Aquisição e Implementação

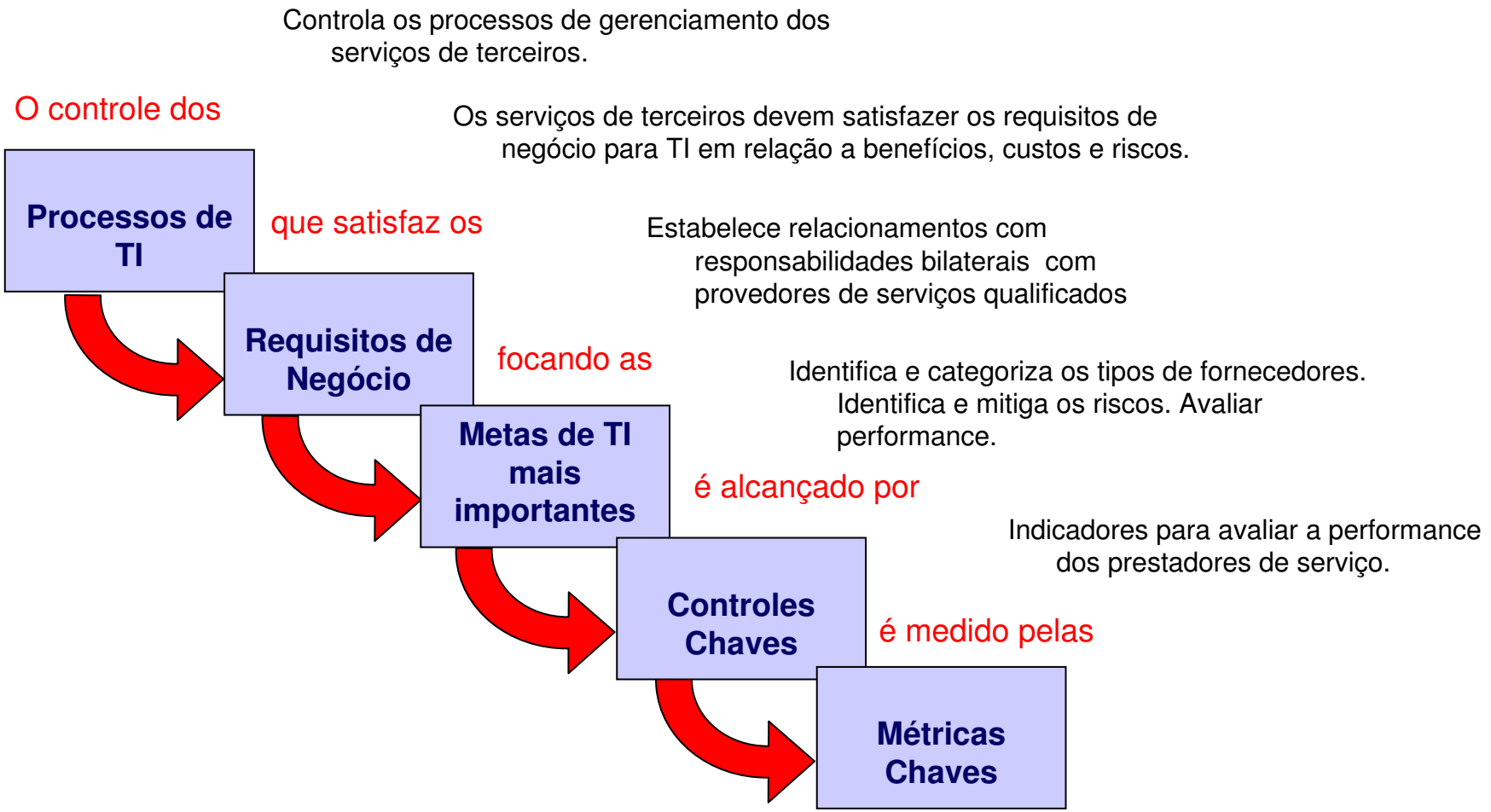
AI4 Desenvolver e manter procedimentos de TI

Planejamento para Soluções Operacionais	Transfere o conhecimento e habilidades para possibilitar a equipe de suporte técnico e de operações a entregar, dar suporte e manter os sistemas de aplicações e infra-estrutura associados de acordo com os níveis de serviço requeridos.
Transferência de Conhecimento para a Gerência de Negócio	
Transferência de Conhecimento para os Usuários Finais	
Transferência de Conhecimento para as Operações e Equipe de Suporte	

Entrega e Suporte

DS2 Gerenciar serviços de terceiros

Vamos aprender agora sobre os objetivos de controle de alto nível para Gerenciar serviços de terceiros na fase de Entrega e Suporte do projeto.



Entrega e Suporte

DS2 Gerenciar serviços de terceiros

Vamos ver os objetivos de Controle detalhados para o Gerenciamento de serviços de terceiros na fase de Entrega e Suporte do processo de TI.

Identificação de todos os Relacionamentos com Fornecedores
Gerenciamento de Relacionamento com Fornecedores
Gerenciamento de Riscos com Fornecedores
Gerenciamento de Performance com Fornecedores

Entrega e Suporte

DS2 Gerenciar serviços de terceiros

Identificação de todos os Relacionamentos com Fornecedores

Gerenciamento de Relacionamento com Fornecedores

Gerenciamento de Riscos com Fornecedores

Gerenciamento de Performance com Fornecedores

Identifica todos os serviços dos fornecedores e os categoriza de acordo com o tipo de fornecedor, importância, criticidade. Mantem uma documentação formal dos relacionamentos técnicos e organizacionais, cobrindo funções, responsabilidades, metas, resultados esperados e nomes dos contatos destes fornecedores.

Entrega e Suporte

DS2 Gerenciar serviços de terceiros

Identificação de todos os Relacionamentos com Fornecedores
Gerenciamento de Relacionamento com Fornecedores
Gerenciamento de Riscos com Fornecedores
Gerenciamento de Performance com Fornecedores

Formaliza o processo de gerenciamento de relacionamento com cada fornecedor. Os responsáveis pelo relacionamento precisam ligar as questões do cliente com o fornecedor e assegurar a qualidade do relacionamento baseada na verdade e transparência, por exemplo, através de Acordos de Nível de Serviço.

Entrega e Suporte

DS2 Gerenciar serviços de terceiros

Identificação de todos os Relacionamentos com Fornecedores	Identifica e mitiga os riscos relacionados com a habilidade do fornecedor para continuar a entrega de serviço efetiva de uma maneira eficiente e segura. Assegurar que os contratos estejam em conformidade com padrões de negócios universais de acordo com requisitos legais e regulatórios.
Gerenciamento de Relacionamento com Fornecedores	
Gerenciamento de Riscos com Fornecedores	
Gerenciamento de Performance com Fornecedores	

Entrega e Suporte

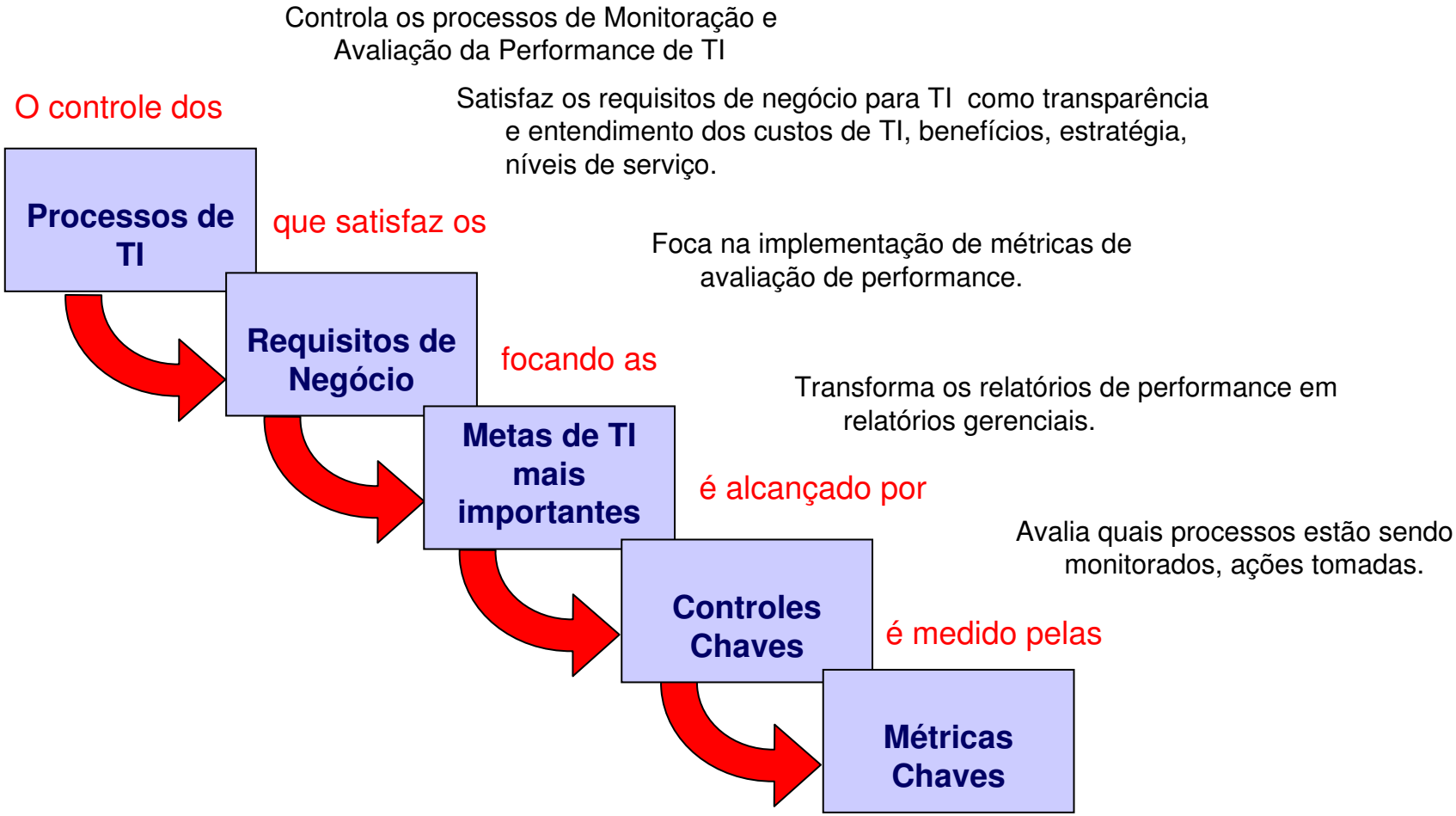
DS2 Gerenciar serviços de terceiros

Identificação de todos os Relacionamentos com Fornecedores	Estabelece um processo para monitorar a entrega de serviço assegurando que o fornecedores estão atendendo os requisitos do negócio e estão atendendo os níveis de serviço acordados em contrato, e que a performance é competitiva com fornecedores alternativos com a mesma condição no mercado.
Gerenciamento de Relacionamento com Fornecedores	
Gerenciamento de Riscos com Fornecedores	
Gerenciamento de Performance com Fornecedores	

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

Vamos ver agora os objetivos de controle de alto nível nos processos da fase de Monitoração e Avaliação do Projeto.



Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

Vamos ver os objetivos de controle detalhados para os processos da fase de monitoração do projeto.

Monitoração
Definição e Coleção de Dados para Monitoração
Método de Monitoração
Avaliação de Performance
Relatório para o Conselho e Administração
Ações corretivas

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

Implementação da Monitoração

- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Assegura que a administração estabeleça um framework de monitoração, e defina o escopo, metodologia e processo para ser seguido para monitorar a contribuição de TI para o resultado da empresa.

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

- **Implementação da Monitoração**
- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Define indicadores de performance, medidas, targets e bechmarks que sejam relevantes para os stakeholders.

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

- **Implementação da Monitoração**
- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Assegura que o processo de monitoração desenvolva um método como um balanced scorecard que forneça uma visão sucinta da performance de TI e esteja adequado com o sistema de monitoração corporativo.

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

- **Implementação da Monitoração**
- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Revisão periódica da performance em relação às metas, realiza a análise de causa raiz, inicia ações corretivas para eliminar as causas.

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

- **Implementação da Monitoração**
- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Fornece relatórios gerenciais para a revisão da administração sobre as metas, performance do portfólio de projetos relacionados a TI, contribuição da TI para o negócio.

Monitoração e Avaliação

ME1 – Monitorar e Avaliar a Performance de TI

- **Implementação da Monitoração**
- **Definição e Coleção de Dados para Monitoração**
- **Método de Monitoração**
- **Avaliação de Performance**
- **Relatório para o Conselho e Administração**
- **Ações corretivas**

Identifica e inicia ações corretivas baseadas na monitoração de performance, avaliação e relatórios.

Curso Online

COBIT

FUNDAMENTOS EM GOVERNANÇA DE TI



Todos os direitos de cópia reservados. Não é permitida a distribuição física ou eletrônica deste material sem a permissão expressa do autor.

Objetivos

Este módulo descreve as diretrizes de gerenciamento e de auditoria.

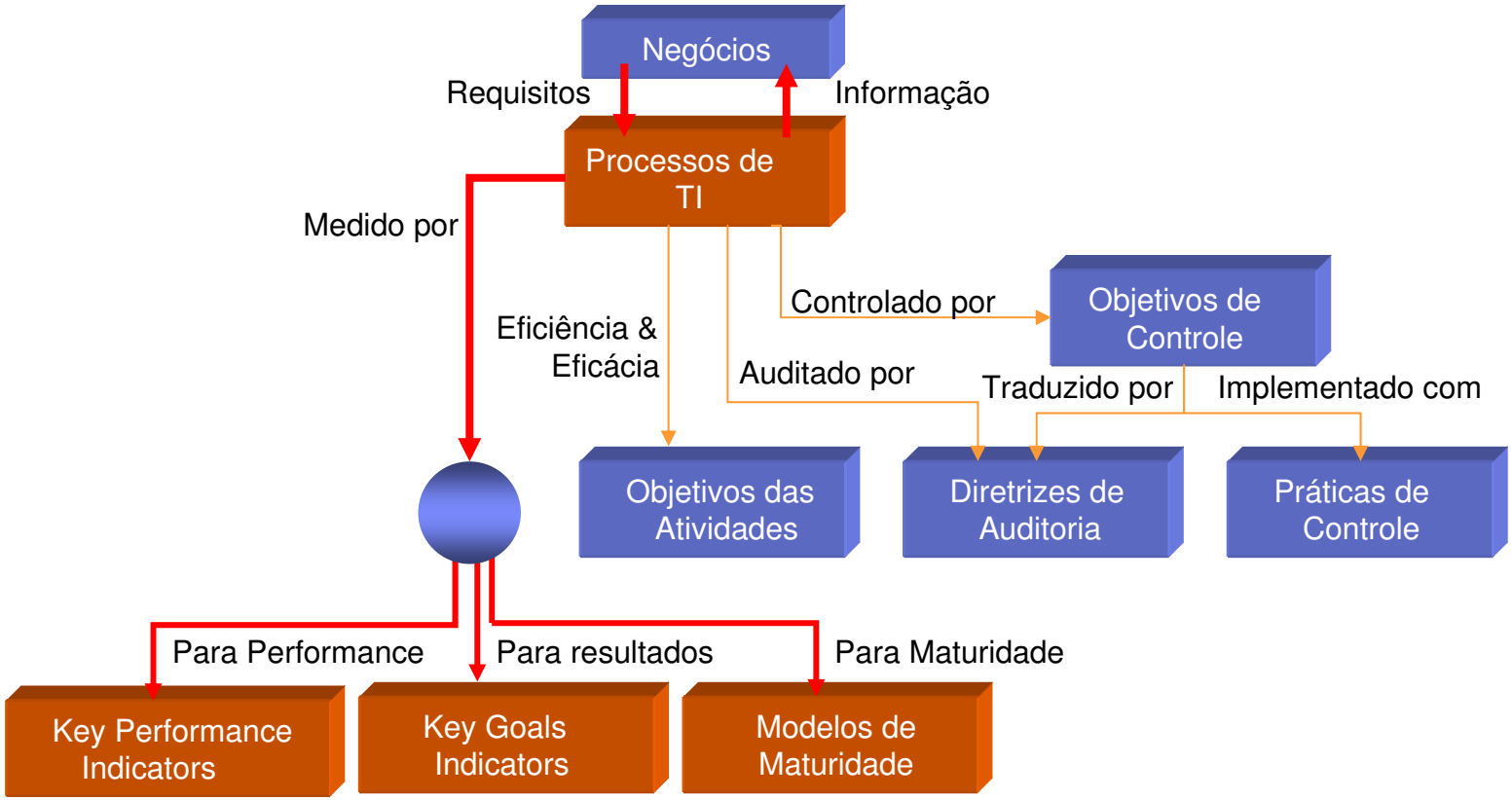
Ao final deste módulo você conseguirá:

- Entender a Estrutura das Diretrizes de Gerenciamento
- Descrever as entradas e saídas dos processos, atividades e gráficos RACI, métricas e metas e modelos de maturidade.
- Entender a Estrutura das Diretrizes de Auditoria
- Entender como os Processos de TI do COBIT são auditados
- Entender o que são Práticas de Controles

Diretrizes de Gerenciamento

Objetivos

Nós já aprendemos sobre os objetivos de controle. Agora vamos aprender sobre os conceitos de diretrizes de gerenciamento.



Diretrizes de Gerenciamento

Existem muitas questões sendo levantadas pela administração, como as que temos abaixo. Estas questões serão respondidas durante este módulo.

- **Como os gerentes responsáveis irão manter O navio em curso?**



- **Como conseguir resultados que sejam satisfatórios para o segmento dos nossos stakeholders ?**

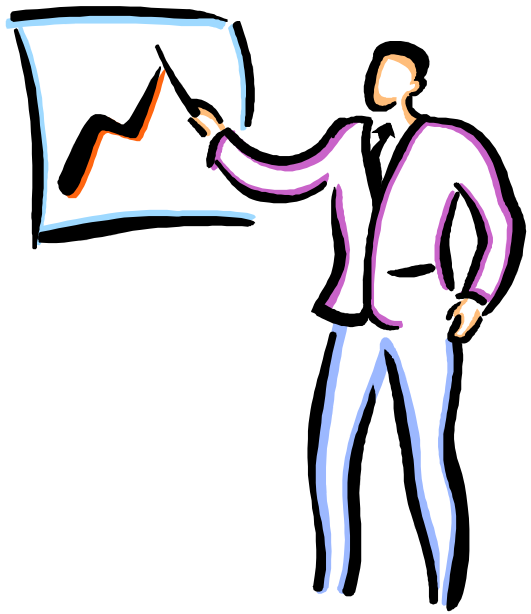


- **Como adaptar a organização rapidamente para as tendências do seu ambiente ?**



Diretrizes de Gerenciamento

As Diretrizes de Gerenciamento do COBIT possibilitam os administradores da organização a lidar de forma eficiente com as necessidades e requisitos da governança de TI. As diretrizes são orientadas a ações e genéricas e fornecem apoio para obter informações sobre a organização e processos relacionados sob controle, para monitorar o cumprimento das metas da organização e para monitorar o desempenho em cada processo de TI e realizar bechmarking (comparação) com outras empresas do mesmo setor.

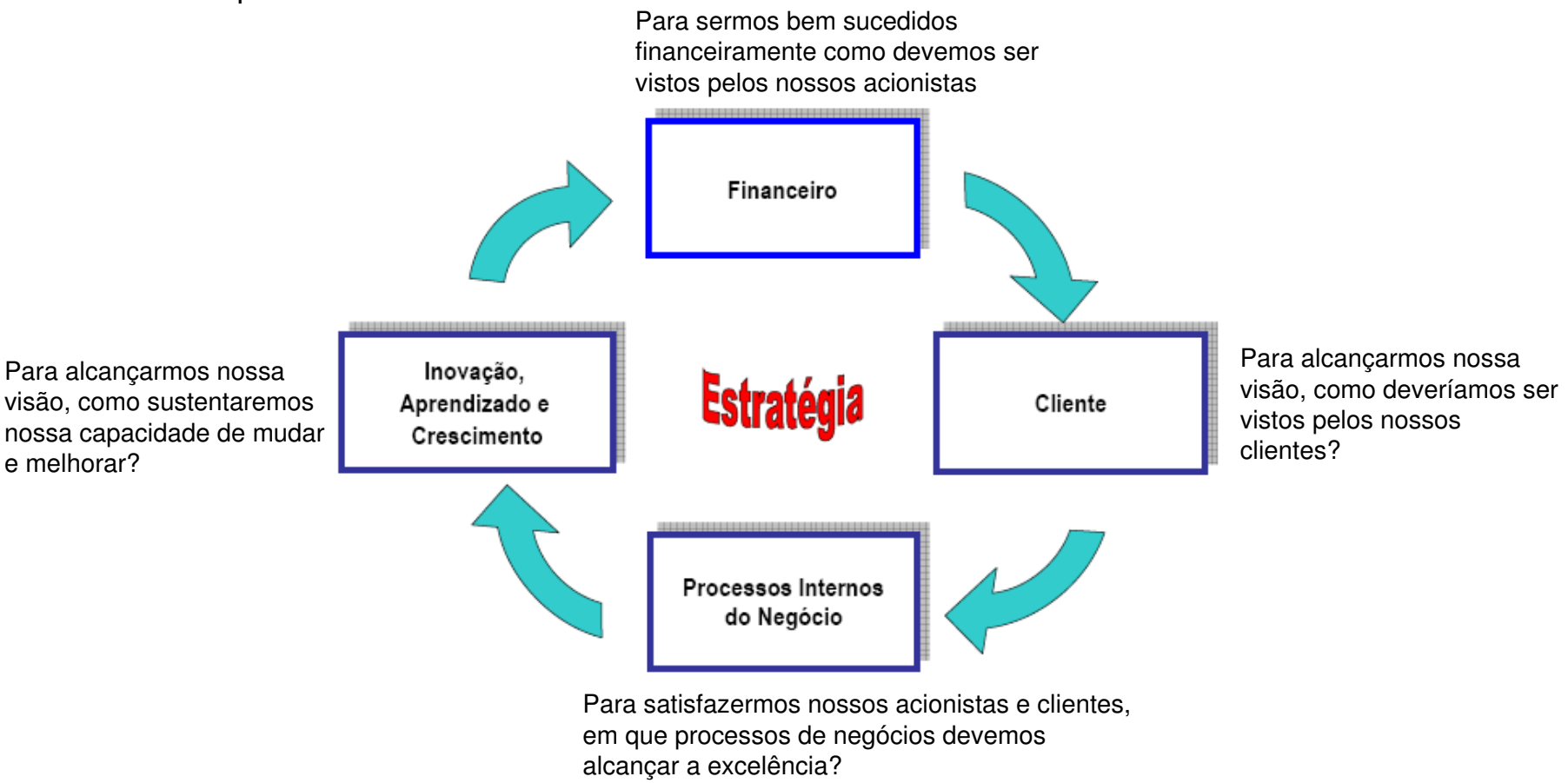


As diretrizes de Gerenciamento irão responder aos seguintes tipos de questões: quanto tempo mais vamos levar, e qual é o custo justificado para o benefício? Quais são os indicadores de performance ideais? Quais são os riscos de não alcançar nossos objetivos? O que os outros estão fazendo? Como nós medimos e comparamos?

Scorecards e Métricas

As Diretrizes de Gerenciamento especificam medidas de resultado em forma de KGIs (Key Gol Indicadors) e medidas de performance em forma de KPIs (Key Performance Indicators). Estas medidas de performance podem ser usadas para medir e monitorar o progresso em direção ao resultado esperado.

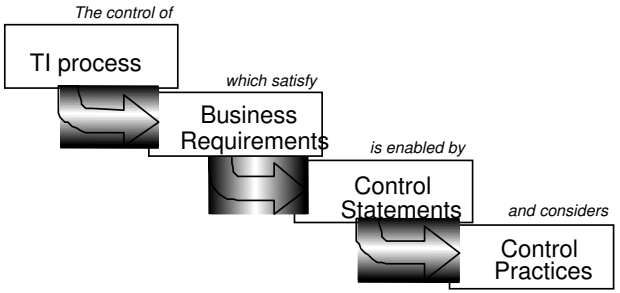
As Diretrizes de Gerenciamento do COBIT sugerem utilizar Balanced Business Scorecards, os quais fornecem métricas para alcançar as metas de TI. O scorecard tem 4 dimensões que mapeiam as metas e indicadores de performance:



Framework de Diretrizes de Gerenciamento

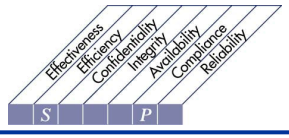
As Diretrizes de Gerenciamento fornecem 34 processos, Entradas e Saídas com vínculos para outros processos, atividades chaves para os processos, gráficos RACI, Metas e Métricas.

Descrição do Processo

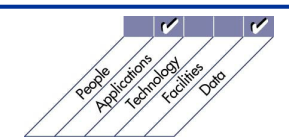


Metas, Métricas

-
-
-



Critérios de Informação



Recursos

Key Goal Indicators

-
-
-

Key Performance Indicators

-
-

Modelos de Maturidade

0 - Processos de Gerenciamento não são aplicados a todos.
1 – Os processos são *desorganizados*.
2 – Os processos seguem um padrão regular.
3 - Os processos são documentados e comunicados.
4 – Os processos são monitorados e medidos.
5 – As melhores práticas são seguidas e automatizadas

Entradas e Saídas de Processos

Cada processo é vinculado a outros processos. Entradas são *deliverables* necessários para um processo a partir de outros processos. As saídas são *deliverables* fornecidos para outros processos. Em alguns casos, as entradas e saídas não fazem parte do COBIT.

Exemplo: P010 Gerenciar Projetos

De	Entradas
PO1	Portfolio de Projetos
PO5	Portfolio de Projetos de IT Atualizado
PO7	Matriz de habilidades de TI
PO8	Padrões de Desenvolvimentos
AI7	Revisão pós-implementação

Saídas	Para			
Relatórios de Performance do Projeto	ME1			
Plano de Gerenciamento de Riscos do Projeto	PO9			
Diretrizes de Gerenciamento de Projetos	AI1....	...AI7		
Planos de Projetos detalhados	PO8	AI1....	...AI7	DS
Portfolio de Projetos atualizados	PO1	PO5		

* Deliverables = resultado do processo, entregas.

Atividades Chaves e Gráficos RACI

Para cada processo, as atividades chaves são definidas junto com um gráfico RACI (**R**esponsible, **A**ccountable, **C**onsulted, and **I**nformed) para cada processo. Accontable significa “aqui pára o dinheiro”. Esta é a pessoa que fornece direção e autoriza uma atividade. Esta não pode ser delegada. Responsibility significa que é a pessoa que executa a tarefa. Neste caso, a tarefa não pode ser delegada. As outras funções, consulted e informed, asseguram qualquer um que precise ser envolvido e suporte o processo. O gráfico RACI define as tarefas que precisam ser delegadas e para quem.

RACI Chart — **Functions**

PO10 – Gerenciar Projetos

Activities	CEO	CFO	Business Executive	CIO	Business Process Owner	Head Operations	Chief Architect	Head Development	Head IT Administration	PMO	Compliance, Audit, Risk and Security
Define a programme/portfolio management framework for IT investments.	C	C	A	R						C	C
Establish and maintain an IT project management framework.	I	I	I	A/R	I	C	C	C	C	R	C
Establish and maintain an IT project monitoring, measurement and management system.	I	I	I	R		C	C	C	C	A/R	C
Build project charters, schedules, quality plans, budgets, and communication and risk management plans.			C	C	C	C	C	C	C	A/R	C
Assure the participation and commitment of project stakeholders.	I		A	R	C						C
Assure the effective control of projects and project changes.			C	C		C	C	C		A/R	C
Define and implement project assurance and review methods.			I	C				I		A/R	C

A **RACI** charts Identifies who is **R**esponsible, **A**ccountable, **C**onsulted and/or **I**nformed.

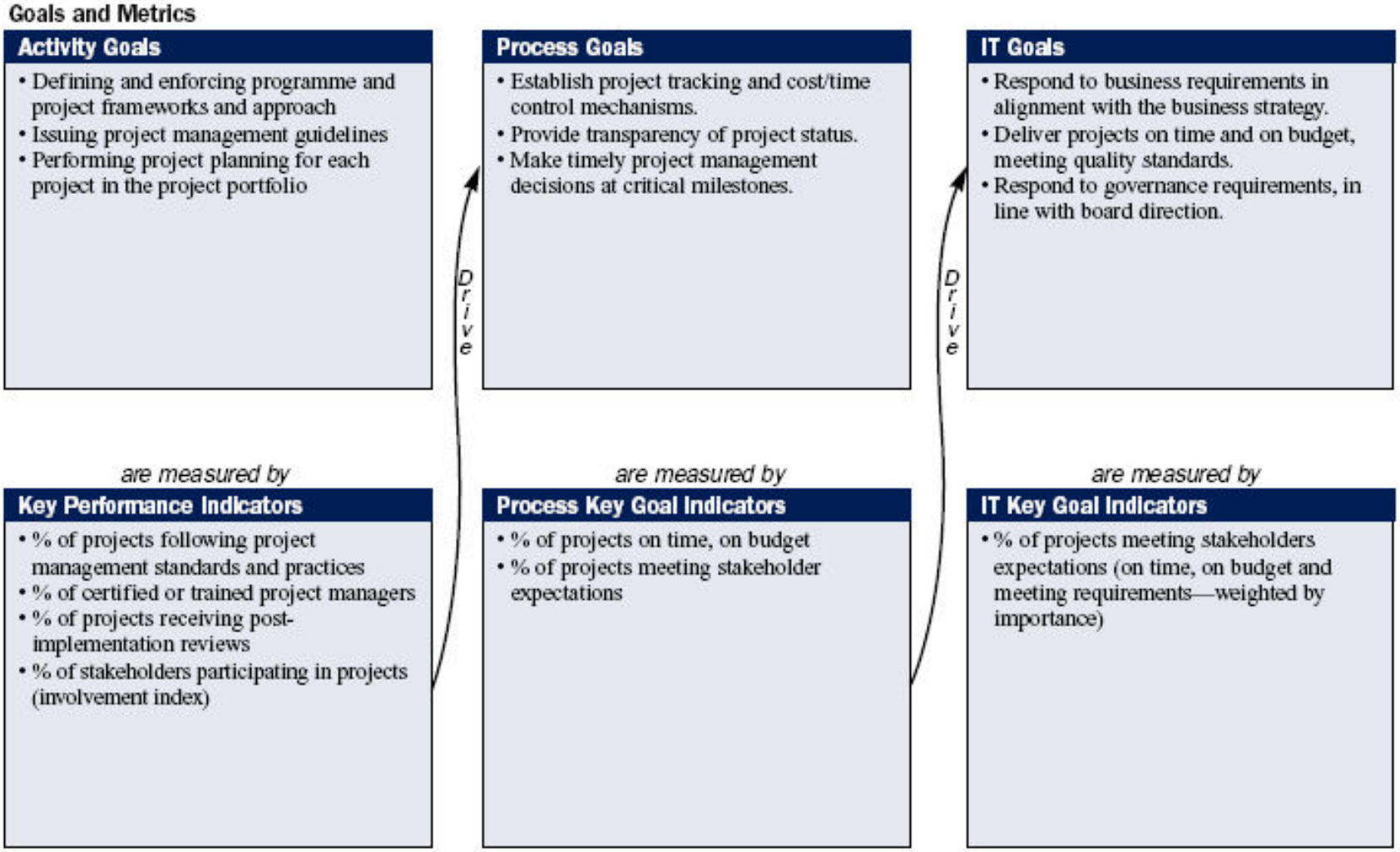
TI, Processos, Metas

Metas e métricas são definidas no COBIT em 3 níveis:

- **Metas e métricas de TI** que definem o que o negócio espera de TI (o que o negócio usaria para medir TI)
- **Metas e métricas de processos** que definem o que precisa entrar no processo de TI para suportar os objetivos de TI (como o proprietário do processo de TI será avaliado)
- **Métricas de performance de processos** (para medir como está a performance do processo indicando se as metas irão ser atingidas)

Tipos de Métricas

O COBIT usa 2 tipos de métricas: indicadores de meta e indicadores de performance. Os indicadores de meta do nível mais baixo tornam os indicadores de performance para o nível mais alto. Os quadros abaixo apresentam as métricas para o **PO10 – Gerenciar Projetos**.



Key Goal Indicator – Indicadores de Meta

Os KGIs definem medidas que dizem à administração se os processos de TI atingiram os seus requisitos de negócio. São medidas após o fato ocorrido, normalmente expressadas em termos de critérios de informação, tais como:

- Disponibilidade de informação necessária para suportar as necessidades do negócio
- Ausência de integridade e riscos de confidencialidade
- Confirmação da confiabilidade, eficácia e conformidade

O COBIT define 2 níveis de KGIs: uma para o departamento de TI (KGI de TI) e outro para o processo de TI (KGI de processo).

Exemplo: P010 Gerenciar Projetos

KGI de TI

- Percentual de projetos que estão atingindo as expectativas dos stakeholders (a nível de tempo, orçamento e requisitos de negócios – por peso de importância)

KGI de Processo

- Percentual de projetos no prazo e dentro do orçamento
- Percentual de projetos que estão atingindo as expectativas dos stakeholders

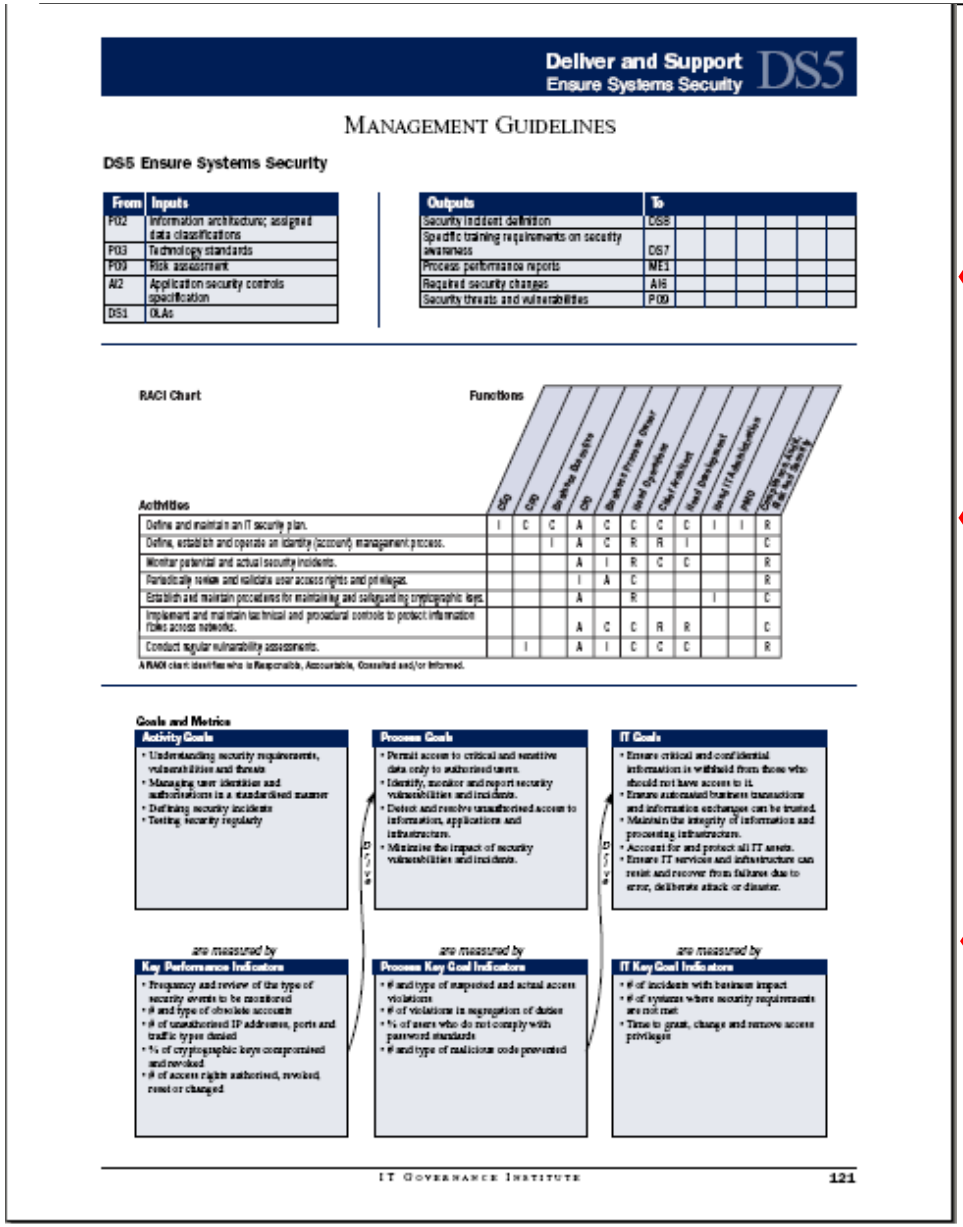
Key Performance Indicator – Indicadores de Performance

Os KPIs definem medidas que determinam como está a performance do processo de TI em relação a meta a ser alcançada. Eles são indicadores de aviso que informam se uma meta será alcançada ou não, e são bons indicadores de capacidades, práticas e habilidades. Eles medem as atividades chaves, as quais são ações que os proprietários do processo devem tomar para alcançar a performance efetiva do processo.

Exemplo: PO10 Gerenciar Projetos

- Percentual de projetos seguindo padrões e práticas de gerenciamento
- Percentual de gerentes de projeto certificados ou treinados
- Percentual de projetos recebendo revisões após a implementação
- Percentual de participações dos stakeholders em projetos (índice de envolvimento)

Exemplo do COBIT® 4.0 - DS5 (pag. 3)



Deliver and Support
Ensure Systems Security
DS5

MANAGEMENT GUIDELINES

DS5 Ensure Systems Security

From	Inputs
PO2	Information architecture; assigned data classifications
PO3	Technology standards
PO9	Risk assessment
AI2	Application security controls specification
DS1	OLAs

Outputs	To
Security incident definition	DS8
Specific training requirements on security awareness	DS7
Process performance reports	ME1
Required security changes	AI6
Security threats and vulnerabilities	PO9

RACI Chart

Functions

Activities	CEO	CFO	Business Executive	CIO	Business Process Owner	Head Operations	Chief Architect	Head Development	Head IT Administration	PMO	Compliance, Audit, Risk and Security
Define and maintain an IT security plan.	I	C	C	A	C	C	C	C	I	I	R
Define, establish and operate an identity (account) management process.			I	A	C	R	R	I			C
Monitor potential and actual security incidents.				A	I	R	C	C			R
Periodically review and validate user access rights and privileges.				I	A	C					R
Establish and maintain procedures for maintaining and safeguarding cryptographic keys.				A		R			I		C
Implement and maintain technical and procedural controls to protect information flows across networks.				A	C	C	R	R			C
Conduct regular vulnerability assessments.		I		A	I	C	C	C			R

A RACI chart identifies who is Responsible, Accountable, Consulted and/or Informed.

Goals and Metrics

Activity Goals
- Understanding security requirements, vulnerabilities and threats
- Managing user identities and authorizations in a standardized manner
- Defining security incidents
- Testing security regularly

are measured by

Key Performance Indicators
- Frequency and review of the type of security events to be monitored
- # and type of obsolete accounts
- # of unauthorized IP addresses, ports and traffic types denied
- % of cryptographic keys compromised and revoked
- # of access rights authorized, revoked, reset or changed

Process Goals
- Permit access to critical and sensitive data only to authorized users.
- Identify, monitor and report security vulnerabilities and incidents.
- Detect and resolve unauthorized access to information, applications and infrastructure.
- Minimize the impact of security vulnerabilities and incidents.

are measured by

Process Key Goal Indicators
- # and type of suspected and actual access violations
- # of violations in segregation of duties
- % of users who do not comply with password standards
- # and type of malicious code prevented

IT Goals
- Ensure critical and confidential information is withheld from those who should not have access to it.
- Ensure automated business transactions and information exchanges can be trusted.
- Maintain the integrity of information and processing infrastructure.
- Account for and protect all IT assets.
- Ensure IT services and infrastructure can resist and recover from failure due to error, deliberate attack or disaster.

are measured by

IT Key Goal Indicators
- # of incidents with business impact
- # of systems where security requirements are not met
- Time to grant, change and remove access privileges

Relacionamentos dos processos

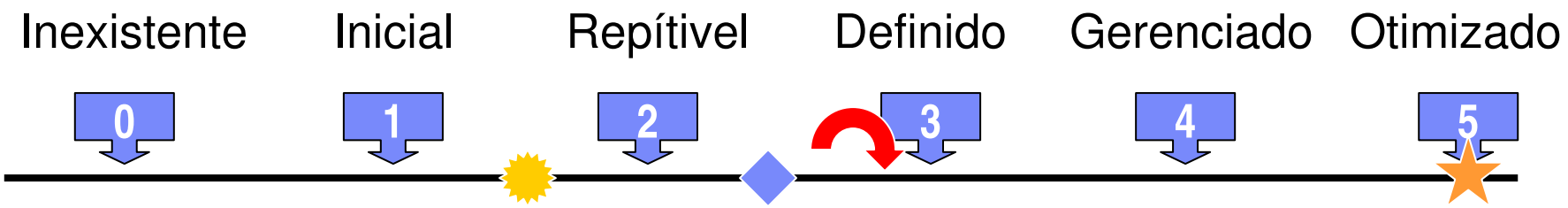
Gráfico RACI (atividades e responsabilidades associadas mais importantes)

Metas de TI & Métricas de Performance

Modelos de Maturidade

Modelos de maturidade fornecem uma escala para comparar (fazer benchmarking) as práticas da empresa em relação a indústria e padrões e diretrizes internacionais.

Um modelo de maturidade é uma medida que possibilita uma organização a classificar sua maturidade para um certo processo de inexistente (0) à otimizado (5).



Legenda para os Símbolos

- **Enterprise current status**
- **International standard guidelines**
- **Industry best practice**
- **Enterprise strategy**

Legendas para o Ranking

0 – Processos de Gerenciamento não são aplicados a todosl.

1 – Os processos são desorganizados.

2 – Os processos seguem um padrão regular.

3 - Os processos são documentados e comunicados.

4 – Os processos são monitorados e medidos.

5 – As melhores práticas são seguidas e automatizadas

.

Modelo de Maturidade Genérico

0 **Inexistente**	Falta completa de qualquer processo identificável. Não existe a consciência da necessidade de controles.
1 **Inicial**	Já existe processos, só que ainda são ad hoc, tendem a ser aplicados a um individuo ou tratados a cada caso. De forma geral ainda o gerenciamento é desorganizado.
2 **Repítivel**	Os processos já seguem procedimentos similares e são seguidos por diferentes pessoas que executam a mesma tarefa. Não existe treinamento formal ou comunicação dos procedimentos padrões, e a responsabilidade é individual. Existe um alto grau de confiança no conhecimento dos indivíduos, desta forma os erros são prováveis.
3 **Definido**	Os procedimentos foram padronizados e documentados, e comunicados através de treinamento. Ainda é possível acontecer desvios, mas não mais com freqüência. Os procedimentos não são sofisticados, mas existe formalização das práticas existentes.
4 **Gerenciado**	É possível monitorar e medir a conformidade com os procedimentos e tomar ação onde os processos aparentam não estar funcionando corretamente. Os processos estão sobre aperfeiçoamento constante e fornecem boas práticas. Ferramentas de automação são usadas de forma limitada e fragmentada.
5 **Otimizado**	Os processos foram refinados a um nível das melhores práticas, baseados em resultados de aperfeiçoamento contínuo e modelagem de maturidade com outras empresas. A TI é usada de forma integrada para automatizar fluxos de trabalho, fornecendo ferramentas para aperfeiçoar a qualidade e eficiência, e fazendo com que a empresa se adapte rapidamente.

Modelos de Maturidade

O modelo de maturidade fornecido pelas Diretrizes de Gerenciamento do COBIT para os 34 processos de TI está se tornando uma ferramenta cada vez mais popular para gerenciar questões típicas de balanceamento de riscos e controle de forma a levar em consideração o custo-efetivo.

Uma característica fundamental do modelo de maturidade é que ele permite uma organização medir o nível de maturidade e definir quais níveis de maturidade quer chegar e quais brechas nos processos quer eliminar. Como resultado, uma organização pode descobrir aperfeiçoamentos práticos para o sistema de controles internos de TI.



Avaliação do Nível de Maturidade

O nível de maturidade de cada processo é avaliado através de questionários de avaliação derivados do Modelo de Maturidade do COBIT. Estes questionários se baseiam em um cenário, cada nível de maturidade é considerado um cenário, incluindo a descrição da organização e controles internos de uma empresa que satisfaça os requisitos de um específico nível de maturidade.

A tabela ao lado mostra um exemplo de como as declarações do questionário são derivadas do modelo de maturidade do processo **PO10 – Gerenciar Projetos**.

Figure 2—Questionnaire Construction for PO10 Managing Projects (maturity levels 0 and part of 1)

Maturity Level Description	Questionnaire Statements
0 Nonexistent—Project management techniques are not used and the organization does not consider business impacts associated with project mismanagement and development project failures.	• The organization does not use project management techniques. • The organization does not report on project mismanagement effects or development project failures.
1 Initial/*Ad hoc*—The organization is generally aware of the need for projects to be structured and it is aware of the risks of poorly managed projects. The use of project management techniques and approaches within IT is a decision left to individual IT managers. Projects are generally poorly defined.	• The organization is generally aware of the need for projects to be structured. • The organization is aware of the risks of poorly managed projects. • The use of project management techniques and approaches within IT is a decision left to individual IT managers. • Projects are generally poorly defined.

Exemplo do COBIT® 4.0 - DS5 (pag. 3)

DS5 Deliver and Support
Ensure Systems Security

Maturity Model

DS5 Ensure Systems Security

Management of the process of *Ensure systems security* that satisfies the business requirements for IT of *maintaining the integrity of information and processing infrastructure and minimising the impact of security vulnerabilities and incidents* is:

0 Non-existent when
The organisation does not recognise the need for IT security. Responsibilities and accountabilities are not assigned for ensuring security. Measures supporting the management of IT security are not implemented. There is no IT security reporting and no response process for IT security breaches. There is a complete lack of a recognisable system security administration process.

1 Initial/*Ad Hoc* when
The organisation recognises the need for IT security. Awareness of the need for security depends primarily on the individual. IT security is addressed on a reactive basis. IT security is not measured. Detected IT security breaches invoke finger-pointing responses, because responsibilities are unclear. Responses to IT security breaches are unpredictable.

2 Repeatable but Intuitive when
Responsibilities and accountabilities for IT security are assigned to an IT security co-ordinator, although the management authority of the co-ordinator is limited. Awareness of the need for security is fragmented and limited. Although security-relevant information is produced by systems, it is not analysed. Services from third parties may not address the specific security needs of the organisation. Security policies are being developed, but skills and tools are inadequate. IT security reporting is incomplete, misleading or not pertinent. Security training is available but is undertaken primarily at the initiative of the individual. IT security is seen primarily as the responsibility and domain of IT and the business does not see that IT security is within its domain.

3 Defined Process when
Security awareness exists and is promoted by management. IT security procedures are defined and aligned with IT security policy. Responsibilities for IT security are assigned and understood, but not consistently enforced. An IT security plan and security solutions exist as driven by risk analysis. Reporting on security does not contain a clear business focus. *Ad hoc* security testing (e.g., intrusion testing) is performed. Security training is available for IT and the business but is only informally scheduled and managed.

4 Managed and Measurable when
Responsibilities for IT security are clearly assigned, managed and enforced. IT security risk and impact analysis is consistently performed. Security policies and practices are completed with specific security baselines. Exposure to methods for promoting security awareness is mandatory. User identification, authentication and authorisation are standardised. Security certification is pursued for staff who are responsible for the audit and management of security. Security testing is done using standard and formalised processes leading to improvements of security levels. IT security processes are co-ordinated with an overall organisation security function. IT security reporting is linked to business objectives. IT security training is conducted in both the business and IT. IT security training is planned and managed in a manner that responds to business needs and defined security risk profiles. KGIs and KPIs for security management have been defined but are not yet measured.

5 Optimised when
IT security is a joint responsibility of business and IT management and is integrated with corporate security business objectives. IT security requirements are clearly defined, optimised and included in an approved security plan. Users and customers are increasingly accountable for defining security requirements, and security functions are integrated with applications at the design stage. Security incidents are promptly addressed with formalised incident response procedures supported by automated tools. Periodic security assessments are conducted to evaluate the effectiveness of implementation of the security plan. Information on threats and vulnerabilities is systematically collected and analysed. Adequate controls to mitigate risks are promptly communicated and implemented. Security testing, root cause analysis of security incidents and proactive identification of risk are used for continuous process improvements. Security processes and technologies are integrated organisationwide. KGIs and KPIs for security management are collected and communicated. Management uses KGIs and KPIs to adjust the security plan in a continuous improvement process.

Modelo de Maturidade para o processo específico

Planejamento e Organização

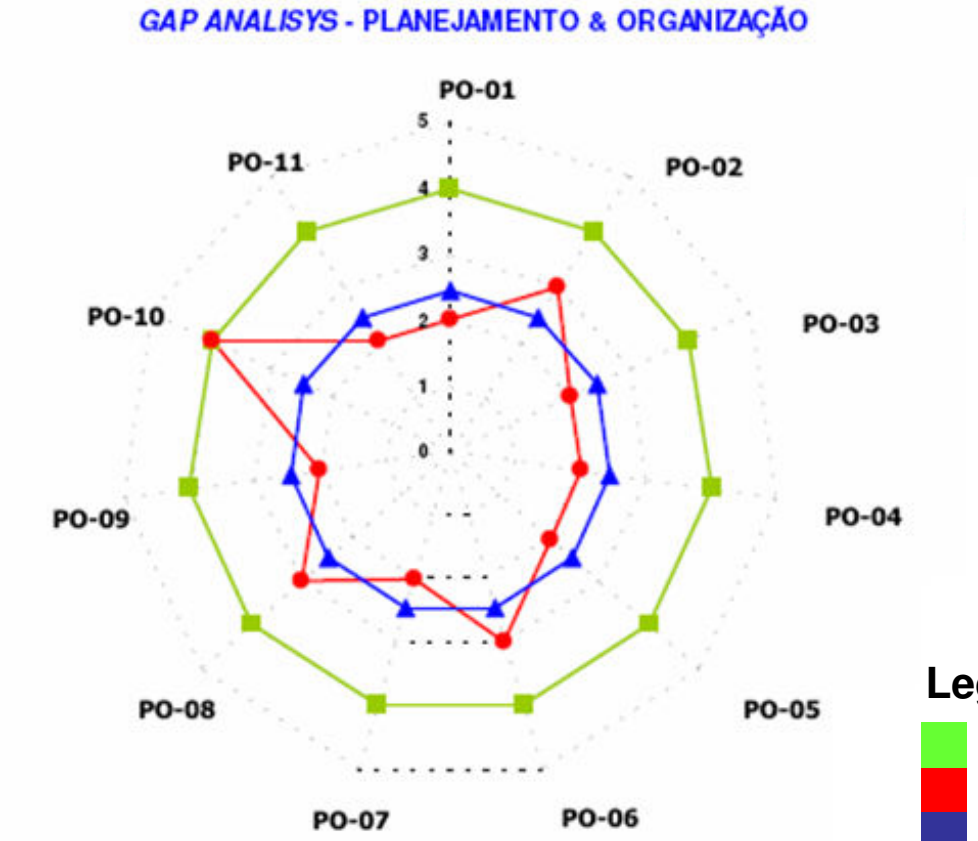
PO1 Definir um Plano Estratégico de TI

Vamos ver agora um exemplo de Modelo de Maturidade para o Objetivo de Controle PO1 - Definir um Plano Estratégico de TI.

0 Inexistente	O planejamento estratégico de TI não é realizado
1 Inicial	O planejamento estratégico é prática padrão e as exceções seriam notadas pela administração.
2 Repítivel	O planejamento estratégico de TI é entendido pela administração de TI, mas não é documentado.
3 Definido	Uma política define quando e como fazer um planejamento estratégico de TI.
4 Gerenciado	O planejamento estratégico é prática padrão e as exceções seriam notadas pela administração.
5 Otimizado	o planejamento estratégico é um processo documentado e vivo, é continuamente considerado no estabelecimento das metas da organização e resulta em valores compreensíveis de negócio através de investimentos em TI.

Análise de GAP

A Análise de GAP auxilia os gestores de TI a identificar como estão posicionados os macro controles de TI da organização em relação aos padrões esperados de mercado e/ou às suas próprias expectativas. Podemos utilizar a mesma técnica para os processos de TI aplicados pelo COBIT. Veja abaixo um exemplo de mapeamento de maturidade dos processos do domínio de Planejamento e Organização.



Avaliação do Domínio:
PO - Planejamento e Organização

PO01	Definir um plano estratégico de TI
PO02	Definir a arquitetura de informação
PO03	Determinar a direção tecnológica
PO04	Definir a organização e relacionamentos da TI
PO05	Gerenciar o investimento em TI
PO06	Comunicar Objetivos e Diretrizes da Administração
PO07	Gerenciar recursos humanos
PO08	Garantia do cumprimento de exigências externas
PO09	Avaliação de riscos
PO10	Gerenciar projetos

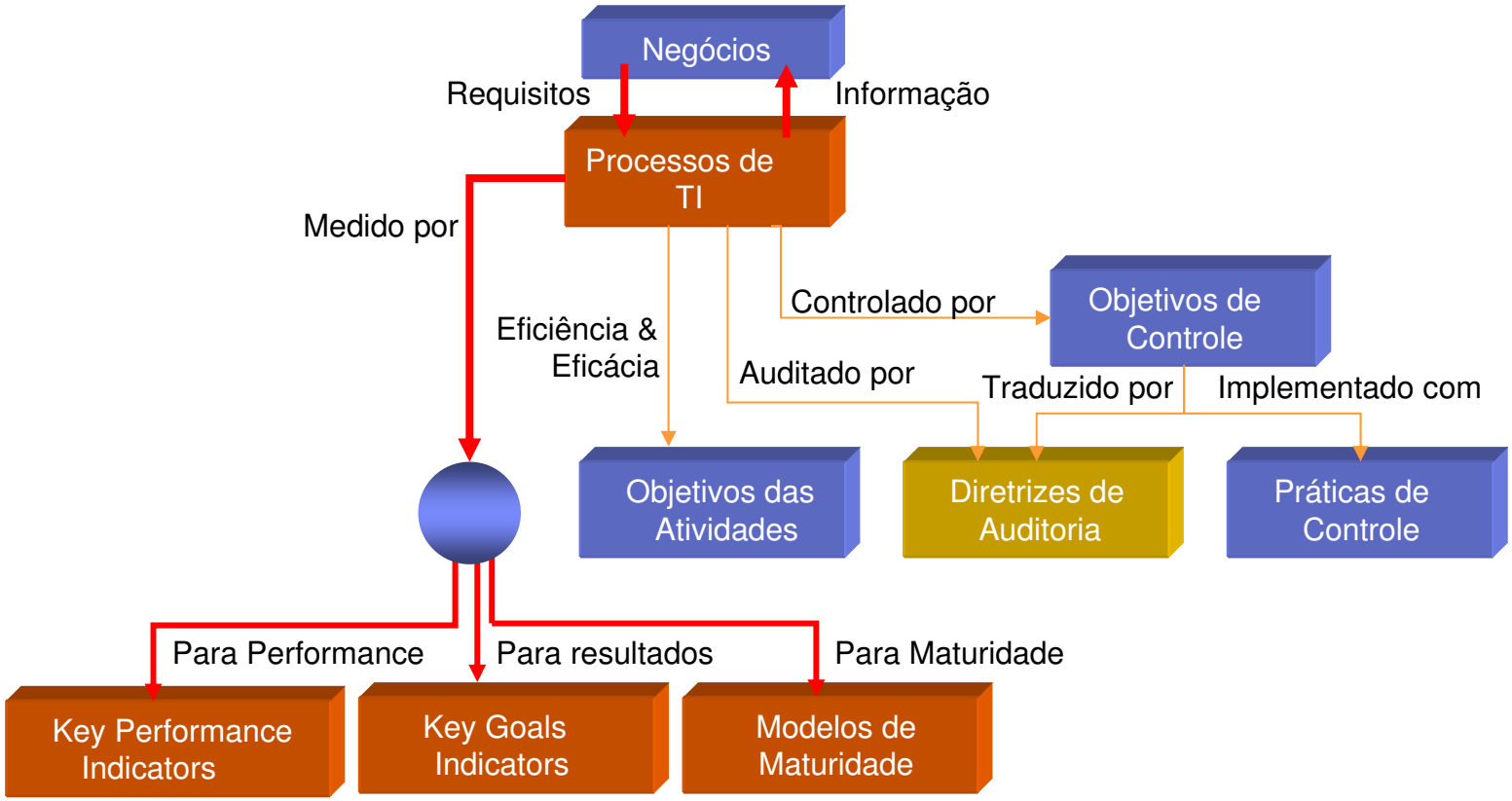
Legenda

- Expectativa
- Situação atual do processo
- Média

Diretrizes de Auditoria

Diretrizes de Auditoria

Tendo entendido os objetivos de controle e diretrizes de gerenciamento, vamos agora ver os conceitos de diretrizes de auditoria.



Objetivos da Auditoria

A administração precisa assegurar que as metas e objetivos de TI estão sendo alcançados e os controles chaves estão sendo aplicados. As diretrizes de gerenciamento descrevem e sugerem atividades de avaliação para serem executadas para cada um dos 34 objetivos de controle de alto nível. Entre os principais objetivos temos:

- Fornecer gerenciamento com segurança razoável de que os objetivos de controle estejam sendo alcançados
- Onde exister pontos fracos de controle significantes, será verificado os riscos resultantes
- Aconselhar a administração em ações corretivas

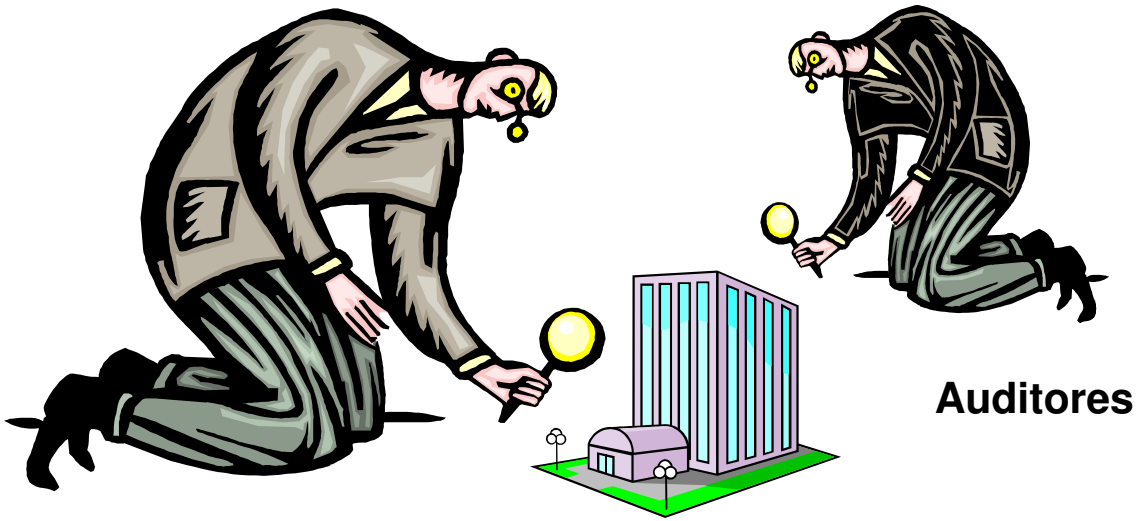


"Está tudo bem? E se não estiver, o que fazer para corrigir? "

Diretrizes de Auditoria

O COBIT permite os auditores internos e externos a confrontar processos de TI específicos com os Objetivos de Controle do COBIT para determinar onde os controles são suficientes ou aconselhar melhor gerenciamento onde os processos precisam ser melhorados.

O propósito das Diretrizes de Auditoria é fornecer uma estrutura simples para controles de auditoria e avaliação baseados em práticas de auditoria geralmente aceitas, que sejam compatíveis com o esquema de processos do COBIT.

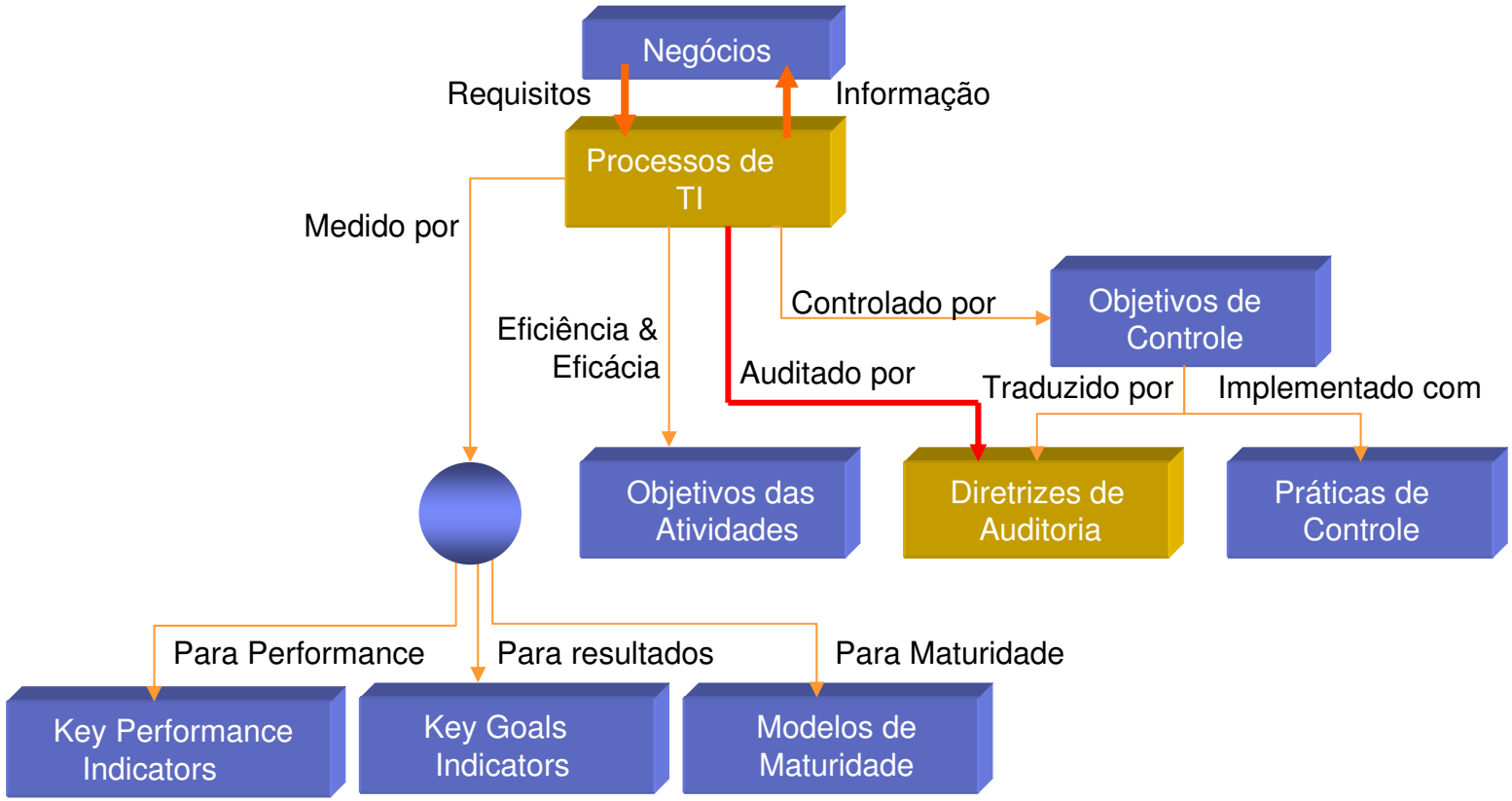


Auditores externos

Auditores internos

Diretrizes de Auditoria

Antes de vermos os componentes das Diretrizes de Auditoria, vamos ver como as Diretrizes de Auditoria estão vinculadas com os outros componentes do framework do COBIT.



Estrutura do Processo de Auditoria

A estrutura do processo de auditoria geralmente aceita compreende 4 estágios:



Obtém um entendimento dos riscos relacionados aos requisitos de negócio e medidas de controle relevantes

Avaliação dos controles determinados

Avaliação da conformidade testando se os controles determinados estão funcionando como prescritos, consistentemente e continuamente

Verificando os riscos dos objetivos de controle que não estão sendo alcançados através de técnicas analíticas e/ou consultando fontes alternativas

Requisitos para a Auditoria de Processos

Tendo definido o que será auditado e fornecido segurança, é hora de determinar a forma ou estratégia mais adequada para executar a auditoria. Para isto o COBIT sugere seguir os seguintes requisitos para a auditoria de processo:

Definir o escopo da auditoria	▪Preocupação com processo de negócio. ▪Plataformas, sistemas e seus relacionamentos com o suporte ao processo. ▪Funções, responsabilidades e estrutura organizacional
Identificar requisitos de informação relevantes para o processo do negócio	▪Relevância para o processo de negócio.
Identificar riscos de TI inerentes e um nível de controle abrangente	▪Mudanças recentes e incidentes no negócio e ambiente de tecnologia. ▪Resultados de auditorias, auto-avaliações e certificações. ▪Controles de monitoração aplicados pela administração.
Selecionar processos e plataformas a serem auditadas	▪Processos. ▪Recursos
Criar uma estratégia de auditoria	▪Controles x risco. ▪Passos e tarefas. ▪Pontos de decisão.

Auditoria de Processos de TI

Um processo de TI é auditado através da:

- **Obtenção do entendimento** dos riscos relacionados com os requisitos de negócio e medidas de controle relevantes.
  - **Avaliação dos controles** determinados, avaliando se estes são **apropriados.**
    - **Avaliação de conformidade** através de testes que verifiquem se o controle determinado está funcionando como previsto, de forma consistente e contínua.
      - **Substanciação dos riscos** dos objetivos de controle que não estão sendo atingidos através de análises técnicas ou consultando outras fontes alternativas.

Diretriz de Auditoria Genérica

Uma **diretriz de auditoria** genérica identifica várias tarefas a serem executadas para avaliar qualquer objetivo de controle dentro de um processo. Esta diretriz é um modelo para todos os objetivos de controle.

Diretrizes de Auditoria orientadas para 34 processos

Outras tarefas são específicas, sugestões para tarefas **orientadas a processos** fornecem uma segurança de gerenciamento de que um controle exista e tenha um nível de eficácia razoável.

Diretriz de Auditoria Genérica (1 de 4)

Obtendo o Entendimento

São os passos de auditoria a serem executados para documentar as atividades relacionadas com os objetivos de controle assim como identificar as medidas/procedimentos de controle a serem aplicados. Para fazer isto a equipe de auditoria precisa entender de maneira clara as áreas de auditoria seguindo os seguintes procedimentos:

- Entrevistar os gerentes e equipes apropriadas para obter e ter um entendimento de:
  - Requisitos de negócio e riscos associados
  - Estrutura da Organização
  - Funções e responsabilidades
  - Políticas e procedimentos
  - Leis e regulamentos
  - Medidas de controles já aplicadas
  - Relatórios gerenciais (status, performance, ações)



- Documentar o processo relacionado com os recursos de TI que afetam particularmente o processo sob análise.
- Confirmar o entendimento do processo sob análise.

Diretriz de Auditoria Genérica (2 de 4)

Avaliando os Controles

O próximo passo a ser executado é avaliar a eficácia das medidas de controle ou o grau para qual o Objetivo de Controle é alcançado, para isto é necessário determinar o que e como testar:

- Avaliando se a medidas de controle são apropriadas para o processo sob análise, considerando o critério identificado, práticas padrões na indústria e aplicando julgamento profissional. Determinando se:
  - Existem Processos documentados
  - *Existem Deliverables* apropriados
  - A Responsabilidade e a prestação de contas está clara
  - Controles de compensação existem quando necessário
- Concluindo o grau para o qual o objetivo de controle é alcançado

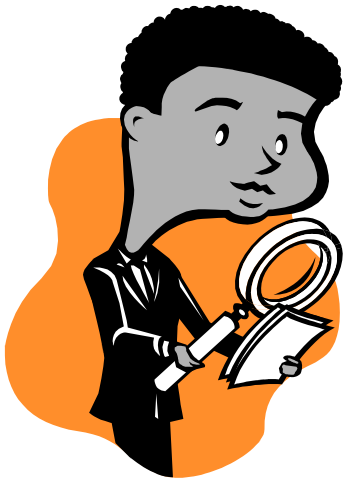


Diretriz de Auditoria Genérica (3 de 4)

Avaliando a Conformidade

O terceiro passo é assegurar que as medidas de controle estabelecidas estão funcionando como previsto, de forma consistente e contínua, e são apropriadas para o ambiente de controle:

- Obter evidência direta ou indireta para os itens/períodos selecionados para verificar se os procedimentos estão em conformidade.
- Realizar uma revisão limitada de adequação dos *deliverables* do processo
- Determinar o nível de testes substantivo e trabalho adicional necessário para fornecer uma garantia que o processo de TI está adequado.



Diretriz de Auditoria Genérica (4 de 4)

Substanciando os Riscos

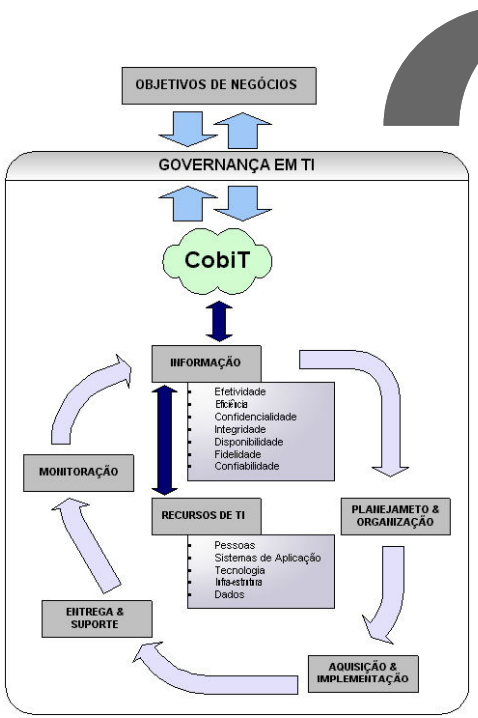
O passo final é substanciar os riscos do Objetivos de Controle que não estão sendo alcançados usando técnicas analíticas e/ou consultando fontes alternativas.

- Documentar as deficiências do controle e possíveis ameaças e vulnerabilidades
- Identificar e documentar o impacto atual e potencial



Diretrizes de Auditoria associadas com cada domínio

Cada um dos 34 processos envolvidos nos 4 domínios possui diretrizes de auditoria. Iremos apresentar a seguir o Processo de PO1 - Definir um Plano Estratégico de TI do domínio de Planejamento e Organização, este servirá como base para entender como cada processo será auditado.



Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

PO2 Definir a Arquitetura de Informação

PO3 Determinar a Direção Tecnológica

PO4 Definir Processos de TI, Organização e Relacionamento

PO5 Gerenciar o Investimento em TI

PO6 Comunicar Metas e Diretivas Gerenciais

PO7 Gerenciar Recursos Humanos

PO8 Gerenciar Qualidade

PO9 Avaliar e Gerenciar Riscos

PO10 Gerenciar Projetos

Objetivo de Controle de Alto Nível

Objetivos de Controle Detalhados

Diretrizes de Auditoria

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

Objetivos de Controle

1. TI como parte do Plano de Longo e Curto Prazo da Organização
2. Plano de Longo Prazo de TI
3. Planejamento de Longo Prazo de TI – Abordagem e Estrutura
4. Mudanças no Plano de Longo Prazo de TI
5. Planejamento de Curto Prazo para a Função de TI
6. Comunicação dos Planos de TI
7. Monitoramento e Avaliação dos Planos de TI
8. Avaliação dos Sistemas Existentes

Tanto o Objetivo de Controle de Alto-nível como o detalhado são auditados por:

Obtenção do Entendimento através de:

Entrevista com:

- Chief Executive Officer (CEO)
- Chief Operations Officer (COO)
- Chief Financial Officer (CFO)
- Chief Information Officer (CIO)
- Membros responsáveis pelo planejamento de TI
- gerência sênior de TI e equipe de serviços

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

Obtendo o Entendimento

Para definir o Plano Estratégico de TI é preciso obter o entendimento de:

- Políticas e procedimentos relacionados com o projetos de processos
- Funções e responsabilidades da gerência sênior
- Objetivos da Organização e Planos de Longo e curto prazo
- Objetivos de TI e planos de longo e curto prazo
- Relatórios de status e reuniões com o comitê de direção/planejamento

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

Avaliando os controles

Considerando se:

A função de TI ou políticas de negócio da organização e procedimentos fazem parte de um ambiente com planejamento estruturado.

Uma metodologia deve existir para formular e modificar os planos e ela deve cobrir pelo menos:

- Missão e metas da organização
- Iniciativas da TI para suportar a missão e metas da organização
- Oportunidades para as iniciativas de TI
- Estudo de viabilidade das iniciativas de TI
- Avaliação de riscos das iniciativas de TI
- Investimento adequado das iniciativas de TI para refletir as mudanças na missão e metas da organização
- Avaliação de estratégias alternativas para aplicações, tecnologia e organização

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

Avaliando a conformidade

Tentando se:

- As pautas da reuniões do comitê de planejamento/direção de TI refletem os processos de planejamento
- Os *deliverables* da Metodologia de Planejamento existem e são como prescritos
- As Iniciativas de TI relevantes estão nos planos de longo e curto prazo (exemplo: mudanças de hardware, plano de capacitação, arquitetura de informação, desenvolvimento ou compra de novos sistemas, plano de disaster recovery, etc)
- As Iniciativas de TI suportam os planos de longo e curto prazo e consideram os requisitos para pesquisa, treinamento, equipe e infra-estrutura.
- Foram identificadas implicações técnicas das iniciativas de TI
- A consideração foi realizada sobre a otimização dos investimentos de TI atuais e futuros.

Planejamento e Organização

PO1 Definir um Plano Estratégico de TI

Substanciando os riscos dos objetivos de controle que não estão sendo atingidos

Executando:

- Benchmarking dos planos estratégicos de TI em relação a outras empresas similares ou padrões internacionais das melhores práticas da indústria
- Revisão detalhada dos planos de TI para assegurar que as iniciativas de TI reflitam a missão e metas da organização
- Revisão detalhada dos planos de TI para determinar se os pontos fracos dentro da organização estão sendo identificados para aperfeiçoamento como parte das soluções de TI contidas nos planos

Identificando:

- Falhas de TI para atender a missão e metas da organização
- Falhas de TI para alinhar planos de longo prazo com planos de curto prazo
- Falhas nos projetos de TI para atender os planos de curto prazo
- Falhas de TI para atender as diretrizes de custo e prazo
- Oportunidades de negócios perdidas
- Oportunidades de tecnologia da informação perdidas

Diretrizes de Auditoria x Objetivos de Controle

Veja como as Diretrizes de Auditoria e Objetivos de Controle estão vinculados:

Obtenção de Entendimento

Coleta informações de fundamento para identificar pontos chaves do negócio, riscos, infra-estrutura, etc

Avaliação de Controles



Analisa os Objetivos de Controle para verificar se estes são apropriados para a empresa e atendem as necessidades da administração

Avaliação de Conformidade



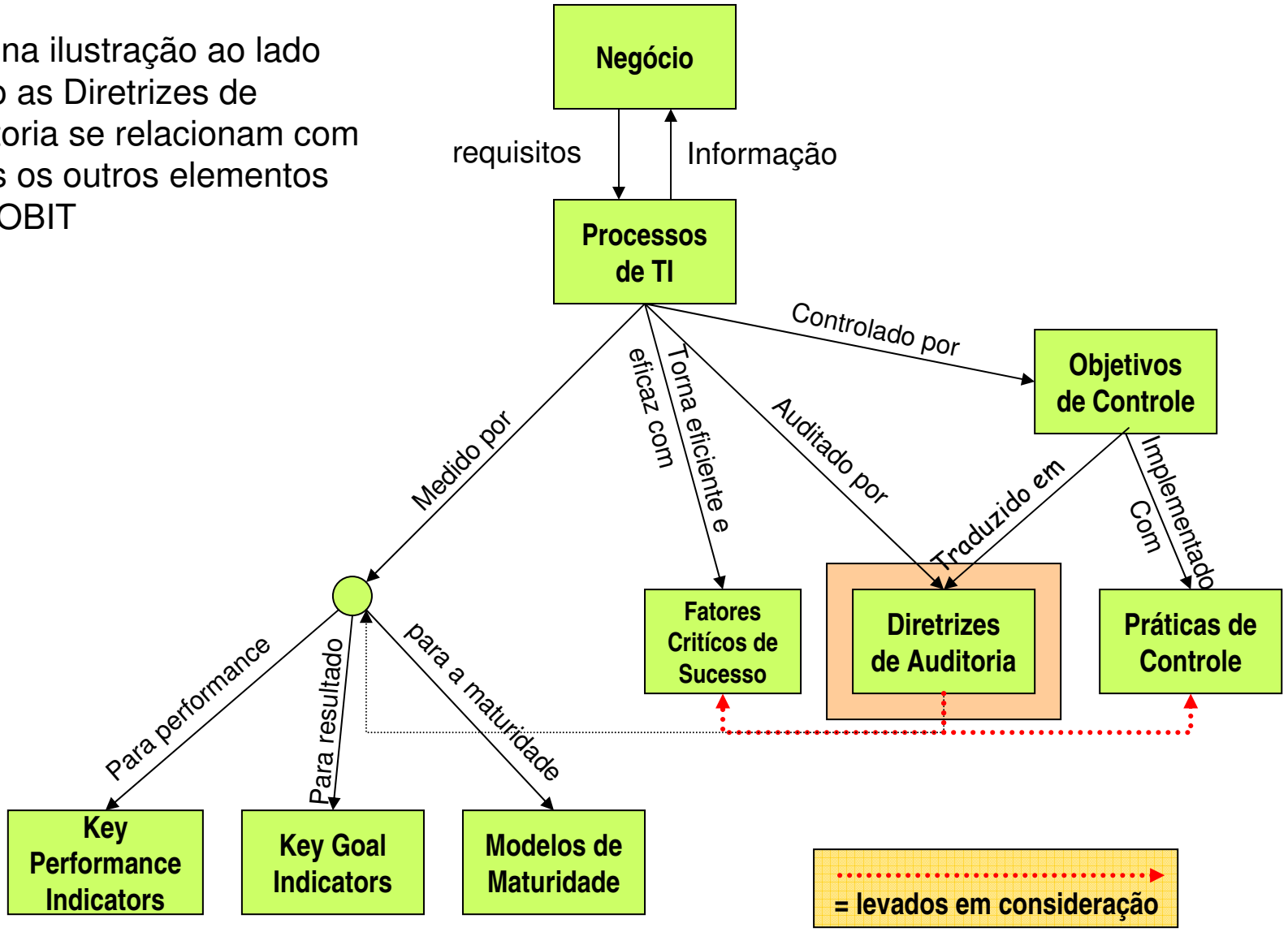
Analisa os Objetivos de Controle para testar e/ou medir se existem controles presentes para suportar os objetivos de controle e se estes estão operando de forma satisfatória

Análise de Riscos

Analisa as falhas nos objetivos do negócio, perdas, etc, devido a ausência de controle adequado

Diretrizes de Auditoria X Elementos do COBIT

Veja na ilustração ao lado como as Diretrizes de Auditoria se relacionam com todos os outros elementos do COBIT



Práticas de Controle

Práticas de Controle

As Práticas de Controle estende a capacidade do COBIT, fornecendo aos usuários um nível adicional de detalhes. Os processos de TI do COBIT, requisitos de negócios e objetivos de controle definem **o que precisa** ser feito para implementar uma estrutura de controle efetiva. As práticas de controle de TI fornece mais detalhes de **como** e **porque** são necessárias para a administração, provedores de serviços, usuários finais e profissionais de controle, para implementar controles específicos baseados na analise de operações e riscos de TI.

Vamos ver a seguir um exemplo de Práticas de Controle

Práticas de Controle

A figura abaixo fornece um exemplo de prática de controle para o processo AI6 Gerenciar Mudanças:

AI6 ManageChange

AI6.4 Emergency Changes

IT management should establish parameters defining emergency changes and procedures to control these changes when they circumvent the normal process of technical, operational and management assessment prior to implementation. The emergency changes should be recorded and authorised by IT management prior to implementation.

IT Control Practices	Why do it?
1. Management has defined parameters, characteristics and procedures that allow to identify and declare emergencies. 2. All emergency changes are documented, if not before, than after implementation 3. All emergency changes are tested, if not before, than after implementation 4. All emergency changes are formally authorised by the system owner and management, before implementation 5. Before and after images as well as intervention logs are retained for subsequent review	Controlling emergency changes by implementing the control practices will : • Ensure emergency procedures are used in declared emergencies only • Ensure urgent changes can be implemented without compromising confidentiality, integrity, availability, reliability and accuracy.

Curso Online

COBIT

FUNDAMENTOS EM GOVERNANÇA DE TI



Todos os direitos de cópia reservados. Não é permitida a distribuição física ou eletrônica deste material sem a permissão expressa do autor.

Objetivos

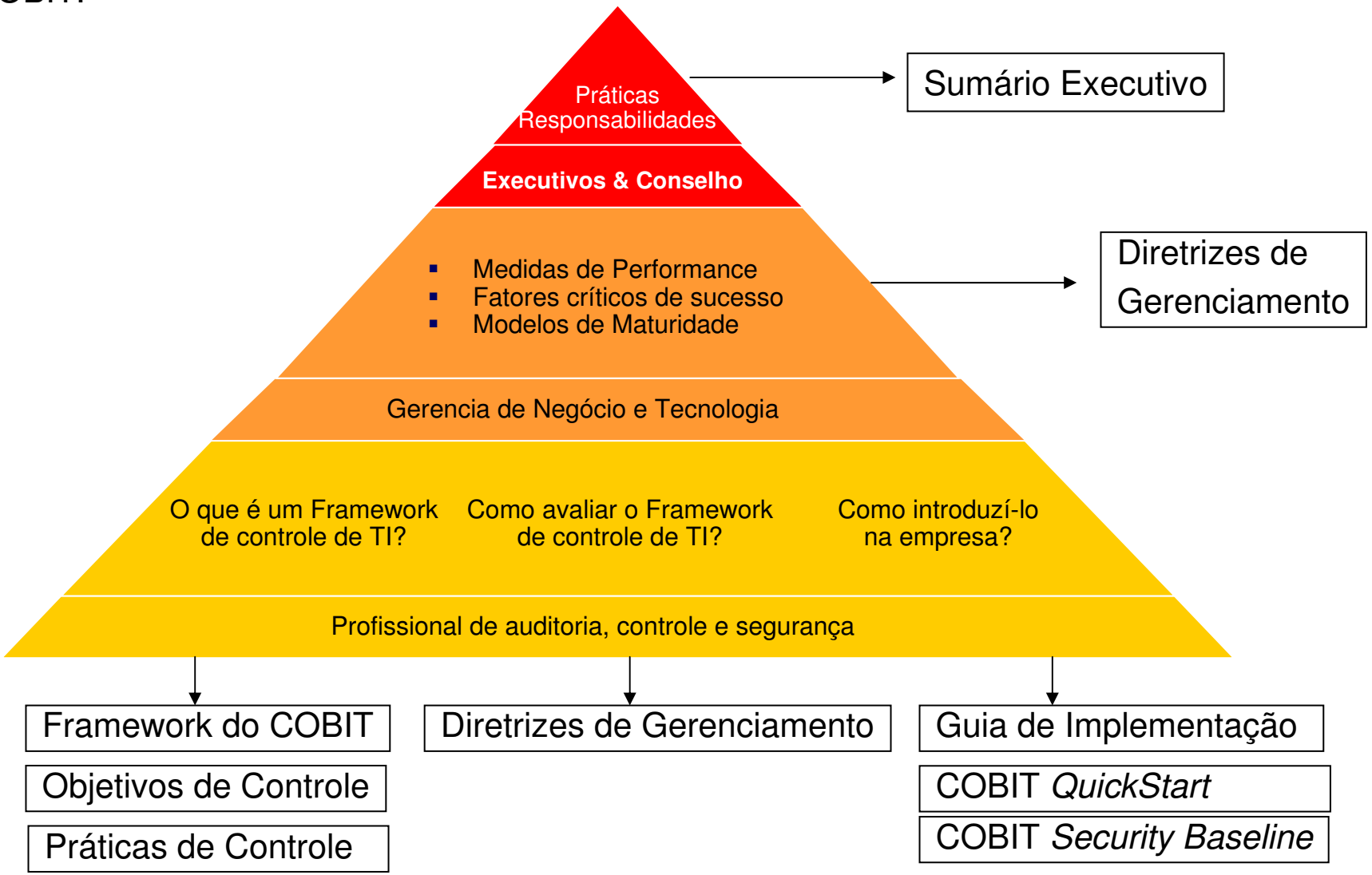
Este módulo descreve os vários produtos e serviços fornecidos pelo ISACA e ITGI para suportar o COBIT.

Durante este módulo iremos descrever os vários documentos relacionados com o COBIT, tais como o COBIT online, COBIT QuickStart, COBIT Security Baseline, Guia de Implementação de Governança de TI e Práticas de Controle.

Recursos do COBIT

Documentos relacionados com o COBIT

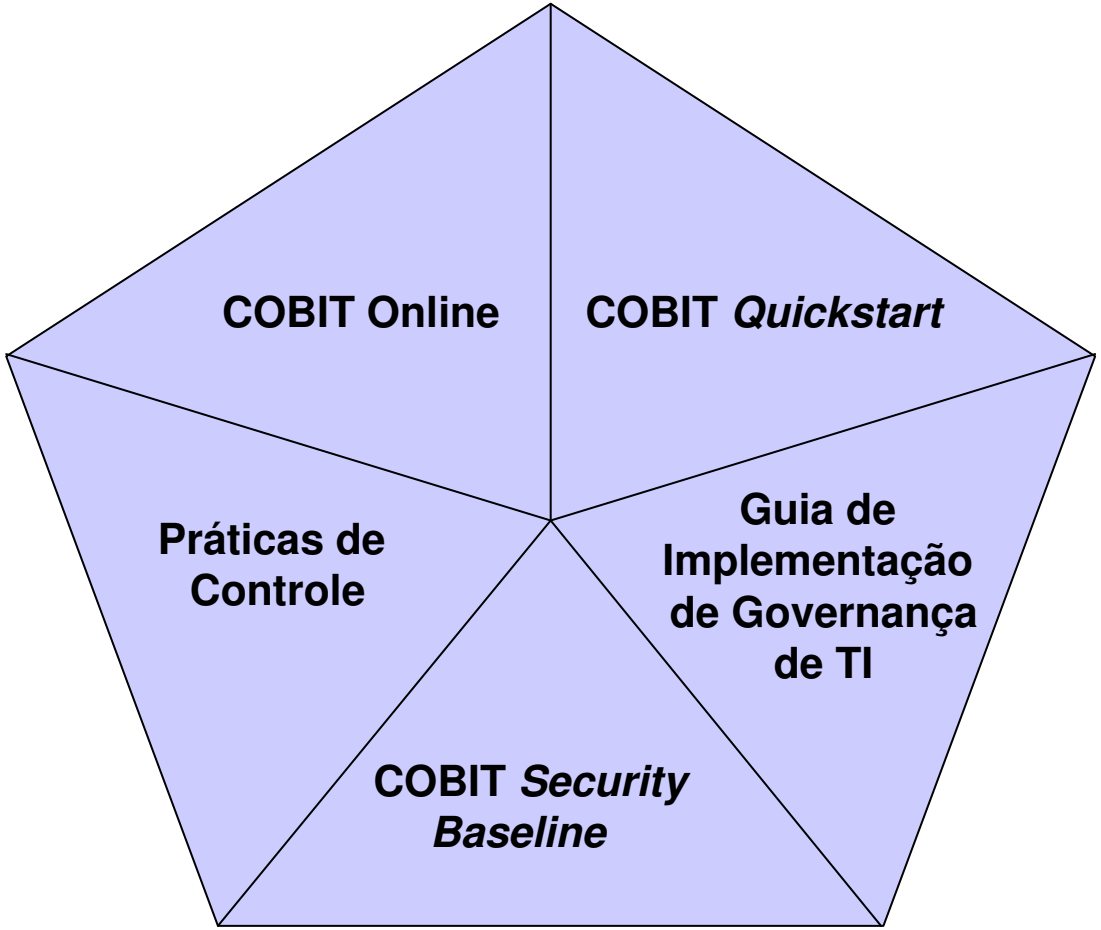
A figura abaixo apresenta a estrutura de documentos do ITGI publicada em conjunto com o COBIT.



Documentos relacionados com o COBIT

Durante este módulo iremos apresentar quais são os principais recursos e documentos relacionados com o COBIT.

A figura abaixo apresenta os recursos que iremos abordar agora:



COBIT Online

O COBIT online amplia as possibilidades de pesquisa e comparação para evitar riscos empresariais, satisfazer necessidades de controle e obter informações sobre aspectos técnicos. O COBIT online é uma base de recursos na Internet, onde é possível baixar diversos arquivos em PDF, postar dúvidas na comunidade online, obter indicadores para os objetivos de controles e realizar benchmark para avaliação de maturidade dos processos com outras empresas do setor.

O COBIT Online está disponível a partir do site www.isaca.org . Para obter acesso é necessário ser membro do ISACA ou comprar uma inscrição de acesso.



COBIT ONLINE™

COBIT Quickstart

O COBIT QuickStart possibilita você adotar facilmente os elementos mais importantes do COBIT. É uma versão resumida dos recursos do COBIT, representa 20% do conteúdo. O COBIT QuickStart foca nos Processos de TI, Objetivos de Controle e métricas, e ajuda os usuários a ganhar rapidamente os benefícios do COBIT.

- É direcionado para empresas de pequeno e médio porte onde a TI não é estratégica ou absolutamente crítica para a sobrevivência da empresa
- Fornece uma seleção dos itens básicos do COBIT
- Fornece um fundamento das principais ações a executar
- Está disponível a partir do COBIT online

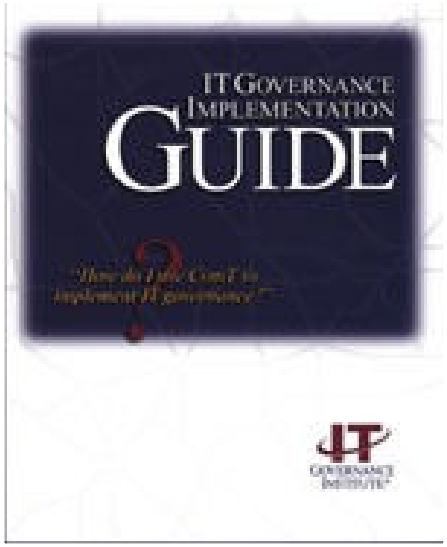
Guia de Implementação de Governança de TI

O Guia de Implementação de Governança de TI é um roadmap para o Conselho de Administração, gerência executiva, profissionais de TI e controle, profissionais de auditoria em TI e gerentes de conformidade.

Este guia fornece uma metodologia, um roadmap detalhado e um conjunto de ferramentas para implementar um ciclo de vida de Governança de TI contínuo usando o COBIT.

Este guia foca e uma metodologia genérica nas seguintes áreas:

- Por que a Governança de TI é importante e por que as organizações devem implementá-la.
- Como o COBIT está vinculado com a Governança de TI e como o COBIT possibilita a implementação da Governança de TI.
- Stakeholders que tem interesse na Governança de TI.
- Um roadmap para implementar a Governança de TI usando o COBIT.



Cobit Security Baseline

O COBIT Security Baseline ajuda uma organização a se focar nos passos essenciais para extrair as informações mais importantes relacionadas a segurança do framework do COBIT. Este documento é uma destilação do COBIT para vários grupos de usuários, sugerindo os passos de controles mínimos para cada processo e objetivos de controle detalhados do COBIT. Inclui também um mapa de controles relacionados com a ISO 17799.

É um kit de sobrevivência para os seguintes grupos de usuários:



Kit de sobrevivência

Práticas de Controle

As práticas de controle descrevem quase 1.600 “Práticas de Controle”, que estende a hierarquia de Domínio-Processo-Objetivo de Controle. São mecanismos que dão suporte para alcançar os objetivos de controle, como prevenção, detecção e correção de eventos não desejados através do uso adequado dos recursos, gerenciamento de riscos apropriado e alinhamento de TI com o negócio.

As práticas de controle detalham:

- Como cada processo pode ajudar a controlar e a gerenciar riscos
- Gerenciamento de riscos através da redução da probabilidade das conseqüências adversas das ameaças e vulnerabilidades
- Aumento dos benefícios através dos ganhos de eficiência e/ou eficácia
- Indicadores de performance das Diretrizes de Gerenciamento do COBIT
- Existem pelo menos duas práticas de controle detalhadas para cada objetivo de controle

